Hollow Internal Security Review 2026-10

Internal security review
Hollow version: 0.13.0
Date: October 30, 2026
Scope: the 0.13.0 release, tag `v0.13.0-beta`
Review period: 2026-09-26 to 2026-10-24
Author: Vitalii Rovinskyi
This report was generated with the assistance of Claude (AI), and the review it describes was carried out with Claude agents directed by the author. Every decision on what Hollow must allow, every severity and every conclusion is the author's. This is not an audit by an independent firm.

Contents

1. Executive summary 3
2. Scope 5
3. Method 6
4. Findings table 9
5. Findings 16
6. Accepted risks and open items 64
7. Code-maturity scorecard 77
8. Appendices 79

1. Executive summary

What was reviewed

Hollow is a distributed, end-to-end encrypted chat and voice application: Rust core (`rust/hollow_core`), Flutter app on six platforms, and a C++ WebSocket relay (`relay-uws`) that members or Hollow run. This review covered the Rust core, the relay and its host, the parts of the Flutter app that make security decisions or handle untrusted input, the push path, and the release and update signing. It ran from 2026-09-26 to 2026-10-24, across the releases 0.12.0 (2026-10-05), 0.12.1 (2026-10-16), 0.12.2 (2026-10-20) and the 0.13 wave (2026-10-22 to 2026-10-24).

Headline numbers

The review filed 182 findings, numbered HOL-SEC-001 to HOL-SEC-186. The numbers 166 to 169 were never used (see section 3.10). Every finding is fixed. What a fix did not remove is recorded as a residual in the finding and, where it is a decision, in the accepted-risk register (section 6).

Every finding also has a class, so that the totals do not read as if every bug were a break of confidentiality:

- **C**: confidentiality, integrity or authenticity, access control included (someone reads, forges, changes or decides something they must not).
- **A**: availability and robustness (a crash, a stall, lost or diverging state, an exhausted resource).
- **P**: privacy and metadata (who, when, where, presence, addresses, location).
- **S**: scale (a cost that grows too fast under honest load).

Severity	C	A	P	S	Total
Critical	7	1	0	0	8
High	26	6	0	0	32
Medium	45	19	11	1	76
Low	37	19	7	1	64
Info	2	0	0	0	2
Total	117	45	18	2	182

Where the fixes shipped:

Fixed in	Findings	Critical	High	Medium	Low	Info
0.12.0 (relay fixes deployed ahead of it)	162	8	29	68	55	2
0.12.1	6	0	1	3	2	0
0.13 (relay deployed 2026-10-23)	14	0	2	5	7	0

Verdict

The cryptographic building blocks Hollow uses (vodozemac for Olm, OpenMLS for groups, Ed25519, X25519, AES-GCM, Argon2id, SPAKE2) were not where the problems were. The problems were in the application layer around them, and they were serious. Before 0.12.0 a message's valid signature or MLS authentication was often taken as permission to act. That let any identity wipe another's device (HOL-SEC-001), let the relay open Olm sessions in other devices' names (HOL-SEC-003) and seat itself in any server's encryption group (HOL-SEC-041), and let the relay speak in any member's name on plaintext frames (HOL-SEC-053). These and the other Criticals were fixed in 0.12.0 by redesigns rather than patches: every relay frame is sealed by its sending device, MLS leaves are bound to device keys and certified by their master, server state is a fold of signed operations from a provable anchor, a person's

devices are a roster rooted in a recovery phrase no device stores, server joins go through a join lock, and locked server rooms hide their members from outsiders.

The 0.13 wave found no Critical. Of its 14 findings, 9 are availability and robustness (class A), 2 are scale (class S) and 3 are class C, all three Low. Two are High: a remote crash of the node through a panic in a third-party image decoder (HOL-SEC-173), and memory exhaustion of the relay box with large broadcasts (HOL-SEC-183). Both are fixed, and the relay fix is deployed.

We believe Hollow 0.13 keeps the promises in `audit/claims.md` as far as tests can show, with the residuals listed per finding and in section 6. This belief rests on an internal review, and the limits below are real.

Limits of this review

- **One model family on both sides.** The builders and the hostile reviewers were Claude models. Fresh contexts and adversarial briefs help, but blind spots are likely correlated. This is the main reason an external audit is planned (section 3.11).
- **No formal model.** None of the protocols (frame sealing, the roster and recovery phrase, the join lock, the MLS authority rules) has a Tamarin or ProVerif model.
- **Fuzzing is partial.** The relay's nine network-facing parsers run under libFuzzer with ASan and UBSan nightly (about 1.36 billion executions in the first run, no memory-safety report). In the Rust core only the image check has a fuzz target; the wire parsers (sealed frames, envelopes, CRDT batches, rosters, archives) are not fuzzed yet.
- **No penetration test of the deployed relay box** beyond the host checks in `relay-uws/deploy/check-host.sh`, and no bug bounty.
- **Native code is covered only at its edges** (section 2).
- **The authorisation matrix is agent-built.** Its citations were checked mechanically (1,737 citations, none wrong) and the open rows and a sample of fixed rows were re-read by hand; the other rows are agent-verified, and the matrix says so.

2. Scope

In scope

- `rust/hollow_core`: the node (frame sealing and every receive handler), Olm and MLS handling, identity, rosters and recovery, CRDT server state, storage, at-rest file encryption, the FFI surface, the push fetch node and the iOS extension's Rust half, the embedded and standalone media forwarder.
- `relay-uws`: the C++ relay, its snapshot codec, its tables and fair-share eviction, its deploy units, the Docker path, and the production host's accounts, sandboxes, secrets and logs.
- The Flutter app where it decides something or handles untrusted input: links and deep links, notifications and App Lock, file saves, data-channel file intake, call signals and share audio, SFrame key handling, the wipe.
- Distribution: the signed update manifest and feeds, the updater's archive handling, the flatpak repository (phase E+F distribution pass).
- The push sidecar's handling of tokens and logs.

Out of scope or covered only in part

- **Native media and decoding code.** The forked `flutter_webrtc` and our patched libwebrtc build were reviewed only where Hollow configures them (SFrame keys and key slots, logging of keys, the frame ratchet, forwarder legs). ffmpeg was moved behind a tap rather than reviewed. Skia and its libwebp are now reached only after a pure-Rust image check (HOL-SEC-173). The share-audio helper process was reviewed at its pipe protocol.
- **What the multi-node harness cannot see.** It does not run the relay C++ (relay rules are tested in the relay's own C++ suites and in a mock relay that mirrors them), it does not cover attribution from a device to its master where that depends on the process-global resolver, and it does not exercise the media plane.
- **The deployed relay box** was checked with `check-host.sh` and hardened (HOL-SEC-073 to 075), not penetration-tested from outside.
- **Third-party services** (the FFZ, Klipy and IGDB proxies, the shop and its Ko-fi webhook, Google and Apple push) only where Hollow's own code meets them; the shop's trust in Ko-fi is AR-23.
- **The websites** (join page, web viewer) only where they carry invite and meeting keys.
- **Traffic analysis, a compromised unlocked running device and post-quantum security** are not promised (AR-04).
- **An attacker with many address blocks** can still churn the relay's fair-share tables; that lets it read, forge or block nothing (HOL-SEC-070, HOL-SEC-183 residuals).

3. Method

3.1 Threat model

The threat model (`audit/threat_model.md`) names twelve attacker profiles and ten trust boundaries. The profiles: P-01 a hostile relay operator (fully active, its own identities), P-02 a network attacker, P-03 a stranger who knows an id, P-04 a malicious friend, P-05 a malicious server member, admin or owner, P-06 a formerly trusted peer, P-07 a linked sibling device, P-08 an own device that was removed but is still usable, P-09 a physical holder of a device, P-10 hostile infrastructure other than the relay (update host, CDN, TURN, a forwarder), P-11 push providers, P-12 third-party websites. Every peer and the relay sit across a trust boundary, so every byte they send is attacker-controlled.

The promises being tested are the claims in `audit/claims.md` (C-01 to C-37, 36 since C-23 was withdrawn), approved by the author on 2026-09-26. Every finding traces to a claim, an asset or an attack tree.

3.2 Research first, then a written method

The method (`reports/planned/security/SECURITY_AUDIT_PLAN.md`) came from reading published messenger audits (Trail of Bits on SimpleX, Cure53 on Briar and Threema, NCC Group on Olm and Keybase, Least Authority on vodozemac, SRLabs on OpenMLS, Quarkslab on Session, Radically Open Security on Galene) and the academic attacks on Matrix, Threema, Signal groups and WhatsApp multi-device. The common lesson is that the serious bugs in end-to-end encrypted messengers are in the application layer, where a valid signature or group authentication is mistaken for authority over the object a message names.

3.3 Phases

- **A. Claims and threat model** (2026-09-26): claims, attacker profiles, trust boundaries, data flows, attack trees, the accepted-risk register.
- **B. Authorisation matrix** (2026-09-26 to 2026-10-03): nine enumeration passes wrote about 275 evidence sections and about 200 suspicions, grouped by root cause; a re-check pass and a full rebuild followed (`audit/authz_matrix.md`).
- **C. Hostile peers in the harness**: tests named `authz_*` in which a peer signs correctly as the wrong principal (a stranger, a non-member, a removed device, another identity's master, the relay) and must be refused with no state change.
- **D. Variant analysis**: every confirmed finding was followed by a search for its siblings; many later findings name the earlier one they vary.
- **Designs** where a class could not be closed by patches: A (every frame names its sender), D (MLS leaf identity and group authority), E (CRDT state as a fold of signed ops), ID-1 and ID-1R (the device roster and the recovery phrase, mirrored on the relay), D1 (door-proof server rooms), and the join lock. Each design went through a hostile design review before it was built.
- **H. Relay host hardening** (2026-09-30).
- **E and F, merged** (2026-10-04): STRIDE and LINDDUN walks and the protocol checklists (RFC 9420 and 9750, RFC 9605, Olm) by work package, in eight read-only slices (`audit/phase_ef/`); every candidate went to a finding, an accepted risk or a recorded non-finding (`audit/phase_ef/dispositions.md`).
- **G. Relay traffic, limits and fuzzing, and close-out** (0.13 wave, 2026-10-22 to 2026-10-24): measured traffic, a circuit breaker in shadow mode, a send budget, relay fuzzing, the scale fixes, this report.

3.4 Severity

Severity follows NCC Group's Impact x Exploitability scheme (plan section 2.7). Impact says how bad the worst outcome is; Exploitability says how easily an attacker can reach it unilaterally. Critical is an immediate, easily reached threat of total compromise, such as a remote wipe by any identity. CVSS is

used only in published advisories. A defect that needs no attacker is scored on its impact and on how often it happens by itself.

3.5 A failing test before every fix

A finding counts only once a test reproduces it. Each finding file names that test instead of walking through the steps; the test fails on the old code and passes with the fix. Distributed behaviour is proven in the multi-node harness (`node/test_harness.rs`, 704 harness tests at the close), which runs many nodes against a mock relay that can drop, delay, reorder, replay and inject frames. Relay rules are proven in the relay's C++ suites (unit tests and live tests against a running relay), plain and under AddressSanitizer and UndefinedBehaviorSanitizer, run on the VPS before every deploy. Rules mirrored in Rust and C++ (relay auth, rosters, kill orders, ring control, door proofs, breaker prices) share pinned vectors that both test suites check.

3.6 Mutation passes

After a fix, a script breaks each security check one at a time (an exact source replacement), runs the tests named for it, expects them to fail, and restores the file byte for byte. A check whose tests still pass when it is broken is a check nothing guards. Each finding records its pass (for example 22/22 killed); a survivor was either covered by a new test or argued equivalent in the finding. A rule enforced in two layers is tested in each layer alone. The scripts are kept in `audit/mutation_passes/`; they match the source of their day and do not run against today's tree.

3.7 Hostile review with one fix round

Every track of the 0.12.x and 0.13 work went through a hostile reviewer with a fresh context after the design and again after the code, then one fix round, then a narrow re-review of the fixes. Low leftovers became follow-ups instead of more rounds. Review also caught serious defects in new code before it merged or shipped, which are not counted as findings because no released version had them. Examples from the 0.13 wave: the first version of the relay send budget let one malformed message end the relay process and let one IPv4 address hold the whole budget; a first draft of the MLS cost work kept the next epoch's secrets and path keys in a saved past copy for three commits; the first range-digest sync let a member freeze the event loop with a crafted range; the first stand-in authority design handed a leafless member's KeyPackage to a ground id; the first breaker kept an unbounded tracker per paying share (about 49 GB on one /48) and took 1.6 s per room bound; an ASan run caught a use-after-free in the send budget's fan-out sizing.

3.8 The real apps

Fixes that change behaviour were driven on throwaway identities in the real apps: a Windows fleet of desktop peers (28 scenarios at the 0.13 merge, all passing), macOS and Linux peers, the iOS Simulator and Android emulators on the Mac mini, and real phones for push and lock-screen behaviour. At the 0.13 merge (commit c4e2f7f5) the full Rust suite passed 2,749 of 2,758 on the Windows PC (the other nine are seven keystore tests that cannot run over SSH and two load-sensitive tests that pass alone), the Flutter suite passed 2,767 with none failing, every iOS phone scenario passed, and a mixed Android and iPhone run passed 10 of 10 in both roles. The commit in scope adds the self-hosted relay installer on top of c4e2f7f5; it changes no relay C++ or relay test file.

3.9 Fuzzing

The relay's network-facing parsers (auth frames, binary opcode frames, client JSON, ring control, join-lock links, rosters, kill orders, the restart snapshot, crypto inputs) run under libFuzzer with ASan and UBSan in nine targets, nightly and privately on the Mac mini so a crash input is never published before its fix is deployed. Every seed and saved crash input is replayed by the relay test script, plain and sanitized. The Rust image check has a cargo-fuzz target, which found HOL-SEC-173.

3.10 Finding numbers

Findings are numbered in the order they were filed. HOL-SEC-166 to HOL-SEC-169 were never used. They fell in a range set aside during the review of the resumable relay sessions on 2026-10-07, which filed HOL-SEC-164, 165 and 170 to 172. That review also drafted 173 and 174 as duplicates of 164 and 165 and withdrew them before any finding file existed, so no finding was withdrawn from the published set. This report assigns HOL-SEC-173 to 186 to the findings of the 0.13 wave. No number has two findings, and no finding was deleted.

3.11 Disclosure and the external audit

Findings, fixes and the threat model stayed on local branches until the release that fixed them; a pre-push hook kept the security branch off GitHub until each release. Hollow's first external report (July 2026, three rounds, credited to Folf) produced six GitHub security advisories; four are published (GHSA-39pq-74wg-66gv, GHSA-pw74-83g2-x56q, GHSA-rp8v-8rcw-gj6x, GHSA-3jhj-9w4q-rqjw) and two await CVE numbers. The eight Critical findings of this review are covered by seven draft advisories (HOL-SEC-001 and 006 share one). 0.13.0 shipped the fixes on 2026-10-30; the advisories publish once their CVE numbers are assigned. The `image-webp` panic behind HOL-SEC-173 was reported upstream independently (image-rs/image-webp#182) and a fix waits in an open pull request; Hollow keeps decoding inside its panic guard until a fixed release ships. An external audit with the support of OSTIF is planned, with this folder as the readiness pack.

4. Findings table

Status is Fixed for every finding. "Fixed in" names the first release that carries the fix, or the date a relay-only fix was deployed to the official relay; where the finding file names commits, they are given. For 0.13 the commits are on `main` since the 0.13.0 release. Where a 0.12.0 fix also changed the relay, the relay was deployed before the client release.

ID	Title	Severity	Class	Status	Fixed in
HOL-SEC-001	Any identity could remotely wipe a device with its own signed device list	Critical	C	Fixed	0.12.0 (0bb09321)
HOL-SEC-002	A relay operator can decrypt every device-link snapshot, master key included	High	C	Fixed	0.12.0
HOL-SEC-003	A relay operator can open an Olm session in any device's name and read that device's DMs, history included	Critical	C	Fixed	0.12.0
HOL-SEC-004	A sync responder could rewrite, re-attribute, card or delete any message it knew the id of	High	C	Fixed	0.12.0
HOL-SEC-005	Any identity could delete another user's identity and messages, or take their identity with one click, through the device-link flow	Critical	C	Fixed	0.12.0
HOL-SEC-006	A stranger's device list could claim a friend's master id, taking over the friendship and, on the victim's replica, the friend's server role	Critical	C	Fixed	0.12.0
HOL-SEC-007	Any peer could kill another user's node with one profile announce, and a member could name a file outside the data folder	High	A	Fixed	0.12.0
HOL-SEC-008	A friend could rewrite or re-caption messages it did not write, our own included, through live and push delivery	Medium	C	Fixed	0.12.0
HOL-SEC-009	Anyone who knew a server's id could post into any of its channels, private and admin-only ones included	High	C	Fixed	0.12.0
HOL-SEC-010	A member of any group we shared could post into another server or a restricted channel through MLS	High	C	Fixed	0.12.0
HOL-SEC-011	A member or friend could make every receiver store a message of any size, and long non-Latin messages were cut and lost their signature	Low	A	Fixed	0.12.0
HOL-SEC-012	Anyone in a server's room could make a member reveal who posts in any channel, restricted ones included, and stall its sync	Medium	P	Fixed	0.12.0
HOL-SEC-013	A decrypted payload that was not an envelope was shown as a DM with no signature and no block check	Medium	C	Fixed	0.12.0
HOL-SEC-014	A public channel served the text of deleted messages to any guest	Low	P	Fixed	0.12.0
HOL-SEC-015	Anyone in a server's room could fake typing and unread or mention badges in any channel	Low	C	Fixed	0.12.0
HOL-SEC-016	A member who could not see a restricted voice channel could still take a seat in it and be dialed	Medium	C	Fixed	0.12.0
HOL-SEC-017	A server member or a meeting guest could be seated in the encryption group under someone else's name	High	C	Fixed	0.12.0
HOL-SEC-018	A member could pin a post below everything that followed it and post past slow mode	Low	C	Fixed	0.12.0
HOL-SEC-019	An Olm peer could grow a server's op log without bound through a fallback nobody sends	Low	A	Fixed	0.12.0
HOL-SEC-020	A member could sign server ops whose clock names someone else, or a counter that wraps ours	Low	C	Fixed	0.12.0
HOL-SEC-021	An Admin could make every member delete a server's files and message history	Medium	C	Fixed	0.12.0

ID	Title	Severity	Class	Status	Fixed in
HOL-SEC-022	A friend or server member could replace or empty a file someone else sent	High	C	Fixed	0.12.0
HOL-SEC-023	Any peer in a shared room could write into another sender's file stream, and fill our disk	Medium	C	Fixed	0.12.0
HOL-SEC-024	A server member could overwrite, relink and delete vault content, and make a download write outside its folder	High	C	Fixed	0.12.0
HOL-SEC-025	Members who cannot see a restricted channel received the keys to its files	High	C	Fixed	0.12.0
HOL-SEC-026	Any peer we shared a room with could join, steer or stop our recovery pool	Medium	C	Fixed	0.12.0
HOL-SEC-027	A replayed share manifest stopped a seeder, and an early Have allocated half a gigabyte	Low	A	Fixed	0.12.0
HOL-SEC-028	One malformed frame from anyone on the internet stopped the relay and emptied its buffers	Critical	A	Fixed	Relay, 2026-09-27
HOL-SEC-029	Anyone could cancel or pre-empt the destroy order waiting for a lost device	High	C	Fixed	0.12.0; relay 2026-09-27
HOL-SEC-030	Anyone who knew a server id could flush its catch-up rings, and guests could post to them	Medium	A	Fixed	Relay, 2026-09-27
HOL-SEC-031	A revoked device could read its master's mailbox again after every relay restart	Medium	C	Fixed	Relay, 2026-09-27
HOL-SEC-032	A revoked device came back through the sibling proof and after a restart	High	C	Fixed	0.12.0
HOL-SEC-033	A carried device list was taken as its master even when it did not bind the sender	Medium	C	Fixed	0.12.0
HOL-SEC-034	An old destroy notice applied again after the identity returned, and any list said it had	Low	C	Fixed	0.12.0
HOL-SEC-035	The push path ignored blocks, key changes, the mention setting and who sent the wake	Medium	C	Fixed	0.12.0
HOL-SEC-036	Anyone could befriend us with an accept, and a block missed half the DM surface	High	C	Fixed	0.12.0
HOL-SEC-037	Call signals were bound by call id alone, and a share could be re-pointed by any participant	Medium	C	Fixed	0.12.0
HOL-SEC-038	Profile avatars were not checked against their signature, and stale or long profiles misbehaved	Medium	C	Fixed	0.12.0
HOL-SEC-039	A replayed edit reverted text, and a replayed reaction came back	Low	C	Fixed	0.12.0
HOL-SEC-040	Being in a room with us was enough for a data channel, a gossip seat and our voice presence	Medium	P	Fixed	0.12.0
HOL-SEC-041	An encryption-group seat proved nothing about who held it	Critical	C	Fixed	0.12.0
HOL-SEC-042	Any member could evict members from an encryption group or add anyone to it	High	C	Fixed	0.12.0
HOL-SEC-043	A Welcome from anyone replaced a working encryption group	High	C	Fixed	0.12.0
HOL-SEC-044	Any frame that failed to process made a member drop its encryption group	Medium	A	Fixed	0.12.0
HOL-SEC-045	Encrypted voice signaling was credited to whoever the relay named	Low	C	Fixed	0.12.0
HOL-SEC-046	A joiner took its whole server state, owner included, from whoever answered	High	C	Fixed	0.12.0
HOL-SEC-047	The relay could replay old server ops and pick each member's outcome by reordering	High	C	Fixed	0.12.0

ID	Title	Severity	Class	Status	Fixed in
HOL-SEC-048	A member could backfill posts signed by someone who was never in the server	High	C	Fixed	0.12.0
HOL-SEC-049	Any member could admit anyone past a ban, a private server or the Twitch gate	Medium	C	Fixed	0.12.0
HOL-SEC-050	Strangers, ex-members and device keys could author server ops	Medium	C	Fixed	0.12.0
HOL-SEC-051	An admin could demote, ban or mute the owner through a device id	Medium	C	Fixed	0.12.0
HOL-SEC-052	Moderation edges skipped rank, and ownership could be minted or dropped	Low	C	Fixed	0.12.0
HOL-SEC-053	Every plaintext frame was attributed to the sender the relay stamped	Critical	C	Fixed	0.12.0
HOL-SEC-054	Frames the relay held back or replayed were acted on again	Medium	C	Fixed	0.12.0
HOL-SEC-055	Any holder of a server id was served the whole op log	Medium	C	Fixed	0.12.0
HOL-SEC-056	A sibling's server announce reopened a server we already held	High	C	Fixed	0.12.0
HOL-SEC-057	A full profile went to anyone who asked	Low	P	Fixed	0.12.0
HOL-SEC-058	Screen-share audio played from any open data channel	Medium	C	Fixed	0.12.0
HOL-SEC-059	The push fetch node cleared every parked destroy order	Medium	C	Fixed	0.12.0
HOL-SEC-060	Any holder of a file could answer for it with other bytes	High	C	Fixed	0.12.0
HOL-SEC-061	Anyone in a meeting's room could run its lobby and admit the knocker	High	C	Fixed	0.12.0
HOL-SEC-062	The relay read friend lists, server state, profiles and join requests	Medium	P	Fixed	0.12.0 (e39ed7cb, c54bcbe9, 73591cbe, daa9917f, 54aef252, 7b3cb37f)
HOL-SEC-063	A captured relay login opened an invisible socket in the device's name	Medium	C	Fixed	0.12.0
HOL-SEC-064	A person's inbox room showed strangers their devices and when they were online	Medium	P	Fixed	0.12.0
HOL-SEC-065	Anyone in a server's room could stretch, stop or flood its catch-up rings	Medium	A	Fixed	0.12.0
HOL-SEC-066	The client acted on values the relay chose	Medium	C	Fixed	0.12.0
HOL-SEC-067	The recovery pool's token rode in the room name the relay reads	Medium	C	Fixed	0.12.0
HOL-SEC-068	Future stamps and replays undid read positions, emotes, reactions and link cards	Low	C	Fixed	0.12.0
HOL-SEC-069	One account could fill the relay's memory and crash it for everyone	High	A	Fixed	Relay, 2026-09-29
HOL-SEC-070	Throwaway identities could push real entries out of the relay's tables	Medium	A	Fixed	Relay, 2026-09-29
HOL-SEC-071	A legacy server's catch-up rings went to whoever signed for them first	Low	A	Fixed	0.12.0; relay 2026-09-29
HOL-SEC-072	The relay read meeting knocks, lobby frames and the host	Medium	P	Fixed	0.12.0
HOL-SEC-073	The relay, push sender and forwarder ran as an account with root	High	C	Fixed	Relay host, 2026-09-30
HOL-SEC-074	Every local account could read the relay's TLS key and secrets	Medium	C	Fixed	Relay host, 2026-09-30

ID	Title	Severity	Class	Status	Fixed in
HOL-SEC-075	Push token prefixes and client addresses were written to the relay's disk	Medium	P	Fixed	Relay host, 2026-09-30
HOL-SEC-076	The recovery phrase and the device's Olm and MLS state rode every backup and link snapshot	High	C	Fixed	0.12.0
HOL-SEC-077	A stolen device or a leaked backup held the identity for good	Critical	C	Fixed	0.12.0
HOL-SEC-078	The relay let a master-key holder read a protected identity's inbox and lock its devices out	Medium	C	Fixed	0.12.0; relay 2026-10-02
HOL-SEC-079	Statements from anyone could push a removal or a vouch out of a roster	High	C	Fixed	0.12.0
HOL-SEC-080	A removed device could bring a new device in through that device's own removal of it	Medium	C	Fixed	0.12.0
HOL-SEC-081	Destroying a device dropped the devices it had linked	Low	A	Fixed	0.12.0
HOL-SEC-082	A recovery did not restart a restored backup's seven days	High	C	Fixed	0.12.0; relay 2026-10-02
HOL-SEC-083	The master key alone could act as the bare master id	High	C	Fixed	0.12.0
HOL-SEC-084	A removed device still committed to MLS groups	Low	C	Fixed	0.12.0
HOL-SEC-085	Any server member could make us forward a file to its gossip neighbours	Medium	C	Fixed	0.12.0
HOL-SEC-086	A push wake from anyone moved the live Android node into a room with them	Low	P	Fixed	0.12.0
HOL-SEC-087	A blocked friend could still pull our DM history	Low	C	Fixed	0.12.0
HOL-SEC-088	A refused server op still moved our clock	Low	C	Fixed	0.12.0
HOL-SEC-089	A frame that failed to decrypt made us send its sender what we hold	Low	P	Fixed	0.12.0
HOL-SEC-090	Every server member learned who sat in a restricted voice channel	Low	P	Fixed	0.12.0
HOL-SEC-091	Anyone holding a server id saw who was in its room and when	Medium	P	Fixed	0.12.0
HOL-SEC-092	Any member could list anyone as a member of a server	Low	C	Fixed	0.12.0
HOL-SEC-093	A member's snapshot of an older server set the joiner's roles and bans	Low	C	Fixed	0.12.0
HOL-SEC-094	A channel restricted after it was public stayed public	Medium	C	Fixed	0.12.0
HOL-SEC-095	A guest stored public posts unjudged and showed names any member chose	Low	C	Fixed	0.12.0
HOL-SEC-096	Junk from a few addresses could push a lost device's destroy order out	Medium	C	Fixed	0.12.0; relay 2026-10-03
HOL-SEC-097	A kick notice made a member drop a server with no removal behind it	Low	C	Fixed	0.12.0
HOL-SEC-098	A channel id could name the join ring or break every ring of a server	Low	A	Fixed	0.12.0
HOL-SEC-099	Rust took any string as a server id	Low	C	Fixed	0.12.0
HOL-SEC-100	A removed author could still rewrite and re-card its old posts	Low	C	Fixed	0.12.0
HOL-SEC-101	Reactions skipped channel visibility live and membership in backfill	Low	C	Fixed	0.12.0
HOL-SEC-102	A stream could declare any size and get a temp file for it	Medium	A	Fixed	0.12.0
HOL-SEC-103	Completed streams with no header parked without a limit	Medium	A	Fixed	0.12.0
HOL-SEC-104	A streamed vault shard bypassed our storage pledge	Low	A	Fixed	0.12.0
HOL-SEC-105	An unasked shard answer blocked a vault download for good	Medium	A	Fixed	0.12.0

ID	Title	Severity	Class	Status	Fixed in
HOL-SEC-106	A recovery plan's content id reached a temp path unchecked	Low	C	Fixed	0.12.0
HOL-SEC-107	The push process had no file header size cap	Low	A	Fixed	0.12.0
HOL-SEC-108	Data channel answers paired with our offer by connection id alone	Low	C	Fixed	0.12.0
HOL-SEC-109	The standalone forwarder took unsealed and replayed frames	Low	C	Fixed	0.12.0
HOL-SEC-110	Voice channel SDP and ICE over Olm had no signal rate limit	Low	A	Fixed	0.12.0
HOL-SEC-111	A key request from anyone minted a fresh one-time key	Low	A	Fixed	0.12.0
HOL-SEC-112	A friend request from before a removal came back	Low	C	Fixed	0.12.0
HOL-SEC-113	A sibling that missed a removal brought the friend back	Low	C	Fixed	0.12.0
HOL-SEC-114	A member removed while offline never learned it	Low	A	Fixed	0.12.0
HOL-SEC-115	A friend removal reached only the device it happened on	Medium	C	Fixed	0.12.0
HOL-SEC-116	The Dart data channel receiver trusted every stream's size and sender	Medium	A	Fixed	0.12.0
HOL-SEC-117	A planted or wrong vault shard blocked a download for good	Medium	A	Fixed	0.12.0
HOL-SEC-118	Olm channel changes for a server we no longer hold were applied	Low	C	Fixed	0.12.0
HOL-SEC-119	A channel delete or a refused reaction reached the screen unchecked	Info	C	Fixed	0.12.0
HOL-SEC-120	Leaving a voice channel while watching a share kept our forwarding offer	Low	C	Fixed	0.12.0
HOL-SEC-121	A member back from away answered a removed joiner's old parked ask	Low	C	Fixed	0.12.0
HOL-SEC-122	Anyone in the room could open an unlimited stream for a file we pulled	Low	A	Fixed	0.12.0
HOL-SEC-123	Meetings took a device its identity's roster no longer counts	Medium	C	Fixed	0.12.0
HOL-SEC-124	A re-sealed MLS commit or Welcome made us send what we hold	Low	P	Fixed	0.12.0
HOL-SEC-125	The bare master id came back into room presence through discovery	Low	C	Fixed	0.12.0
HOL-SEC-126	Anyone could see who used a media forwarder and when	Medium	P	Fixed	Relay, 2026-10-04
HOL-SEC-127	A socket a locked server room hides still left channel copies and wakes	Low	A	Fixed	Relay, 2026-10-04
HOL-SEC-128	One join frame from any identity crashed the relay and lost every buffer	High	A	Fixed	Relay, 2026-10-04
HOL-SEC-129	A device-link code, a backup file or an archive from someone else could write files anywhere the user can	High	C	Fixed	0.12.0
HOL-SEC-130	A restored backup the owner refused gained the power to remove every owner device by waiting seven days	High	C	Fixed	0.12.0; relay 2026-10-04
HOL-SEC-131	Every Welcome into a server would fail once any member's leaf was 84 days old	Medium	A	Fixed	0.12.0
HOL-SEC-132	A member could repeatedly evict another member from a server's encryption group with that member's old KeyPackage	Medium	A	Fixed	0.12.0
HOL-SEC-133	A member that missed one removal commit kept encrypting server content to the removed member	Medium	C	Fixed	0.12.0
HOL-SEC-134	A meeting guest could keep another guest out for good by spending its KeyPackage	Medium	A	Fixed	0.12.0

ID	Title	Severity	Class	Status	Fixed in
HOL-SEC-135	A member could Welcome a leafless member into a group that seats an outsider	Low	C	Fixed	0.12.0
HOL-SEC-136	A meeting a participant left kept its secrets, SFrame key included, on disk	Low	C	Fixed	0.12.0
HOL-SEC-137	A crash or a burst could lose or bloat MLS state	Low	A	Fixed	0.12.0
HOL-SEC-138	A kicked or banned member, or a removed device, stayed in the server's voice call	Medium	C	Fixed	0.12.0
HOL-SEC-139	Any call participant or the forwarder could pin a receiver's CPU with frames that fail to decrypt	Medium	A	Fixed	0.12.0
HOL-SEC-140	A screen share could pass through the forwarder before it was encrypted	Medium	C	Fixed	0.12.0
HOL-SEC-141	Anyone who could reach us in a room learned our IP addresses through the Share lane, even with Always relay on	Medium	P	Fixed	0.12.0
HOL-SEC-142	Call keys could reach the debug log, new camera cryptors started on an old key slot, and a sharer could override a viewer's volume	Low	C	Fixed	0.12.0
HOL-SEC-143	Whoever served history could make a signed message read as a shorter text its author never wrote	Medium	C	Fixed	0.12.0
HOL-SEC-144	One friend request let a stranger watch our devices come and go, and blocking did not stop queued DMs	Medium	P	Fixed	0.12.0
HOL-SEC-145	One-time keys could be spent by another requester, extreme stamps panicked debug builds, and padded keys made alias ids	Low	C	Fixed	0.12.0
HOL-SEC-146	Links someone else chose opened with any scheme, and a preview card showed a domain its sender picked	Medium	C	Fixed	0.12.0
HOL-SEC-147	News posts fetched remote images, and a manifest version reached file names and update scripts	Low	C	Fixed	0.12.0
HOL-SEC-148	A link preview made the sender's own machine fetch loopback and LAN addresses	Medium	C	Fixed	0.12.0
HOL-SEC-149	A received video or voice note was decoded by ffmpeg with no tap	Medium	C	Fixed	0.12.0
HOL-SEC-150	Sent videos and some photos carried the sender's location	Medium	P	Fixed	0.12.0
HOL-SEC-151	Peer thumbnails reached Flutter's image decoder unchecked	Medium	C	Fixed	0.12.0
HOL-SEC-152	A device whose clock stepped back forgot its recovery key for good	Medium	C	Fixed	0.12.0
HOL-SEC-153	During the legacy window a forged recovery key could lock the owner's own devices out of their phrase	Medium	C	Fixed	0.12.0
HOL-SEC-154	A destroy order could be dated in the future, judged without our roster, or have its targets re-split	Low	C	Fixed	0.12.0; relay 2026-10-04
HOL-SEC-155	App Lock showed message content and a reply box in notifications, and a link could open above the lock	Medium	C	Fixed	0.12.0
HOL-SEC-156	A wipe left Hollow files, log lines and the push registration behind	Medium	C	Fixed	0.12.0
HOL-SEC-157	A duress code typed at a Settings prompt wiped but left the session running, and Settings could show a dead duress code	Medium	C	Fixed	0.12.0
HOL-SEC-158	iOS backups carried Hollow's data and keys, and the recovery phrase could be captured on screen and in the clipboard	Medium	C	Fixed	0.12.0
HOL-SEC-159	A 4-digit App Lock PIN and a backup passphrase of any length fell quickly to an offline search	Medium	C	Fixed	0.12.0

ID	Title	Severity	Class	Status	Fixed in
HOL-SEC-160	The relay, the forwarder's disk and the shareable logs held more about people than they need	Low	P	Fixed	0.12.0
HOL-SEC-161	Olm sessions accepted the truncated MAC of v1 and keys of small order	Info	C	Fixed	0.12.0
HOL-SEC-162	The device-link screens never said the code is only for a device you hold	Low	C	Fixed	0.12.0
HOL-SEC-163	Saving a received file on iOS let its sender's name replace any file in the app's sandbox	Medium	C	Fixed	0.12.1
HOL-SEC-164	One small frame made the relay walk every room a session holds	High	A	Fixed	0.12.1 (relay)
HOL-SEC-165	A client could grow the relay's ack timer queue by one entry per heartbeat	Low	A	Fixed	0.12.1 (relay)
HOL-SEC-170	Receivers that never ack could make the relay drop other people's waiting messages	Medium	A	Fixed	0.12.1 (relay)
HOL-SEC-171	Session bounds walked whole tables on hot paths, so full rings or a full table could stall the relay	Medium	A	Fixed	0.12.1 (relay)
HOL-SEC-172	A device coming back to a full address could lose its own session to its own login	Low	A	Fixed	0.12.1 (relay)
HOL-SEC-173	A crafted WebP thumbnail in a stranger's friend-request card stopped the receiver's node	High	A	Fixed	0.13 (a7263f6b)
HOL-SEC-174	Two devices of one identity could mint the same server op id, and replicas diverged for good	Medium	A	Fixed	0.13 (6b612cb0)
HOL-SEC-175	The CRDT sync state vector could lose a server op for good	Medium	A	Fixed	0.13 (98b4d842)
HOL-SEC-176	A ground master id led a server's encryption group while the owner was away	Medium	A	Fixed	0.13 (eb7ed684)
HOL-SEC-177	One identity's roster could lift another identity's removal of a device	Low	C	Fixed	0.13 (10dac6d6)
HOL-SEC-178	A busy channel's ring replay starved the owner's direct frames, so a joiner was never seated	Medium	A	Fixed	0.13 (892f0dcc)
HOL-SEC-179	A frame carried to our own sibling device could be lost in a room the sibling had left	Low	A	Fixed	0.13 (5d5d9116)
HOL-SEC-180	Two frames sealed in the same millisecond tied, so the second was taken as a replay	Low	A	Fixed	0.13 (5d5d9116)
HOL-SEC-181	A removal stamped ahead of a later re-add ended the re-added friendship on some devices	Low	A	Fixed	0.13 (c4e2f7f5)
HOL-SEC-182	A device removed while it was connecting never learned its removal live	Low	C	Fixed	0.13 (60438a4a)
HOL-SEC-183	A few addresses could exhaust the relay box's memory with large broadcasts	High	A	Fixed	Relay, 2026-10-23 (986a4d75)
HOL-SEC-184	Peer discovery answered every device with full member lists every 30 seconds	Medium	S	Fixed	0.13; relay 2026-10-23 (70f7f10e)
HOL-SEC-185	Opening a channel asked every member device for its history, and each page cost grew with the history	Low	S	Fixed	0.13 (e87391e0)
HOL-SEC-186	The relay read client JSON only up to a raw NUL byte	Low	C	Fixed	Relay, 2026-10-23 (22116aa5)

5. Findings

One section per finding, condensed from its file in `reports/planned/security/audit/findings/`. Each gives the flaw, its impact, the fix, any residual and the tests that prove it; the files hold the components, trust boundaries, attacker profiles and the claims each finding traces to. No section walks through an exploit.

HOL-SEC-001: Any identity could remotely wipe a device with its own signed device list

Severity: Critical (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0 (0bb09321).

Impact. Any identity that could reach a device could wipe it, silence third parties' devices and rebind other identities' device ids.

Description. A device list signed by another master was checked for its signature and for its sender being listed in it, then acted on. Our own device id in its revoked set raised the full wipe, its revoked entries silenced third parties' devices, and its device entries rebound other identities' ids to the signer. The signer's authority over the ids it named was never checked.

Fix. A foreign list speaks only for ids that are unbound or already bound to its own master, never ours, and the foreign-branch wipe is removed; only our own master revokes us. Design ID-1 later replaced device lists with rosters (HOL-SEC-077).

Test. `authz_a_foreign_roster_cannot_claim_or_remove_anyone_elses_devices` (node/roster_book.rs), successor of `a_foreign_device_list_cannot_revoke_or_claim_other_identities_devices`, which failed before the fix.

HOL-SEC-002: A relay operator can decrypt every device-link snapshot, master key included

Severity: High, possibly Critical (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Total identity compromise for whoever runs or controls the relay a device link passes through.

Description. Device linking sent the full backup snapshot, master key included, through the relay, encrypted under a passphrase the relay already held. That passphrase was the link code, which the relay saw in plaintext, or on the code-less path the public master id.

Fix. The code now has six rendezvous characters the relay sees and four secret characters it never sees. The two devices run SPAKE2 keyed by the secret and bound to the rendezvous, with a key confirmation before anything is sealed. The snapshot travels under a fresh random key carried inside that channel. One code answers one handshake. The code-less path is deleted.

Residual. A relay that plays one side gets one online guess at 20 bits per link attempt, and each guess costs the person a new code. The relay still learns that a link is happening and between which two connections.

Test. `link_the_relay_cannot_open_the_snapshot`, `authz_a_relay_that_answers_the_code_gets_one_guess`, `authz_link_frames_from_a_stranger_are_refused`, `every_layer_binds_on_its_own`, `a_pending_link_installs_the_device_key_it_was_made_for`. Mutation pass 9/9.

HOL-SEC-003: A relay operator can open an Olm session in any device's name and read that device's DMs, history included

Severity: Critical (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay could read a device's new DMs and its history, receive file and call keys, and ring forged calls, silently on first contact.

Description. The 0.8.2 signed key exchange covered only the responder's Olm keys. The receiver of a PreKey frame built its inbound session on the frame's Curve25519 identity key, which nothing bound to the device the relay named as sender. The relay could obtain the one-time keys it needed and replace a working session.

Fix. Every PreKey frame carries the sending device's signature over its Olm identity key (`hollow-olm-identity`), and every consumer (node, push fetch, forwarder, iOS extension) verifies it against the stamped sender before touching any session. An absent or wrong proof drops the frame and leaves the existing session alone.

Test. `authz_olm_prekey_relay_cannot_open_a_session_as_another_device`, which failed before the fix on all three counts (call rang, new DM read, history read).

HOL-SEC-004: A sync responder could rewrite, re-attribute, card or delete any message it knew the id of

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Any channel or DM message could be rewritten under its real author's name, moved to the attacker's name, given a card or hidden, and then served onward by the victim's own sync.

Description. A catch-up sync item's signature proved who wrote the item, never that the existing row it landed on (named by message id) was theirs. File cards riding an item were judged by the blob's own sender field.

Fix. One guard, now `message_ops::change_may_touch_row`, runs before any sync item touches an existing row. The row must sit in the channel or conversation the item names, and its author must be the item's signer. Both channel transports share one ingest function, and file cards must describe the file id the item signed.

Test. `authz_synced_channel_item_cannot_rewrite_another_authors_row`, `authz_synced_dm_item_touches_only_its_own_conversation_and_direction`.

HOL-SEC-005: Any identity could delete another user's identity and messages, or take their identity with one click, through the device-link flow

Severity: Critical (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. Any identity that knew a public master id could delete the victim's identity and messages at the next launch, or take the identity with one click.

Description. Neither half of device linking checked who it was talking to. A stranger's link frames registered a snapshot that the next launch imported after deleting the identity and database first. A stranger's snapshot request raised the sync prompt, and accepting it sent the full backup encrypted with the public master id.

Fix. The empty device takes a snapshot only from a peer it asked, while a code is set. The populated device prompts only for a requester in the room of the code it claimed, or for its own device. The import decrypts and checks the blob before deleting anything. The protocol was then replaced with HOL-SEC-002.

Test. `authz_link_frames_from_a_stranger_are_refused`, `pending_link_import_keeps_the_identity_when_the_blob_does_not_open`.

HOL-SEC-006: A stranger's device list could claim a friend's master id, taking over the friendship and, on the victim's replica, the friend's server role

Severity: Critical (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. A friendship moved to the attacker, the friend's server role folded into the attacker's key on the victim's replica, and a legacy contact could be silenced.

Description. The fix for HOL-SEC-001 let a foreign list speak for ids that resolve to themselves. A master id always resolves to itself, so a stranger's list could name another identity's master id, rebinding it to the attacker or marking it revoked.

Fix. A foreign list may not name an id that is another identity's master. Revocation enforcement reaches only devices the list's own master already held. Design ID-1 then made every roster entry carry the device's own consent.

Test. `authz_a_foreign_roster_cannot_claim_or_remove_anyone_elses_devices` (successor of `a_foreign_device_list_cannot_claim_a_master_id_or_silence_a_legacy_contact`).

HOL-SEC-007: Any peer could kill another user's node with one profile announce, and a member could name a file outside the data folder

Severity: High (Impact M-H, Exploitability H). **Class:** A. **Fixed in:** 0.12.0.

Impact. Any peer sharing a room, the relay included, could end the victim's node task with one profile announce, repeatably; a member could also name a file outside the data folder on Windows.

Description. Four places cut a remote string with a byte slice, which panics inside a multi-byte character and ends the event loop task. A member-supplied shard content id also named a temp file.

Fix. `crypto_handler::clip_bytes` is the one way to cut a remote string, at a character boundary. The shard temp name keeps only alphanumerics.

Test. `authz_a_remote_string_never_panics_the_node`.

HOL-SEC-008: A friend could rewrite or re-caption messages it did not write, our own included, through live and push delivery

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A friend could rewrite, hide, card or re-caption messages it did not write, our own sent messages included.

Description. HOL-SEC-004 bound synced changes to their rows; the live and push paths still decided by message id alone. Signatures were checked against the sender rather than the row's author, the push path had no direction check, reactions attached to any id, and channel changes could name another channel, which also let a muted member edit.

Fix. `change_may_touch_row` is the one ownership check for every change, live or synced, on every transport and on push. A channel change must name its row's own channel, and a reaction lands only where it says.

Test. `authz_live_dm_change_touches_only_the_senders_own_rows`, `authz_push_dm_change_touches_only_the_senders_own_rows`, `authz_live_channel_change_must_name_the_rows_own_channel`, `authz_dm_reaction_lands_only_in_the_reactors_conversation`.

HOL-SEC-009: Anyone who knew a server's id could post into any of its channels, private and admin-only ones included

Severity: High (Impact M-H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. Anyone holding a server id, which every invite carries, could post under its own name into any channel, private and admin-only ones included.

Description. Receivers stored a signed plaintext public-channel post without checking that the channel was public in their own state. No receiver checked that the author may post there, and the Olm and push paths skipped mute, slow mode and media-only.

Fix. A plaintext public frame is taken only for a channel public in our own state. One gate, `live_channel_post_refusal`, judges every live transport and push. It admits only a current member who can see and post in the channel and is not muted. A wiring test fails if a receive path stops calling it.

Test. `authz_public_frame_only_for_a_channel_public_here`, `authz_live_post_needs_a_member_who_can_see_and_post`, `authz_live_channel_post_is_judged_by_our_state`.

HOL-SEC-010: A member of any group we shared could post into another server or a restricted channel through MLS

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member of any MLS group the victim held could post into other servers and restricted channels, and drive server-scoped handlers from an unrelated group, a meeting included.

Description. An MLS envelope names its own server and channel, and handlers acted on those names without comparing them with the group that decrypted the envelope.

Fix. `crypto_handler::mls_envelope_fits_group` runs on every decrypted envelope, live and push. The envelope must name the decrypting group's server, a subgroup carries only its own channel, restricted content arrives only through its subgroup, and DM-shaped envelopes never ride a group.

Test. `authz_mls_envelope_must_fit_the_group_that_decrypted_it`.

HOL-SEC-011: A member or friend could make every receiver store a message of any size, and long non-Latin messages were cut and lost their signature

Severity: Low (Impact L-M, Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A modified client could make every receiver store and render a message of many megabytes, while honest long non-Latin DMs were cut and then failed their own signature.

Description. No size bound existed on live channel, sync, edit or meeting chat paths, while the live DM and push paths clipped text to 4,000 bytes after verifying it.

Fix. One protocol limit of 64 KiB in Rust and Dart; signature verification fails a longer body, so every path drops it whole, and nothing clips any more.

Test. `message_over_the_size_limit_never_verifies`, `oversized_message_is_dropped_whole_on_every_path`, `push_dm_is_stored_whole_or_dropped_never_clipped`.

HOL-SEC-012: Anyone in a server's room could make a member reveal who posts in any channel, restricted ones included, and stall its sync

Severity: Medium (Impact M, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Anyone with a server id, or the relay, learned the author list and latest post times of any channel, restricted ones included, and could stall a member's sync of it.

Description. Retired channel probe handlers stayed in the code. The response handler answered anyone, for any channel, with our per-author watermarks in the clear, and stamped the dedup that gates our real sync.

Fix. The probe message types and their handlers are deleted; such frames are refused at parse.

Test. `restricted_channel_history_and_files_never_reach_a_non_qualifier` (stranger section), `retired_channel_probes_are_refused_at_parse`.

HOL-SEC-013: A decrypted payload that was not an envelope was shown as a DM with no signature and no block check

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Text of a friend's choosing, a blocked former friend's included, could appear as a DM with no signature.

Description. A decrypted Olm payload that did not parse as an envelope was shown as a legacy DM with no signature, block or revocation check.

Fix. Such a payload is logged and dropped, as on the push path.

Test. `a_dm_reaches_the_ui_only_after_its_signature_verifies`.

HOL-SEC-014: A public channel served the text of deleted messages to any guest

Severity: Low (Impact L, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Text an author deleted from a public channel stayed readable to any stranger browsing it as a guest.

Description. The page served to guests came from the members' history query, which keeps deleted rows as evidence.

Fix. The guest page query leaves deleted rows out; members' own sync is unchanged.

Test. `guest_pages_leave_deleted_messages_out`.

HOL-SEC-015: Anyone in a server's room could fake typing and unread or mention badges in any channel

Severity: Low (Impact L, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. Anyone with a server id could fake typing indicators, unread counts and mention badges in any channel.

Description. The plaintext post hint and typing signals were never checked against the server or the channel's visibility, and typing from a blocked identity was shown.

Fix. One gate, `channel_signal_accepted`, requires a sender who passes the post gate for that channel and a channel we can see. The plaintext exposure of the hint was then closed by HOL-SEC-062 (the hint rides MLS).

Test. `authz_channel_signals_only_from_a_poster_about_a_channel_we_see`, `channel_ingest_gates_stay_wired`.

HOL-SEC-016: A member who could not see a restricted voice channel could still take a seat in it and be dialed

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member who could not see a restricted voice channel could take a seat in it, be dialled by every participant and receive their network addresses; the audio stayed under a key it did not hold.

Description. A voice join was checked for membership and channel type only.

Fix. Both join paths ask `voice_handler::voice_join_refusal`, which seats only a member who can see the channel.

Test. `authz_voice_seat_only_for_a_member_who_can_see_the_channel`, `channel_ingest_gates_stay_wired`.

HOL-SEC-017: A server member or a meeting guest could be seated in the encryption group under someone else's name

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member or meeting guest could hold an MLS leaf in the owner's or host's name, so group envelopes were attributed to that identity.

Description. The live KeyPackage path and the meeting knock seated whatever credential the package named.

Fix. Both refuse a package unless its credential names the sending device. The relay half of this class was closed by design D (HOL-SEC-041).

Test. `authz_key_package_must_name_its_sending_device`, `key_package_identity_reads_the_leaf_credential`.

HOL-SEC-018: A member could pin a post below everything that followed it and post past slow mode

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A post could stay pinned below later messages, and slow mode could be bypassed.

Description. A message's signed timestamp was unbounded, and slow mode compared posts by those sender-chosen stamps.

Fix. A message dated more than ten minutes past our clock fails verification everywhere. Slow mode judges a fresh post by when it reached us.

Test. `message_dated_past_our_clock_never_verifies`, `slow_mode_judges_fresh_posts_by_our_clock`.

HOL-SEC-019: An Olm peer could grow a server's op log without bound through a fallback nobody sends

Severity: Low (Impact L, Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. An Olm peer could grow a server's op log with replayed copies of one signed op and be answered with the op log in plaintext.

Description. Three Olm CRDT arms that no client used still ingested ops and answered sync requests. A bug that was not a security flaw was fixed with it. At the 1,000-op cap new remote ops were never persisted.

Fix. The Olm CRDT arms are ignored, and `apply_op` reports whether an op was new.

Test. `authz_olm_carries_no_crdt_ingest`, `a_full_op_log_still_counts_new_ops`.

HOL-SEC-020: A member could sign server ops whose clock names someone else, or a counter that wraps ours

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member could sign ops whose clock names another identity, winning ties, and a counter at its ceiling wrapped a release build's clock.

Description. Ingest never compared an op's clock actor with its author, and the clock incremented its counter unchecked.

Fix. `verify_author` refuses a clock naming anyone but the author, and the clock moves to the next millisecond at the counter's ceiling.

Test. `ingest_rejects_a_clock_naming_another_author` (named `admit_remote_rejects_a_clock_naming_another_author` at the fix), `a_counter_at_its_ceiling_moves_the_clock_forward`.

HOL-SEC-021: An Admin could make every member delete a server's files and message history

Severity: Medium (Impact H, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. An Admin could make every member's retention sweep delete the server's files and message history.

Description. `ServerSettingChanged` accepted any key and value from anyone with Manage Server, retention included.

Fix. Retention policies and their stamps are Owner-only and take only the values the app offers; a reader treats any other value as keep everything.

Test. `authz_retention_is_owner_only_and_takes_only_app_values`, `a_value_the_app_does_not_offer_keeps_everything`.

HOL-SEC-022: A friend or server member could replace or empty a file someone else sent

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A friend or member could replace the bytes behind someone else's attachment, even after download, or empty it, and the victim then served it onward.

Description. The file header's key registration and inline write accepted any sender, and an unused `FileChunk` envelope wrote chunks for any file with no check.

Fix. One gate, `file_header_refused`, runs first on every header arm. A header for a card we hold comes only from its owner or from the holder we asked. Finished files are immutable, and `FileChunk` is deleted.

Test. `authz_file_header_delivers_only_for_its_owner`, `file_header_gate_stays_wired`, `retired_file_chunk_is_refused_at_parse`.

HOL-SEC-023: Any peer in a shared room could write into another sender's file stream, and fill our disk

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Any peer in a shared room could corrupt or take over a download in progress and write temp files without bound.

Description. Stream state was keyed by stream id alone and frames were written past the declared size, with no cap on open streams.

Fix. A stream belongs to the device that opened it, writes past its size drop it, and open streams are capped per peer and in total.

Test. `a_stream_belongs_to_the_peer_that_opened_it`.

HOL-SEC-024: A server member could overwrite, relink and delete vault content, and make a download write outside its folder

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A server member could replace vault files with its own bytes for every member, relink others' file cards, wipe placements in another server, and make a download write outside its folder.

Description. Vault shard writes, manifests and deletes accepted any member, the rebuilt file was never compared with its content id, and a sender-chosen content id named the cache file.

Fix. One gate for shard writes, the rebuilt file must hash to its content id, a manifest lands only from its creator, one delete rule with Manage Server, and cache names keep only alphanumerics.

Test. `authz_shard_write_needs_a_member_and_a_shard_we_lack`, `authz_vault_manifest_lands_only_from_its_creator`, `vault_gates_stay_wired`, `a_key_holder_cannot_rebuild_other_content`, `cache_path_stays_inside_the_cache`, `delete_placement_test`.

HOL-SEC-025: Members who cannot see a restricted channel received the keys to its files

Severity: High (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. Every file posted in a restricted channel of a server with six or more members was readable by every member of the server.

Description. Such files also went to the vault, whose manifest (with the file key) went to the whole server group.

Fix. A file in a channel that uses a subgroup never enters the vault, and shards are served only to members who can read the file's channel.

Test. `authz_restricted_channel_file_never_enters_the_vault`, `vault_gates_stay_wired`.

HOL-SEC-026: Any peer we shared a room with could join, steer or stop our recovery pool

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A peer sharing any room with us could join, steer or stop our recovery pool and make us stream shards to a peer it named.

Description. Recovery-pool frames were taken from any room.

Fix. A recovery frame counts only in the pool's own room, a transfer plan only from the elected coordinator, shards stream only to pool members, and an unused manifest-sync message is deleted.

Test. `authz_recovery_frames_count_only_from_the_pool_room`.

HOL-SEC-027: A replayed share manifest stopped a seeder, and an early Have allocated half a gigabyte

Severity: Low (Impact L, Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A replayed share manifest stopped a seeder and reset a download, and an early Have allocated half a gigabyte per forged sender.

Description. A share took its manifest again on every copy, and a Have was sized before any manifest existed.

Fix. A share takes its manifest once, and a Have is taken only against a known manifest's chunk count.

Test. `a_share_takes_its_manifest_once_and_haves_only_against_it`.

HOL-SEC-028: One malformed frame from anyone on the internet stopped the relay and emptied its buffers

Severity: Critical (Impact H, Exploitability H). **Class:** A. **Fixed in:** Relay, 2026-09-27.

Impact. One malformed frame from anyone on the internet stopped the relay and lost every RAM buffer, repeatably.

Description. The pre-auth path read the auth frame with a throwing JSON accessor and did not catch the exception, which unwound into the WebSocket library and ended the process; the restart snapshot runs only on a clean shutdown.

Fix. `parse_auth_frame` uses type-checked accessors only and refuses pre-auth frames over 16 KiB; auth and binary dispatch are wrapped so no client input can unwind into the library.

Test. Relay unit test `test_auth_frame.cpp` (every wrong-typed field, non-object, non-JSON and oversized frames refused without throwing).

HOL-SEC-029: Anyone could cancel or pre-empt the destroy order waiting for a lost device

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0; relay 2026-09-27.

Impact. The destroy order parked for a lost or stolen device could be replaced by junk or blocked for a year by one far-future deposit.

Description. Any account could deposit a kill signal for any device id, and a newer stamp replaced the waiting order whoever made it.

Fix. Each issuer holds its own slot per target, far-future stamps are refused, and the device acknowledges a refused signal by its stamp; a bare acknowledgment follows only a wipe.

Test. Relay unit test `test_kill_list.cpp` (block I2) and the client destroy tests.

HOL-SEC-030: Anyone who knew a server id could flush its catch-up rings, and guests could post to them

Severity: Medium (Impact M, Exploitability H). **Class:** A. **Fixed in:** Relay, 2026-09-27.

Impact. Anyone with a server id could flush its catch-up rings, and guest sockets could deposit frames and wake phones.

Description. Rings evicted first in, first out, and guest sockets were not limited on topic frames or JSON directs.

Fix. A full ring drops the oldest frame of the sender holding the most, and guests may not send topic frames or JSON directs.

Test. Relay unit test `test_ring_evict.cpp`.

HOL-SEC-031: A revoked device could read its master's mailbox again after every relay restart

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** Relay, 2026-09-27.

Impact. A revoked device could read its master's mailbox again after every relay restart.

Description. The relay's device-list version marks lived in RAM only and were not in the restart snapshot.

Fix. The marks ride the restart snapshot (codec version 3).

Test. Relay unit test `test_snapshot_codec.cpp`.

HOL-SEC-032: A revoked device came back through the sibling proof and after a restart

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A revoked sibling was bound to our identity again and handed our friend list, servers and DM history, and any revoked device passed key exchange after a restart.

Description. The sibling proof bound a device before reading our own tombstones, and revocations lived in memory only.

Fix. `sibling_proof_refused` runs first, enforced revocations are persisted and warmed at every start, and key exchange refuses a revoked device.

Test. `authz_only_a_roster_member_gets_sibling_state`, `authz_a_removed_device_stays_refused_after_a_restart`.

HOL-SEC-033: A carried device list was taken as its master even when it did not bind the sender

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A revoked device could join a server, plant a key bundle or decline a request in its former master's name.

Description. Three arms attributed a message to the carried list's master whatever the ingest decided, and dropped the revocations it reported.

Fix. Attribution comes only from an ingest that really bound the sender, and the arms enforce reported revocations; a source guard keeps the arms wired.

Test. `authz_a_carried_roster_attributes_only_a_member`, `carried_roster_arms_stay_wired`.

HOL-SEC-034: An old destroy notice applied again after the identity returned, and any list said it had

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A replayed destroy notice re-raised a contact's destroyed banner and removed their verified mark, and any device list cleared it.

Description. The banner stamp was cleared when the identity returned, so the old notice applied again, and any bindable list counted as a return.

Fix. The newest applied notice keeps its own stamp, and only a new device for that identity counts as a return.

Test. `authz_a_friend_destroy_order_applies_once_even_after_the_identity_returns`, `authz_only_a_new_member_means_a_destroyed_identity_returned`, `destroy_friend_announce_flips_verified_and_banner`.

HOL-SEC-035: The push path ignored blocks, key changes, the mention setting and who sent the wake

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. On the push path a blocked person's DMs were stored and shown, key changes raised no notice, mentions-only channels showed every post, anyone could put banners naming themselves on the phone, and a push could make the phone join any server room.

Description. The push fetch process and the iOS extension never loaded the block list, skipped the Olm key pin, trusted the sender's mention flag, and joined the payload's server unchecked.

Fix. Every process that judges inbound frames warms blocks and revocations; key changes are recorded; mentions are judged from our own decryption; fallback banners name only known senders; wakes for servers we do not hold join nothing.

Residual. iOS shows the provider's alert before the extension runs unless Apple grants the notification filtering entitlement (requested, still pending).

Test. `authz_a_fresh_push_process_knows_our_blocks`, `authz_a_key_change_first_seen_by_push_is_recorded`, `authz_an_empty_wake_names_only_a_sender_we_know`, `authz_a_mentions_only_channel_shows_only_mentions_we_read`, `a_channel_wake_for_a_server_we_do_not_hold_joins_nothing`.

HOL-SEC-036: Anyone could befriend us with an accept, and a block missed half the DM surface

Severity: High (Impact M-H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. A stranger could become an accepted friend without consent, have its own request accepted in our name, and a blocked person could still edit, delete and react in our DMs.

Description. A `FriendAccept` was honoured with no friend row, or flipped an incoming request; the block was checked before a new device bound; DM changes had no block check.

Fix. An accept lands only on our own pending outgoing request; the block is checked again after binding; DM changes drop blocked senders.

Test. `authz_a_friend_accept_lands_only_on_a_request_we_sent`, `authz_a_blocked_friend_changes_nothing_in_our_dms`, `authz_a_blocked_identitys_unknown_device_is_dropped_once_its_roster_binds`.

HOL-SEC-037: Call signals were bound by call id alone, and a share could be re-pointed by any participant

Severity: Medium (Impact M, Exploitability L-M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Anyone with a call id could end, answer or re-point another person's call; any participant could re-point our sibling's screen share; any identity with an Olm session could ring us.

Description. Call signals were matched by call id alone, ids came from a non-secure random source, and screen assignment origins were checked loosely.

Fix. Signals must come from the live call's peer, ids come from `Random.secure()`, origins are checked per direction, and only friends or our own devices ring us.

Test. `test/call_signal_sender_test.dart`, `authz_only_a_friend_or_our_own_device_rings_us`, `authz_a_share_is_assigned_by_its_originator_and_reported_to_its_owner`.

HOL-SEC-038: Profile avatars were not checked against their signature, and stale or long profiles misbehaved

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay could replace a contact's avatar, a replayed profile renamed a member everywhere, and non-Latin names failed their own signature.

Description. Avatar bytes were not compared with the signed hash, a refused stale profile still applied its side effects, and text was clipped in bytes before verification.

Fix. Bytes must hash to the signed avatar hash, a refused profile changes nothing, and one byte limit per field is refused whole on every path.

Test. `authz_an_incoming_profile_keeps_only_what_its_owner_signed`, `authz_profile_text_is_refused_whole_at_one_limit`.

HOL-SEC-039: A replayed edit reverted text, and a replayed reaction came back

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A replayed edit reverted a message's text and a replayed reaction came back.

Description. The store applied any edit with different text and never read reaction removals.

Fix. An edit applies only when newer than the row's last edit, and an add no later than a recorded removal is refused.

Test. `authz_an_older_edit_never_reverts_a_newer_one`, `authz_a_removed_reaction_stays_removed`.

HOL-SEC-040: Being in a room with us was enough for a data channel, a gossip seat and our voice presence

Severity: Medium (Impact M, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Our IP addresses reached anyone who could join a room with us, and non-members joined the gossip overlay and learned our voice channel.

Description. A finished key exchange opened a WebRTC data channel to any room peer, and gossip and voice presence followed room presence.

Fix. Data channels only with own devices, friends and co-members; gossip only with CRDT members; voice presence only to members who can see the channel.

Test. `authz_room_presence_alone_opens_no_channel_to_us`.

HOL-SEC-041: An encryption-group seat proved nothing about who held it

Severity: Critical (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay operator could seat itself in any server group, restricted channels included, and read every group-encrypted message and key; a member could appear as any identity.

Description. An MLS leaf was signed by a random per-install key with a self-chosen id, and KeyPackages were seated when the relay-stamped sender matched that id.

Fix. A leaf's signing key is the device's Ed25519 key and its credential carries the master's certificate for that device; every receiver judges a leaf from the leaf alone, unbound leaves are ignored, and existing groups rebind in place.

Test. `authz_no_one_seats_a_leaf_in_another_devices_name`, `a_leaf_is_bound_only_by_its_device_key_and_its_masters_certificate`, `a_copied_certificate_never_becomes_a_leaf`.

HOL-SEC-042: Any member could evict members from an encryption group or add anyone to it

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Any member holding a leaf could evict other members, the owner included, or add outsiders to a server group or subgroup.

Description. A received commit was processed and merged in one step, with no look at who committed it or whom it changed.

Fix. Every commit is staged, judged against membership rules, and only then merged; uncertain cases are held up to 60 s and re-judged.

Test. `authz_a_member_cannot_evict_a_member_or_add_an_outsider`, the `commit_verdict` matrix.

HOL-SEC-043: A Welcome from anyone replaced a working encryption group

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member could move another member into a group of its own making, and anyone in a meeting room could cut a participant out.

Description. The Welcome handler dropped our group before parsing the Welcome and joined whatever it described; KeyPackages were minted for anyone.

Fix. Welcomes are staged and judged first, replacing a group only when we asked; KeyPackage requests are answered only to entitled members.

Test. `authz_a_welcome_never_replaces_a_group_unasked`, `authz_key_package_requests_need_a_member_who_may_repair`, `a_refused_welcome_replaces_nothing`.

HOL-SEC-044: Any frame that failed to process made a member drop its encryption group

Severity: Medium (Impact M, Exploitability H). **Class:** A. **Fixed in:** 0.12.0.

Impact. Anyone able to send into a server room, the relay included, could knock members out of the group repeatedly with garbage frames.

Description. Any commit or decrypt failure made the receiver drop its group and ask to be added again.

Fix. A group changes only on an authenticated event that passes our rules; failures send throttled epoch probes, and forks are detected by an epoch-authenticator digest and repaired in one commit.

Test. `authz_garbage_mls_frames_never_drop_a_group`, `a_same_epoch_fork_heals_through_the_probe`, `the_epoch_digest_tells_forks_apart`.

HOL-SEC-045: Encrypted voice signaling was credited to whoever the relay named

Severity: Low (Impact L, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay could replay one member's voice signalling as another member's.

Description. Voice envelopes from a group were routed by the relay-stamped sender without comparing it with the encrypting leaf.

Fix. A voice envelope is dropped unless its leaf is the device the relay named.

Test. `authz_voice_frames_over_mls_come_from_their_leaf`.

HOL-SEC-046: A joiner took its whole server state, owner included, from whoever answered

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A joiner's replica could name the attacker as Owner, refuse the real owner's ops from then on, and serve that view to later joiners.

Description. While a join was pending, a state snapshot from any sender was adopted whole.

Fix. Servers founded on 0.12 get a self-certifying id hashed from the owner and a nonce, and joiners build state from signed ops alone; older servers move to an owner-signed checkpoint and invite links pin the owner.

Test. `authz_a_joiner_takes_its_state_only_from_the_servers_anchor`, `authz_a_self_certifying_server_is_founded_only_by_its_key`, `authz_a_join_snapshot_needs_the_pinned_owner`.

HOL-SEC-047: The relay could replay old server ops and pick each member's outcome by reordering

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay or a peer keeping old ops could re-admit kicked members, reopen closed channels and choose each member's outcome by reordering.

Description. Ops were judged against arrival-time state in arrival order, and dedup covered only the newest 1,000 ops.

Fix. Server state is a pure function of the signed ops held, folded in HLC order with each op judged at its point (design E); logs are retained, and owners sign checkpoints.

Test. `authz_fold_state_does_not_depend_on_arrival_order`, `authz_a_replayed_old_op_never_undoes_a_later_one`, `a_checkpoint_keeps_what_its_owner_had_not_seen`.

HOL-SEC-048: A member could backfill posts signed by someone who was never in the server

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member could backfill posts signed by someone who was never in the server, shown as verified and spread by every receiver's sync.

Description. Backfill accepted any correctly signed post, and nothing recorded past membership.

Fix. Every state keeps a membership record (spans from admission to removal), and backfill drops posts whose author was not a member at the post's time.

Test. `authz_backfill_refuses_a_post_by_someone_never_a_member`, `the_membership_record_spans_admission_to_removal`.

HOL-SEC-049: Any member could admit anyone past a ban, a private server or the Twitch gate

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Any member could admit a banned identity, or anyone into a private, full, owner-verified or Twitch-gated server.

Description. The join gates ran only on the honest admitter's path; receivers accepted any member's `MemberAdded`.

Fix. Every member re-checks the gates on the op at its point in the fold, including the joiner's Twitch credential copied into the op.

Test. `authz_a_member_cannot_admit_past_the_join_gates`, `authz_member_added_rechecks_the_join_gates`.

HOL-SEC-050: Strangers, ex-members and device keys could author server ops

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Strangers' ops were persisted and re-flooded, and a revoked device kept its master's authority.

Description. `op_allowed` defaulted unknown authors to Member and resolved device ids to masters through the resolver.

Fix. An op's author acts by its own id and only while it is a current member.

Test. `authz_ops_need_a_member_author_acting_by_its_own_id`.

HOL-SEC-051: An admin could demote, ban or mute the owner through a device id

Severity: Medium (Impact H, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. An admin could demote, ban or mute the owner on replicas that had not yet learned the owner's device list.

Description. Role, ban and mute registers under an unresolved device id were later folded onto its master by timestamp.

Fix. Anchored servers never fold device-keyed registers; on legacy servers the fold only adopts and never lands on the owner or a moderator.

Test. `authz_device_registers_never_demote_ban_or_mute_the_owner_or_a_moderator`.

HOL-SEC-052: Moderation edges skipped rank, and ownership could be minted or dropped

Severity: Low (Impact M, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. Moderators lifted higher-ranked bans and mutes, admins rewrote the owner's nickname or granted bits they lacked, and an owner could leave a server ownerless.

Description. Several moderation edges checked no rank, and authoring used different rules from ingest.

Fix. Lifting needs the setter's rank, edits of others need to outrank them, permissions grant only held bits, the owner is fixed, and our own authoring passes `op_allowed`.

Test. `authz_moderation_edges_respect_rank`, `authz_the_owner_is_fixed`.

HOL-SEC-053: Every plaintext frame was attributed to the sender the relay stamped

Severity: Critical (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay could delete any server through its owner's own device, unfriend anyone, plant friends, kick members and answer data-channel offers with its own fingerprint.

Description. Every plaintext handler took the relay-stamped `from` as the sender; nothing bound a frame to its sender, room or recipient.

Fix. Every peer payload on the relay is sealed by the sending device over a domain tag, the room, the route, a time, a nonce and the body hash; every receiver opens it against the sender's key before reading. Several senderless legacy messages are deleted.

Test. `authz_the_relay_cannot_send_a_frame_in_a_members_name`, `authz_a_sealed_frame_cannot_be_moved_to_another_room_or_device`, `authz_the_relay_cannot_echo_a_devices_own_frame_back_to_it`, the `frame_auth` unit tests.

HOL-SEC-054: Frames the relay held back or replayed were acted on again

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay could ring a day-old call invite, tear down sessions with a repeated Olm frame, end new friendships with old removals and re-admit people with old join requests.

Description. Frames carried no trustworthy send time, and a repeated Olm frame triggered a session teardown.

Fix. Every message type is classed live-only or late-deliverable in one exhaustive list; live frames are refused after 300 s or on a repeated nonce, late frames are bounded by seal time, and sessions drop repeats before any teardown.

Test. `authz_a_live_frame_is_taken_once_and_only_while_fresh`, `authz_a_call_invite_held_back_by_the_relay_never_rings`, `authz_a_replayed_olm_frame_leaves_the_session_alone`, `authz_a_removal_older_than_the_friendship_is_ignored`, `authz_a_join_request_from_before_a_leave_never_readmits`, `authz_a_kick_from_before_a_rejoin_is_ignored`.

HOL-SEC-055: Any holder of a server id was served the whole op log

Severity: Medium (Impact M, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. Anyone with a server id could read its members, roles, bans, restricted channel names, grants and Twitch credentials.

Description. The `SyncRequest` responder served the op log to any requester.

Fix. The op log goes only to a current member; a deleted server answers with only the deletion op.

Test. `authz_only_a_member_is_served_the_op_log`.

HOL-SEC-056: A sibling's server announce reopened a server we already held

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Our copy of an older server could be replaced by another member's snapshot, owner included.

Description. A sibling's routine server announce ran the join flow for a server we already held, opening a window for an unpinned snapshot.

Fix. A held server gets only a list refresh, and a new server's pending join is pinned to the announcing device's anchor owner.

Test. `authz_a_sibling_announce_for_a_held_server_starts_no_join`.

HOL-SEC-057: A full profile went to anyone who asked

Severity: Low (Impact M, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Strangers received our avatar, banner and showcase bytes and an oracle for whom we know.

Description. `ProfileRequest` answered anyone with the full profile, and cached third-party profiles were relayed to anyone.

Fix. A full profile goes only to own devices, friends, co-members and pending friends; a relayed profile only to a co-member of its subject.

Test. `authz_a_full_profile_goes_only_to_someone_we_know`.

HOL-SEC-058: Screen-share audio played from any open data channel

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A peer with an open data channel could inject audio heard as a sharer's.

Description. Share-audio callbacks ignored the sender.

Fix. A DM call plays share audio only from its peer while watching; a voice channel only from a sharer we watch.

Test. `test/share_audio_gate_test.dart` (mutation pass of four gates, each failed).

HOL-SEC-059: The push fetch node cleared every parked destroy order

Severity: Medium (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A lost phone's pending destroy order could be erased before it ran.

Description. The push fetch node answered a junk order with a bare acknowledgment, which clears every parked order.

Fix. A junk or refused order is acknowledged by its own stamp; a bare acknowledgment follows only a wipe.

Test. `a_junk_kill_deposit_is_acked_alone`.

HOL-SEC-060: Any holder of a file could answer for it with other bytes

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A holder of a file could make another person's attachment show content its author never sent.

Description. The message signature bound the file id but nothing about the file's content.

Fix. A 0.12 file id is SHA-256 over author, message id, size, content hash, name and extension, so the author's signature covers all of it; every header and card is checked against the id and every completion path hashes the bytes.

Residual. Files sent before 0.12 keep the old gates (AR-13).

Test. `authz_a_holder_cannot_substitute_a_files_bytes`, the `node/file_commit.rs` units, `authz_a_synced_card_cannot_relabel_a_committed_file`. Mutation pass 9/9.

HOL-SEC-061: Anyone in a meeting's room could run its lobby and admit the knocker

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Anyone in a meeting's room could become its committer and SFrame source for a knocker, or deny, end and kick for the host.

Description. A meeting id named nobody, any bound leaf's Welcome was taken while knocking, host frames came from any sender, and knock proofs were replayable.

Fix. A meeting id hashes the host's master and a nonce, host frames and the admitting Welcome prove it, and a knock proves the code with an HMAC bound to the knocking device.

Test. `authz_only_the_host_a_meeting_id_names_runs_its_lobby`, `authz_a_knock_proves_its_code_only_for_its_own_device`, and the conference unit tests. Mutation pass 11/11.

HOL-SEC-062: The relay read friend lists, server state, profiles and join requests

Severity: Medium (Impact M, Exploitability M). **Class:** P. **Fixed in:** 0.12.0 (e39ed7cb, c54bcbe9, 73591cbe, daa9917f, 54aef252, 7b3cb37f).

Impact. The relay read friend lists, server state, profiles, read positions, sync watermarks and join requests with their Twitch credentials; a removed member could answer a joiner.

Description. All of this rode plaintext frames the relay reads, and DM rooms were a hash of public ids.

Fix. The lane rule (`HavenMessage::lane`) decides what may ride a plaintext frame; everything else is carried in Olm or MLS. DM rooms derive from the masters' X25519 agreement, profiles go only to their audience, joins ride sealed boxes behind the join lock.

Residual. The relay still sees routing metadata (device ids, rooms, sizes, timing and a few routing fields), as claim C-24 allows.

Test. The `c24_*` wiretap tests, the `authz_*` join and profile tests and the `join_lock_*` tests in node/test_harness.rs, with the unit and relay `test_join_lock.cpp` tests. Mutation passes for every phase.

HOL-SEC-063: A captured relay login opened an invisible socket in the device's name

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A captured relay login could open an invisible socket in the device's name on another relay, take its room slots, drain its offline buffer and acknowledge its destroy orders.

Description. Logins signed a string that named no relay and carried no challenge, and fetch sockets could displace full sockets.

Fix. Auth v2 signs the relay's domain, a fresh nonce, the mode and the license key hash; fetch sockets never take a full socket's slot and are never listed.

Test. `auth_v2_message_matches_the_relays_pinned_vector`, `auth_domain_is_the_dialled_host_without_port`, `test_auth_message_format`, relay `test_auth_frame.cpp` (auth v2).

HOL-SEC-064: A person's inbox room showed strangers their devices and when they were online

Severity: Medium (Impact M, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Anyone holding a master id learned a person's devices and when each was online.

Description. The relay showed every inbox joiner the room's roster and presence.

Fix. Only sockets proving they are the master's devices own the inbox and see each other; deposits reach every owner live.

Residual. The relay itself still sees which devices join an inbox.

Test. `authz_an_inbox_shows_its_devices_only_to_each_other`.

HOL-SEC-065: Anyone in a server's room could stretch, stop or flood its catch-up rings

Severity: Medium (Impact M, Exploitability H). **Class:** A. **Fixed in:** 0.12.0.

Impact. Anyone with a server id could stretch its ring retention to a week, stop its rings, or flood them.

Description. Ring control was authorised by room membership alone.

Fix. Ring control must be signed by the newest join lock's change key, eviction is by bytes, and per-room and per-device caps apply.

Residual. A legacy server's rings could be bound by a lock filed in another name (closed by HOL-SEC-071); many addresses can still churn the global cap.

Test. `authz_only_the_servers_authority_changes_its_rings`, `ring_control_payload_matches_the_relays_pinned_vector`, relay `test_ring_auth.cpp`.

HOL-SEC-066: The client acted on values the relay chose

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay could send our friend request to a master it chose, route call media through a TURN host it chose, name a person's device as forwarder, and stop the node with one reply.

Description. Nickname resolution, TURN URIs, the forwarder name and license refusals all rested on the relay's word.

Fix. Nickname claims are master-signed and a lookup sends nothing before the person confirms; TURN must name the relay's own host; known identities cannot be forwarders; only exact refusal codes count.

Residual. The forwarder pin trusts the first advertisement (AR-14).

Test. `authz_a_nickname_names_only_a_master_that_signed_for_it`, `authz_the_relay_cannot_name_a_known_person_as_its_forwarder`, `turn_uris_must_name_the_relay`, `only_the_relays_exact_codes_are_license_refusals`.

HOL-SEC-067: The recovery pool's token rode in the room name the relay reads

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay could join a deleted server's recovery pool and read or steer its transfers.

Description. The pool token rode in the room name, and pool frames were plaintext.

Fix. The room is named by a hash of the token, and pool frames are sealed under a token-derived key bound to room and sender.

Test. `authz_a_recovery_frame_counts_only_with_the_pool_token`, `c24_a_recovery_pool_shows_the_relay_neither_its_token_nor_its_frames`.

HOL-SEC-068: Future stamps and replays undid read positions, emotes, reactions and link cards

Severity: Low (Impact L, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. Read positions, personal emotes, reactions and link cards could be undone for good by future stamps or replays.

Description. Sibling-lane stamps had no ceiling, reaction removals had no ordering, and link cards were not ordered.

Fix. One ceiling, `frame_auth::stamp_ceiling` (300 s past the frame time), refuses or clamps stamps; removals delete only reactions added no later; live link cards apply only when newer than the row's last card.

Residual. Remote message timestamps and a stranger's `requested_at` stay unbounded; cards through sync backfill are unordered.

Test. `authz_a_sibling_lane_stamp_never_runs_ahead_of_its_frame`, `authz_a_replayed_public_unreaction_or_card_never_undoes_a_later_one`, `authz_an_old_unreaction_never_removes_a_later_re_add`, `authz_an_older_card_never_replaces_a_newer_one`. Mutation pass 10/10.

HOL-SEC-069: One account could fill the relay's memory and crash it for everyone

Severity: High (Impact H, Exploitability H). **Class:** A. **Fixed in:** Relay, 2026-09-29.

Impact. One free identity could fill the relay's memory and crash it, losing every RAM buffer.

Description. Join lock chains, topic subscriptions, push registrations and channel-push throttle entries had no bound on what one account could make them hold.

Fix. Byte budgets with fair-share eviction for locks and registrations, per-socket caps on subscriptions, validated tokens and platforms, and a cap on throttle entries per target.

Residual. The CPU cost of verifying a 256-link lock chain was left to phase G (the circuit breaker of HOL-SEC-183's commit, in shadow mode).

Test. Relay `test_join_lock` and the live probe; `test_snapshot_codec` (v6). All 13 relay suites passed on the VPS.

HOL-SEC-070: Throwaway identities could push real entries out of the relay's tables

Severity: Medium (Impact M, Exploitability M). **Class:** A. **Fixed in:** Relay, 2026-09-29.

Impact. Throwaway identities could push real offline messages, catch-up rings, parked joins and destroy orders out of the relay's tables.

Description. Every full relay table evicted by age or by identity, and identities are free.

Fix. Every table a stranger can fill charges each entry to the writer's hashed address share and evicts from the heaviest share (`fair_share.h`); nothing refuses and nothing is rate limited.

Residual. An attacker holding many address blocks can still churn the caches, without reading, forging or blocking anything.

Test. Relay `test_fair_share`, `test_kill_list`, `test_relay_validators`, `test_ring_evict`, `test_join_lock`. An ASan run of these tests caught a use-after-free in the new eviction before deploy.

HOL-SEC-071: A legacy server's catch-up rings went to whoever signed for them first

Severity: Low (Impact L, Exploitability M). **Class:** A. **Fixed in:** 0.12.0; relay 2026-09-29.

Impact. A pre-0.12 server's relay catch-up could be stopped or stretched by whoever signed for its rings first.

Description. A 32-hex server id names no owner, and the relay kept one ring set per room bound to the first signer.

Fix. A legacy server's ring topics carry the owner, and signed control reaches only that owner's topics.

Residual. A joiner whose invite has no `owner=` uses plain topics, so its parked join is not seen (AR-10 territory).

Test. `authz_a_legacy_servers_rings_follow_its_owner_not_the_first_signer`, `a_legacy_servers_topics_carry_its_owner`, `a_legacy_control_reaches_only_its_owners_topics`, relay `test_ring_auth`.

HOL-SEC-072: The relay read meeting knocks, lobby frames and the host

Severity: Medium (Impact M, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. The relay read meeting knockers' names and credentials, the host's name, and enough to identify the host.

Description. Knocks, lobby and host frames and the meeting Welcome rode frames the relay reads.

Fix. Meeting links carry a key, and every meeting-lane frame rides `MeetingSealed` under a key derived from it, bound to room and sender.

Residual. The relay still sees the meeting's room, who sits in it and when.

Test. `c24_a_meeting_shows_the_relay_no_name_and_no_host`, `authz_a_meeting_frame_counts_only_under_its_link_key`, `a_meeting_frame_opens_only_under_its_key_in_its_room_for_its_sender`.

HOL-SEC-073: The relay, push sender and forwarder ran as an account with root

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** Relay host, 2026-09-30.

Impact. One memory-safety bug in the relay or its sibling services would have given root on the relay box, with the TLS key, the TURN secret and the push credential.

Description. The relay, push sender and forwarder ran unsandboxed as an account with passwordless sudo, the relay binary was writable by that account, and an abandoned proxy still listened.

Fix. Each service runs as its own account from root-owned binaries in a full systemd sandbox (exposure scores 1.1 to 1.4), denied system calls return EPERM, and the proxy is removed.

Residual. The admin account keeps sudo behind SSH keys; a kernel bug reachable through the allowed calls would still escape.

Test. `relay-uws/deploy/check-host.sh`, which fails on a unit shaped like the old one; a canary run and production restored every buffer.

HOL-SEC-074: Every local account could read the relay's TLS key and secrets

Severity: Medium (Impact H, Exploitability L). **Class:** C. **Fixed in:** Relay host, 2026-09-30.

Impact. Any local account on the relay box could read the TLS private key and the service secrets.

Description. A renewal hook made private keys world-readable, secrets sat in `Environment=` lines readable through `systemctl show`, and coturn's secret was on its command line.

Fix. Keys are group-readable only by their services, secrets live in root-only environment files or `LoadCredential=`, and coturn reads its secret from a private file.

Test. `check-host.sh` (Secrets and Private keys sections).

HOL-SEC-075: Push token prefixes and client addresses were written to the relay's disk

Severity: Medium (Impact M, Exploitability M). **Class:** P. **Fixed in:** Relay host, 2026-09-30.

Impact. Push token prefixes, client addresses and share activity were written to the relay's disk, against the privacy policy.

Description. rsyslog copied service journal lines to disk, the firewall logged client addresses, and the forwarder and a proxy kept their own logs.

Fix. rsyslog drops every `hollow-*` program, firewall logging is off, the headless forwarder opens no log file, and old lines were scrubbed.

Residual. `auth.log` keeps SSH attempts (needed by fail2ban); sysstat keeps whole-box totals only.

Test. `check-host.sh` (Disk section), `the_headless_forwarder_opens_no_log_file`.

HOL-SEC-076: The recovery phrase and the device's Olm and MLS state rode every backup and link snapshot

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Every backup and link snapshot carried the recovery phrase and the device's live Olm and MLS state.

Description. The phrase was stored in the database and copied whole into every snapshot, with the Olm account and sessions.

Fix. The phrase is never stored (shown once, checked, forgotten); snapshots export a scrubbed database and every import clears device secrets so each device mints its own.

Residual. Whoever reads the phrase on paper is the identity (AR-15).

Test. `snapshots_leave_device_secrets_behind_both_ways`, `dialogs_batch1_test` (the two-step phrase dialog).

HOL-SEC-077: A stolen device or a leaked backup held the identity for good

Severity: Critical (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. A stolen usable device or a leaked backup held the identity for good, able to remove the owner's real devices and order wipes.

Description. Every device holds the master key, and the master key was the authority over the device list.

Fix. Design ID-1 makes the roster of self-verifying statements the authority, rooted in a recovery phrase no device stores; the master key admits nothing, restored backups wait seven quiet days unless approved, removed devices lock and erase, and remote destroy needs the phrase.

Residual. Recorded as AR-15, which covers legacy identities until the phrase is confirmed, first contact after a forged recovery key, and the fact that whoever holds the phrase is the identity.

Test. `authz_a_stolen_backup_is_never_a_member_until_approved`, `authz_the_phrase_takes_the_identity_back_from_a_stolen_device`, `authz_a_destroy_order_needs_the_phrase`, `a_restored_device_matures_at_a_contact_after_seven_quiet_days`. Mutation pass 22/22.

HOL-SEC-078: The relay let a master-key holder read a protected identity's inbox and lock its devices out

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0; relay 2026-10-02.

Impact. A master-key holder could read a protected identity's inbox and lock its real devices out of their own mailbox.

Description. The relay gave inbox ownership to any master-signed device list naming the socket, and kept the highest list version, so a forged huge version locked the owner out.

Fix. Design ID-1R makes the relay fold every roster shown for an identity with the apps' own rules (`relay-uws/src/roster.h`, checked against vectors the Rust code writes) and own the inbox only for a member.

Residual. After a relay box reboot the first roster shown sets the recovery key there (AR-15).

Test. `authz_the_master_key_alone_never_owns_a_protected_inbox`, `authz_a_removed_device_loses_the_inbox_at_once`, `mailbox_requires_a_roster_that_counts_the_device`, relay `test_roster.cpp` (117 vectors).

HOL-SEC-079: Statements from anyone could push a removal or a vouch out of a roster

Severity: High (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. Anyone's roster statements could push a real removal or vouch out of a roster, so a removed device counted again at every contact.

Description. Statements were kept up to per-kind ceilings in statement order, and a signer's standing in the roster was never checked.

Fix. A vouch or removal counts only from a signer with standing, and the kept statements are ordered by the signer's distance from the phrase, so a flood pushes out nothing shallower. The relay mirrors the rule.

Residual. A member that is not removed can still flood its own base; the phrase ends it.

Test. `authz_a_strangers_flood_pushes_no_statement_out`, `authz_a_members_flood_never_displaces_a_signer_closer_to_the_phrase`, `authz_signer_rank_decides_what_a_full_roster_keeps`, `compaction_is_stable`, `the_largest_roster_fits_on_the_wire`.

HOL-SEC-080: A removed device could bring a new device in through that device's own removal of it

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A removed device could keep adding devices that every contact counted as the person's.

Description. The vouchees a removed device kept were the union over every removal of it, including one signed by its own new device.

Fix. A removed device keeps only what every removal of it keeps (the intersection). The relay mirrors the rule.

Residual. By default the app keeps current members the removed device vouched for.

Test. `authz_a_removed_device_cannot_bring_a_device_back_through_its_own_removal`, `a_removed_device_keeps_only_what_every_removal_keeps`.

HOL-SEC-081: Destroying a device dropped the devices it had linked

Severity: Low (Impact M, Exploitability L). **Class:** A. **Fixed in:** 0.12.0.

Impact. Destroying one device dropped the person's other devices it had linked.

Description. The self-removal kept none of the device's vouchees.

Fix. The self-removal keeps every current member the device vouched for.

Test. `removing_itself_keeps_the_devices_it_linked`.

HOL-SEC-082: A recovery did not restart a restored backup's seven days

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0; relay 2026-10-02.

Impact. A backup the phrase had cut off joined again at once at every contact and the relay.

Description. A pending join's first sight was kept per device across bases, so after a recovery the old seven days still counted.

Fix. First sight is kept per base in the apps and at the relay; a recovery restarts every waiting device's seven days.

Test. `authz_a_backup_left_out_by_a_recovery_waits_again_in_the_new_base`, relay vector `a-recovery-restarts-the-clock`, `a_waiting_backup_asks_again_when_the_wait_is_turned_off`.

HOL-SEC-083: The master key alone could act as the bare master id

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A master-key holder logged in as the bare master id was treated as one of the identity's devices, served its DM history, friends and servers, and taken as the owner by contacts.

Description. The resolver mapped a master id to itself, so every "is this our device" check accepted the bare master id.

Fix. A master id is a device only when the roster held for it counts it; frames from a bare master id are dropped everywhere except the roster notice.

Test. `authz_the_master_key_alone_never_speaks_as_the_bare_master_id`, `authz_a_master_id_is_a_device_only_while_its_roster_counts_it`, `bare_master_gates_stay_wired`. Mutation pass 24/24.

HOL-SEC-084: A removed device still committed to MLS groups

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A removed device that still held a leaf could evict its identity's other devices from groups.

Description. `commit_verdict` never asked whether the committer was revoked or disowned.

Fix. Commits from, and rebinds into, a revoked or disowned leaf are refused.

Test. `a_removed_disowned_or_bare_master_leaf_neither_commits_nor_is_added`.

HOL-SEC-085: Any server member could make us forward a file to its gossip neighbours

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Any member of a larger server could make us forward a file's ciphertext from another conversation to its gossip neighbours.

Description. A `BroadcastMeta` envelope bound nothing, and the gossip file relay it armed never worked for honest use.

Fix. The gossip file relay is deleted.

Test. `a_broadcast_meta_envelope_arms_nothing`.

HOL-SEC-086: A push wake from anyone moved the live Android node into a room with them

Severity: Low (Impact L, Exploitability M). **Class:** P. **Fixed in:** 0.12.0.

Impact. A push wake naming a stranger made an Android phone join a room with that stranger, revealing it online.

Description. The DM wake's named sender was never checked before the room join.

Fix. One gate, `fetch::dm_wake_room`, joins a room only with ourselves or an unblocked friend.

Test. `a_dm_wake_from_a_stranger_joins_nothing`, `a_dm_wake_names_only_ourselves_or_a_friend`.

HOL-SEC-087: A blocked friend could still pull our DM history

Severity: Low (Impact L, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. A blocked friend could still pull our whole conversation with it.

Description. The DM sync responder did not check the block list.

Fix. The responder refuses a blocked identity before reading the store.

Test. `authz_a_blocked_friend_pulls_no_dm_history`.

HOL-SEC-088: A refused server op still moved our clock

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A refused op could still date our next server ops up to five minutes ahead.

Description. The fold advanced our clock before asking whether the op's author may write.

Fix. Only admitted ops move the clock.

Test. `authz_only_an_admitted_op_moves_our_clock`.

HOL-SEC-089: A frame that failed to decrypt made us send its sender what we hold

Severity: Low (Impact L, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Anyone in a server's room could learn which ops and messages we hold.

Description. After an undecryptable MLS frame we asked its sender to sync, without checking the sender.

Fix. Sync requests go only to a member device, and a channel's only to a member who can read it.

Test. `authz_a_frame_that_fails_to_decrypt_asks_only_a_member_to_sync`.

HOL-SEC-090: Every server member learned who sat in a restricted voice channel

Severity: Low (Impact L, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Every member learned who sat, muted, shared or recorded in a restricted voice channel.

Description. Voice presence and state rode the server-wide group and an Olm copy to every member.

Fix. A restricted voice channel's presence and state ride its own subgroup, and the Olm copy goes only to members who can see it.

Test. `restricted_voice_presence_reaches_only_its_viewers`.

HOL-SEC-091: Anyone holding a server id saw who was in its room and when

Severity: Medium (Impact M, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. Anyone holding a server id saw every online member device, each join and leave and every broadcast's sender, linkable across servers.

Description. Joining a server's relay room took only an authenticated socket.

Fix. Where a server's join lock is on the relay, only a socket proving the newest door (an HMAC under X25519 of the door and the relay key, bound to the auth nonce) sees the room; a lock move keeps provers for 60 s and stale members ask for the door.

Residual. Recorded as AR-16, which covers open invites, a device id someone already knows, the 60 s grace, and legacy servers and meetings, which are unchanged.

Test. `authz_an_outsider_holding_a_server_id_sees_nobody_in_its_room`, `authz_a_removed_member_stops_seeing_the_room_once_the_lock_moves`, `door_proof_matches_the_relays_pinned_vector`, relay `test_door_room`.

HOL-SEC-092: Any member could list anyone as a member of a server

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member could list any identity as a member of a server on every replica.

Description. `MemberAdded` named its target by id alone, with no proof the target asked.

Fix. The joiner signs an ask with its master key, the admitting op carries it, and each ask admits once.

Test. `authz_member_added_names_only_someone_who_asked`, `authz_a_member_lists_only_someone_who_asked_to_join`.

HOL-SEC-093: A member's snapshot of an older server set the joiner's roles and bans

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. The member answering a join could, on the joiner's replica, make itself admin, ban others or make a channel public until the owner's checkpoint arrived.

Description. A join snapshot from a member was taken whole apart from the owner check.

Fix. A member's snapshot keeps only the owner's role and drops roles, bans, mutes, grants, labels and public flags.

Test. `authz_a_join_snapshot_carries_no_authority`, `authz_a_members_snapshot_of_an_older_server_decides_nothing`.

HOL-SEC-094: A channel restricted after it was public stayed public

Severity: Medium (Impact M, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. Posts in a channel the admins had restricted went out unencrypted, readable by the relay and guests.

Description. Restricting a public channel left its public flag set.

Fix. A restricted channel is never public, restricting clears the flag for good, and an op flagging a restricted channel public is refused.

Test. `authz_a_restricted_channel_is_never_public`, `authz_a_hidden_channel_never_shows_to_a_guest`.

HOL-SEC-095: A guest stored public posts unjudged and showed names any member chose

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A guest stored public posts unjudged in its database and showed author names any member chose.

Description. Guest posts went through the member ingest with no server state, and answering members named authors freely.

Fix. Guest posts live only in memory while browsing, and authors show only by their own master-signed card.

Test. `a_guest_store_lives_in_memory_only_while_held`, `authz_a_guest_keeps_public_posts_in_memory_only`, `authz_a_guest_shows_an_author_only_by_its_own_card`.

HOL-SEC-096: Junk from a few addresses could push a lost device's destroy order out

Severity: Medium (Impact H, Exploitability L). **Class:** C. **Fixed in:** 0.12.0; relay 2026-10-03.

Impact. Junk deposits from a few address blocks could evict the destroy order parked for a stolen device.

Description. A target held at most eight issuer slots with fair-share eviction, and an acknowledgment named only a stamp.

Fix. The relay reads a parked order and keeps a phrase-proven one in its own slot that opaque deposits never reach; acknowledgments name issuer and stamp.

Residual. Recorded as AR-18, which covers identities with no recovery key yet and attackers holding many address blocks.

Test. Relay `test_kill_list`, `test_kill_order` (30 shared vectors), `a_kill_signal_keeps_its_issuer_for_the_ack`, `authz_turning_away_junk_that_shares_an_orders_stamp_keeps_the_order`. Mutation pass 23/24 (one equivalent).

HOL-SEC-097: A kick notice made a member drop a server with no removal behind it

Severity: Low (Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A moderator could silently eject a member from a server that every other replica still listed.

Description. The kicked member acted on a bare kick notice with no signed removal behind it.

Fix. The notice carries the removal or ban op, which enters through the one remote ingest; a ban of us now tears down like a removal.

Residual. A member offline during the kick learns it later (HOL-SEC-114).

Test. `authz_a_kick_notice_without_its_removal_op_is_ignored`, `authz_a_kick_from_before_a_rejoin_is_ignored`, `a_ban_of_us_heard_as_an_op_leaves_the_server`.

HOL-SEC-098: A channel id could name the join ring or break every ring of a server

Severity: Low (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A member with channel rights could break every catch-up ring of a server.

Description. `ChannelAdded` took any string, including the join ring's topic and shapes the relay refuses.

Fix. A channel id must be 1 to 64 bytes of `[A-Za-z0-9_-]` on authoring, ingest, snapshots and checkpoints.

Test. `authz_channel_added_needs_a_channel_id_shape`.

HOL-SEC-099: Rust took any string as a server id

Severity: Low (Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Hardening. Malformed server ids could be read as channel subgroups or start a server join for a meeting id.

Description. Only the Dart link parser checked a server id's shape.

Fix. Rust accepts only 40 or 32 lowercase hex server ids at every entry, and every inbound MLS frame is shape-checked at dispatch.

Test. `a_server_id_is_32_or_40_lowercase_hex`, `an_mls_frame_names_a_group_only_by_real_ids`, `join_with_a_malformed_server_id_starts_nothing`.

HOL-SEC-100: A removed author could still rewrite and re-card its old posts

Severity: Low (Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A kicked or banned author could keep rewriting and re-carding its old posts.

Description. Live edits and cards checked only the mute flag.

Fix. One ladder, `live_channel_change_refusal` (member, can see, not muted), judges every live edit, card and reaction.

Test. `authz_a_removed_author_no_longer_edits_or_recards_live`.

HOL-SEC-101: Reactions skipped channel visibility live and membership in backfill

Severity: Low (Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Members who cannot see a channel, and never-members through sync, could attach reactions to its posts.

Description. Live reactions skipped visibility, and sync batches never checked reactors.

Fix. Live reactions take the change ladder; batches keep a reaction only if its reactor was a member at its time; DM sync keeps only the two parties' reactions.

Residual. A backfilled reaction's time is the reactor's claim (as AR-11).

Test. `authz_a_reaction_needs_a_reactor_who_can_see_the_channel`, `authz_a_synced_dm_reaction_comes_only_from_a_party`, `authz_backfill_drops_a_reaction_by_a_never_member`.

HOL-SEC-102: A stream could declare any size and get a temp file for it

Severity: Medium (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A room peer could fill the receiver's disk with streams nobody asked for.

Description. The stream lane trusted a stream's declared size.

Fix. A new stream must fit a ceiling set by what we expect of it before a temp file exists.

Test. `a_stream_cannot_declare_past_its_ceiling`, `a_stream_ceiling_follows_the_header_the_ask_or_the_link`.

HOL-SEC-103: Completed streams with no header parked without a limit

Severity: Medium (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A room peer could bypass the per-sender stream cap and pile up temp files.

Description. Streams completed before their header were parked with no limit.

Fix. Early streams are capped per sender and in total, and a flood evicts only its own.

Test. `early_streams_cap_each_sender_and_evict_its_own_oldest`.

HOL-SEC-104: A streamed vault shard bypassed our storage pledge

Severity: Low (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A member could make us store more vault data than we pledged.

Description. A streamed shard was judged against the pledge as one byte.

Fix. Completion re-judges the real size with `pledge_refused`.

Test. `pledge_refused_counts_the_real_size`, `vault_gates_stay_wired`.

HOL-SEC-105: An unasked shard answer blocked a vault download for good

Severity: Medium (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A member could make vault content impossible for us to rebuild.

Description. Any member could answer a shard pull we never made, and a held shard is never replaced.

Fix. Every pull records the device asked, and only its answer is taken, once.

Residual. Unasked stores remain possible by design; HOL-SEC-117 handles bad copies.

Test. `an_unasked_shard_response_is_dropped`, `vault_gates_stay_wired`.

HOL-SEC-106: A recovery plan's content id reached a temp path unchecked

Severity: Low (Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A shard temp file was named from a sender-chosen string.

Description. The recovery plan built temp names from content ids that shard writes never shape-checked.

Fix. Shard writes take only 64-hex content ids, and temp names come from the hashed shard key.

Test. `authz_shard_write_needs_a_member_and_a_shard_we_lack` (extended).

HOL-SEC-107: The push process had no file header size cap

Severity: Low (Exploitability L). **Class:** A. **Fixed in:** 0.12.0.

Impact. A friend could make the push process write a large file and decode inline bytes before any check.

Description. The push fetch process had no copy of the file header size cap.

Fix. One gate, `header_size_refused`, serves every header arm and judges inline bytes before decoding.

Test. `fetch_refuses_a_dm_header_over_the_send_limit`, `header_size_gate_judges_inline_bytes_before_decoding`.

HOL-SEC-108: Data channel answers paired with our offer by connection id alone

Severity: Low (Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. The relay with an identity of its own could answer our data channel offer; the channel's payloads kept their own end-to-end encryption.

Description. Answers and ICE were paired by a non-secure connection id alone.

Fix. A signal pairs only with a connection of its sender's identity, early ICE is queued per identity, and ids come from `Random.secure()`.

Test. `test/rtc_signal_pairing_test.dart` (three cases, all failed before).

HOL-SEC-109: The standalone forwarder took unsealed and replayed frames

Severity: Low (Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Replayed key requests could force re-keys at the standalone forwarder.

Description. The forwarder accepted unsealed frames from new senders and checked neither seal time nor nonce.

Fix. The forwarder judges frames with the same `frame_auth` code as the main node.

Test. `fwd_refuses_an_unsealed_frame_from_a_first_contact`, `fwd_takes_a_key_request_once_and_only_while_fresh`, `fwd_answers_every_peer_sealed`.

HOL-SEC-110: Voice channel SDP and ICE over Olm had no signal rate limit

Severity: Low (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A voice participant could flood targeted signals limited only by the general frame bucket.

Description. Only the MLS arm charged the voice signal bucket; targeted signals ride Olm.

Fix. One predicate feeds both the MLS and a new Olm guard.

Test. `authz_a_vc_signal_flood_over_olm_is_rate_limited`, `is_vc_signal_covers_every_voice_channel_envelope`.

HOL-SEC-111: A key request from anyone minted a fresh one-time key

Severity: Low (Exploitability H). **Class:** A. **Fixed in:** 0.12.0.

Impact. Any device id could make us mint one-time keys without limit, pushing out the key a friend request carries.

Description. Each signed KeyRequest from an unknown device minted a fresh one-time key.

Fix. Each requesting device holds one slot whose key is re-sent until spent; 256 slots, persisted with the account.

Test. `a_key_request_flood_never_spends_a_carried_key`, `one_requester_holds_one_key_across_repeats`, `authz_one_device_holds_one_of_our_one_time_keys`. Mutation pass 9/9.

HOL-SEC-112: A friend request from before a removal came back

Severity: Low (Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A removed friend could reappear as a pending request or as a friend.

Description. A friend request had no bound against a later end of the friendship.

Fix. The arm refuses revoked senders, caps the stamp at the seal, and drops a request made before the friendship last ended.

Residual. A friend whose clock runs more than five minutes behind loses a re-request sent right after a removal.

Test. `authz_a_friend_request_from_before_a_removal_never_returns`, `a_removal_bounds_only_what_was_made_before_it`.

HOL-SEC-113: A sibling that missed a removal brought the friend back

Severity: Low (Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A sibling that missed a removal brought the friend back as accepted.

Description. The removal tombstone was written and never read.

Fix. The friend list arm skips an entry whose request predates the friendship's recorded end.

Test. `authz_a_stale_siblings_friend_list_never_brings_back_a_removed_friend`.

HOL-SEC-114: A member removed while offline never learned it

Severity: Low (Exploitability none needed). **Class:** A. **Fixed in:** 0.12.0.

Impact. A member removed while offline kept a stale copy of the server and its group (no access granted).

Description. Former members were served nothing, so they never learned their removal.

Fix. A former member's device that asks gets the op that ended its membership and the ops its fold needs to admit it, and nothing later.

Residual. A checkpoint that prunes the removal, and legacy servers past the log cap, leave such a member uninformed.

Test. `authz_a_member_kicked_while_away_learns_it_when_it_asks_for_the_door`, `authz_a_member_banned_while_away_learns_it_from_its_sync`, `authz_a_former_member_is_told_its_removal_and_the_rank_behind_it_only`. Mutation pass 11/11.

HOL-SEC-115: A friend removal reached only the device it happened on

Severity: Medium (Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A removed friend kept friend access (full profile, DMs) on our other devices.

Description. A removal changed only the device it happened on, and the sibling friend list carried accepted friends only.

Fix. Removals ride the sibling friend list in their own field, taken only from a roster-counted, unrevoked device of ours.

Residual. A legacy tombstone with no time is never shared.

Test. `authz_a_removal_reaches_an_online_sibling_and_never_undoes_a_readd`, `a_removal_reaches_a_sibling_that_was_away`, `authz_only_our_own_device_tells_us_a_friendship_ended`. Mutation pass 11/11.

HOL-SEC-116: The Dart data channel receiver trusted every stream's size and sender

Severity: Medium (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A data channel peer could fill the receiver's disk or spoil another peer's transfer.

Description. The Dart data channel receiver trusted every stream's declared size and sender.

Fix. A first frame is judged against Rust's ceilings, a stream is extended only by its opener, and open streams are capped per connection and in total.

Residual. A co-member who knows a file id can open it first and hold it for 10 s.

Test. `test/rtc_stream_intake_test.dart` (five cases, all failed before). Mutation pass 15/15.

HOL-SEC-117: A planted or wrong vault shard blocked a download for good

Severity: Medium (Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. A member could block a vault download for good by planting a wrong shard.

Description. Held shards are never replaced and nothing removed a bad copy after a failed rebuild.

Fix. The creator's manifest pins each shard's hash; contradicted copies are refused and deleted, and a holder that answered wrongly is not asked again.

Residual. Older manifests carry no hashes; the first manifest for a content id still wins (AR-20).

Test. `a_planted_vault_shard_is_dropped_and_the_real_one_pulled`, `a_holder_that_answers_with_a_wrong_shard_is_not_asked_again`, `a_shard_must_be_the_one_its_manifest_names`. Mutation passes 19/19 and 14/14.

HOL-SEC-118: Olm channel changes for a server we no longer hold were applied

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Any device holding an Olm session with us could attach reactions to rows of a server we had left.

Description. Olm change arms passed a missing server state to handlers that read it as nothing to judge.

Fix. Every Olm channel change arm refuses a server we hold no state for.

Test. `authz_olm_channel_changes_need_a_server_we_hold`.

HOL-SEC-119: A channel delete or a refused reaction reached the screen unchecked

Severity: Info (Impact L, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A delete or a refused reaction could show on screen until the next reload; nothing was stored.

Description. The delete event was emitted outside the store transaction, and reaction events were emitted whether stored or not.

Fix. Events follow only a stored change.

Test. `authz_a_channel_change_reaches_dart_only_once_stored`.

HOL-SEC-120: Leaving a voice channel while watching a share kept our forwarding offer

Severity: Low (Impact L, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A sharer we once watched could keep using our upload after we left the voice channel.

Description. Our leave handler cleared watched shares before the teardown read them, and a racing second teardown skipped cleanup.

Fix. One call teardown runs at a time, reads watched shares first, and guards each phase.

Test. `test/vc_leave_teardown_test.dart` (seven tests). Mutation pass 9/9.

HOL-SEC-121: A member back from away answered a removed joiner's old parked ask

Severity: Low (Impact L, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member back from away could briefly re-admit a joiner that had since been kicked or banned.

Description. The relay replayed a join ring oldest first with no end mark, so an old parked ask looked fresh to a member that missed its verdict.

Fix. A member holds join asks until its ring replay ends (a new relay end mark) and a member's nonce-echoed sync answers, at most 10 s, and answers nothing while the relay hides it.

Residual. A member alone in the room judges with what the ring gave it; other members' folds refuse the double admission (HOL-SEC-092).

Test. `authz_a_member_back_from_away_gives_a_kicked_joiners_old_ask_nothing`, `authz_a_member_back_from_away_gives_a_banned_joiners_old_ask_nothing`, `authz_a_member_back_hidden_answers_no_direct_ask`, relay `test_catchup_end_mark`. Mutation passes 35/35 and 5/5.

HOL-SEC-122: Anyone in the room could open an unlimited stream for a file we pulled

Severity: Low (Impact L, Exploitability M). **Class:** A. **Fixed in:** 0.12.0.

Impact. Anyone in a room could open an unlimited stream for a file we were pulling.

Description. An explicit pull lifted the stream ceiling for whoever opened the stream.

Fix. The unlimited ceiling goes only to the device our ask names.

Residual. Any room device can still open a capped stream for that id and hold it for 10 s.

Test. `a_stream_ceiling_follows_the_header_the_ask_or_the_link`.

HOL-SEC-123: Meetings took a device its identity's roster no longer counts

Severity: Medium (Impact M, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A device its identity's roster no longer counts could run a meeting's lobby, knock as that identity and stay in the call.

Description. Meetings checked only the master's certificate, never the roster.

Fix. `mls_authority::refused` applies to host frames, knocks, admits, chat and voice joins; the host commits out a dropped device and every participant closes its call.

Residual. A host that holds no roster for the identity still trusts the certificate (AR-15).

Test. `authz_a_device_the_hosts_roster_leaves_out_runs_no_lobby`, `authz_a_device_its_roster_leaves_out_never_joins_or_speaks_in_a_meeting`, `authz_the_host_unseats_a_device_its_roster_drops_mid_meeting`. Mutation passes 7/7 and 17/17.

HOL-SEC-124: A re-sealed MLS commit or Welcome made us send what we hold

Severity: Low (Impact L, Exploitability M). **Class:** P. **Fixed in:** 0.12.0.

Impact. Whoever re-sealed a genuine commit or Welcome to us learned which ops and messages we hold.

Description. The follow-up sync went to the frame's sealer, which nothing tied to the committing leaf.

Fix. Syncs go to the committing leaf's own member device, or to a sender `sync_partner` admits.

Test. `authz_a_held_commit_asks_only_a_member_to_sync`, `authz_a_welcome_asks_only_a_member_to_sync`.

HOL-SEC-125: The bare master id came back into room presence through discovery

Severity: Low (Impact L, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A bare master id re-entered room presence through discovery and received our key request.

Description. The discovery arm did not filter bare master ids like the other presence arms.

Fix. The discovery arm filters through `bare_presence.admits`.

Test. `bare_master_gates_stay_wired` (extended).

HOL-SEC-126: Anyone could see who used a media forwarder and when

Severity: Medium (Impact M, Exploitability H). **Class:** P. **Fixed in:** Relay, 2026-10-04.

Impact. Anyone who knew a forwarder's id saw every sharer and viewer using it, across servers and over time.

Description. The relay treated `fwd:{X}` rooms like any other room.

Fix. Every member of a forwarder room is paired with the forwarder alone (`fwd_room.h`); no other member sees or reaches another.

Residual. The forwarder itself sees everyone using it, by design.

Test. Relay `test_relay_live` forwarder section and `test_fwd_room`; harness `authz_a_stranger_in_a_forwarder_room_meets_only_the_forwarder`. Mutation pass 21/21.

HOL-SEC-127: A socket a locked server room hides still left channel copies and wakes

Severity: Low (Impact L, Exploitability M). **Class:** A. **Fixed in:** Relay, 2026-10-04.

Impact. A socket a locked room hides could still park channel copies and fire push wakes at members.

Description. The 0x09 handler checked room presence, not whether the sender sees the room.

Fix. Channel copies and wakes are kept only from a sender that sees the room.

Test. Relay `test_relay_live` door-room section; harness `authz_a_socket_the_room_hides_leaves_no_channel_copy`.

HOL-SEC-128: One join frame from any identity crashed the relay and lost every buffer

Severity: High (Impact H, Exploitability H). **Class:** A. **Fixed in:** Relay, 2026-10-04.

Impact. One join frame from any identity crashed the relay and lost every RAM buffer.

Description. The relay re-serialised a client's nested JSON recursively, so a frame nested about 200,000 levels deep overflowed the stack.

Fix. Every client JSON enters only through `client_json::parse`, which refuses nesting deeper than 32 before parsing.

Test. Relay `test_deep_json`, `test_client_json.cpp`, depth checks in `test_auth_frame.cpp` and `test_kill_order.cpp`. Mutation pass 9/9.

HOL-SEC-129: A device-link code, a backup file or an archive from someone else could write files anywhere the user can

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A link code, backup file or archive from someone else could write files anywhere the user can, which on a desktop leads to code execution.

Description. Snapshot and archive import wrote zip entries to paths built from raw entry names.

Fix. Entries are read only through `enclosed_name()` against an allowlist with a size budget, checked before anything is written; the updater refuses non-plain names.

Test. `a_snapshot_lands_only_what_a_snapshot_holds`, `a_snapshot_that_unpacks_past_its_size_is_refused`, `an_archive_lands_attachments_only_in_its_own_folder`, `rejects_absolute_entries`. Mutation pass 34/37 (three layered survivors).

HOL-SEC-130: A restored backup the owner refused gained the power to remove every owner device by waiting seven days

Severity: High (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0; relay 2026-10-04.

Impact. A restored backup the owner refused could, after seven days, remove every owner device.

Description. A refused pending join still matured and gained removal power.

Fix. A pending join removed by a device that belongs without waiting never matures. The relay mirrors the rule.

Test. `authz_a_refused_join_never_gains_removals_by_waiting`, vector `a-refused-join-removes-nobody`.

HOL-SEC-131: Every Welcome into a server would fail once any member's leaf was 84 days old

Severity: Medium (Impact M, Exploitability none needed). **Class:** A. **Fixed in:** 0.12.0.

Impact. Every Welcome into a server would have failed about three months after 0.12 shipped, for many servers at once.

Description. OpenMLS validates the lifetime of untouched leaves in a Welcome, the default KeyPackage lifetime is 84 days, and Hollow leaves never updated themselves.

Fix. Welcomes skip leaf lifetime validation; seats are judged by the roster and the CRDT, never by leaf age.

Test. `a_welcome_still_installs_after_an_old_members_leaf_lifetime_ends`.

HOL-SEC-132: A member could repeatedly evict another member from a server's encryption group with that member's old KeyPackage

Severity: Medium (Impact M, Exploitability H). **Class:** A. **Fixed in:** 0.12.0.

Impact. A member could repeatedly evict another member from a server's group with that member's old KeyPackage.

Description. Receivers accepted removing a leaf whenever the same commit re-added the device, with any KeyPackage of it.

Fix. A re-add counts as a repair only with a KeyPackage minted for this group after the leaf it replaces; held commits get one slot per committer.

Residual. A member can still force epochs with a self-update (AR-27).

Test. `authz_a_member_cannot_evict_a_member_with_its_old_key_package`, `a_spent_or_foreign_key_package_repairs_nothing`, `a_held_commit_survives_another_committers_held_commit`. Mutation pass 15/15.

HOL-SEC-133: A member that missed one removal commit kept encrypting server content to the removed member

Severity: Medium (Impact H, Exploitability L/M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A removed member could read posts sent after its removal by a member that missed the removal commit.

Description. No MLS send path compared the group's leaves with the CRDT membership.

Fix. Every MLS send refuses to encrypt while the group holds a leaf our view no longer seats, falls back to Olm, and the committer removes such leaves.

Test. `authz_a_member_that_missed_a_removal_commit_never_encrypts_to_the_removed_leaf`, `a_member_that_leaves_loses_its_leaf_at_once`.

HOL-SEC-134: A meeting guest could keep another guest out for good by spending its KeyPackage

Severity: Medium (Impact M, Exploitability H). **Class:** A. **Fixed in:** 0.12.0.

Impact. A meeting guest could keep another guest out for good.

Description. OpenMLS spends a KeyPackage as soon as a Welcome names it, and Hollow staged any Welcome before judging its sender.

Fix. A meeting Welcome is staged only from the certified host while we knock, unspent KeyPackages are put back, and re-knocks follow only a real spend.

Test. `authz_a_guest_cannot_spend_another_guests_key_package`, `a_welcome_that_is_not_installed_spends_no_key_package`, `a_guest_who_left_a_meeting_is_admitted_again`. Mutation pass 18/18.

HOL-SEC-135: A member could Welcome a leafless member into a group that seats an outsider

Severity: Low (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A member could Welcome a leafless member into a group that seats an outsider, until a probe repaired the fork.

Description. A server Welcome was held only for a non-member sender or a banned leaf.

Fix. Every bound leaf in a Welcome must pass the membership rule, else the Welcome is held and re-judged.

Test. `welcome_rules`, `authz_a_welcome_never_seats_a_non_member`.

HOL-SEC-136: A meeting a participant left kept its secrets, SFrame key included, on disk

Severity: Low (Impact M, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A left meeting's group secrets, its SFrame key included, stayed on disk for good.

Description. Participants never dropped a meeting's group, and every persist rewrote the whole MLS store.

Fix. The group is dropped on leave, end and kick, and unloaded groups are erased at start.

Test. `a_meeting_left_leaves_no_group_secret_on_disk`, `a_restart_keeps_no_meeting_group_and_every_server_group`.

HOL-SEC-137: A crash or a burst could lose or bloat MLS state

Severity: Low. **Class:** A. **Fixed in:** 0.12.0.

Impact. Unused KeyPackage private keys accumulated, a crash could lose a frame for good, and the persistence queue bloated.

Description. Unused KeyPackages were never deleted, a frame lost to a rollback was dropped as a replay, and the queue held a full store copy per send.

Fix. Stale KeyPackages are dropped, a member's replay triggers a channel sync, and queued snapshots coalesce to the newest.

Test. `unused_key_packages_are_dropped_when_stale`, `a_replayed_channel_frame_from_a_member_asks_it_for_the_channel`, `queued_mls_snapshots_coalesce_to_the_newest` (retired in 0.13, when MLS saves became row deltas).

HOL-SEC-138: A kicked or banned member, or a removed device, stayed in the server's voice call

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A kicked or banned member, or a removed device, kept hearing and seeing a server's voice call.

Description. Voice participants were removed only on their own leave or a relay presence change.

Fix. Every remote voice seat is re-judged at the loop head and a failing seat leaves the call; old key slots are overwritten after rotation.

Test. `authz_a_kicked_member_loses_its_voice_seat_at_every_participant`, `authz_a_device_its_roster_drops_loses_its_voice_seat`, `authz_a_voice_seat_is_judged_again_after_it_was_granted`. Mutation passes Rust 5/5, Dart 16/16.

HOL-SEC-139: Any call participant or the forwarder could pin a receiver's CPU with frames that fail to decrypt

Severity: Medium (Impact M, Exploitability H). **Class:** A. **Fixed in:** 0.12.0.

Impact. Any call participant or the forwarder could pin a receiver's CPU with frames that fail to decrypt.

Description. The frame cryptor ran its PBKDF2 key ratchet on every failed frame.

Fix. The ratchet window is 0, so a failed frame costs one AES-GCM open.

Test. Dart "a frame that fails to decrypt is never ratcheted".

HOL-SEC-140: A screen share could pass through the forwarder before it was encrypted

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A screen share could pass through the relay operator's forwarder before it was encrypted.

Description. Nothing on the forwarder path checked that the share's cryptor held a key.

Fix. Forwarder routing, ingest and egress wait for a keyed cryptor.

Test. Dart `forwarder_sframe_gate_test`.

HOL-SEC-141: Anyone who could reach us in a room learned our IP addresses through the Share lane, even with Always relay on

Severity: Medium (Impact M, Exploitability M). **Class:** P. **Fixed in:** 0.12.0.

Impact. Anyone who could reach us in a room learned our IP addresses through the Share lane, even with Always relay on.

Description. Share-lane offers were checked only against the block list and answered with a STUN-only connection.

Fix. A Share-lane offer is answered only for a peer that proved the link key of a share we hold.

Test. `authz_only_a_link_holder_gets_a_share_lane_answer`.

HOL-SEC-142: Call keys could reach the debug log, new camera cryptors started on an old key slot, and a sharer could override a viewer's volume

Severity: Low. **Class:** C. **Fixed in:** 0.12.0.

Impact. Call keys could reach the debug log, new camera cryptors could start on an old key slot, and a sharer could change a viewer's volume.

Description. libwebrtc logged keys at info level, new sender cryptors stayed at slot 0, and the share-audio pipe accepted control frames.

Fix. Key lines are dropped in both log sinks, cryptors get the current key index first, and the renderer drops control frames and bad lengths.

Test. `webrtc_native_log_test`, Dart "a cryptor made after a rotation starts on the current slot", `screen_audio_renderer_test`.

HOL-SEC-143: Whoever served history could make a signed message read as a shorter text its author never wrote

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Whoever served history could make a signed message read as a shorter text its author never wrote.

Description. The signing payload joins fields with ':' with the text last, and only the album field was shape-checked, so text could move into another field.

Fix. Signer and verifier both require every field before the text to have its own colon-free shape.

Test. `a_text_chunk_moved_into_another_slot_never_verifies`, `authz_a_synced_item_cannot_move_text_into_another_slot`, `the_signer_refuses_malformed_signed_slots`. Mutation pass 35/35.

HOL-SEC-144: One friend request let a stranger watch our devices come and go, and blocking did not stop queued DMs

Severity: Medium (Impact M, Exploitability H). **Class:** P. **Fixed in:** 0.12.0.

Impact. One friend request let a stranger watch our devices come and go, and a block did not stop queued DMs.

Description. The target joined the DM room as soon as any request arrived and on every connect for every friend row.

Fix. A DM room is joined only for an accepted, unblocked friend or our own outgoing request, and left on decline, cancel, removal and block; a block drops queued DMs.

Residual. Copies the relay parked before a block still replay (AR-31).

Test. `authz_a_friend_request_never_shows_the_stranger_our_devices`, `authz_a_block_takes_our_devices_out_of_the_friends_dm_room`, `authz_a_block_drops_dms_still_queued_for_the_blocked_friend`.

HOL-SEC-145: One-time keys could be spent by another requester, extreme stamps panicked debug builds, and padded keys made alias ids

Severity: Low. **Class:** C. **Fixed in:** 0.12.0.

Impact. A one-time key could be spent by another requester, extreme stamps panicked debug builds, and padded keys gave one key several ids.

Description. Slotted keys were not bound to their requester, stamp arithmetic was unchecked, and key encodings were not length-checked.

Fix. A PreKey spending another requester's key is refused, stamp arithmetic saturates, and public keys must be exactly 36 bytes.

Test. `a_requesters_key_opens_only_that_requesters_session`, `a_frame_stamped_at_the_i64_extremes_is_judged_without_overflow`, `a_public_key_encoding_with_trailing_bytes_is_refused`.

HOL-SEC-146: Links someone else chose opened with any scheme, and a preview card showed a domain its sender picked

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Links someone else chose opened with any scheme (on Windows `file:`, UNC paths and protocol handlers), and a preview card could show one domain and open another.

Description. Chat, card, banner and news links went to the OS launcher with no scheme check.

Fix. One helper, `openUntrustedUrl`, allows https (http where needed) and handles `hollow://` in the app; a card's domain is derived from its URL.

Test. `untrusted_link_test.dart`, `link_preview_card_test.dart`, `a_card_url_and_domain_are_judged_on_the_way_to_dart`. Mutation passes Rust 23/23, Dart 13/13.

HOL-SEC-147: News posts fetched remote images, and a manifest version reached file names and update scripts

Severity: Low. **Class:** C. **Fixed in:** 0.12.0.

Impact. News posts fetched remote images on render, and an update manifest's version reached file names and update scripts unchecked.

Description. The news body used the default image builder, and the signed version string was never shape-checked.

Fix. News renders alt text only; a version must be three numeric parts, and Windows script paths are escaped.

Test. "opening a post fetches no image and shows its alt text", `a_manifest_with_a_malformed_version_is_refused`, `bat_paths_keep_percent_literal_and_refuse_quotes`.

HOL-SEC-148: A link preview made the sender's own machine fetch loopback and LAN addresses

Severity: Medium (Impact M, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A link preview made the user's own machine fetch loopback and LAN addresses.

Description. The preview fetcher checked only the scheme and followed redirects without an address check.

Fix. Names resolving to any non-public address are refused, the connector gets only the checked addresses, and every redirect is checked.

Test. The `address_guard` tests.

HOL-SEC-149: A received video or voice note was decoded by ffmpeg with no tap

Severity: Medium (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A received video or voice note reached ffmpeg's demuxers and decoders with no tap.

Description. The bubbles cut posters and probed voice notes with the bundled ffmpeg on build.

Fix. A received video shows the sender's poster until opened, a voice note's duration comes from a Dart Ogg reader, and ffmpeg runs only after a tap.

Test. `a_received_video_is_not_decoded_before_a_tap`, `a_voice_note_reaches_no_decoder_before_a_tap`.

HOL-SEC-150: Sent videos and some photos carried the sender's location

Severity: Medium (Impact M, Exploitability none needed). **Class:** P. **Fixed in:** 0.12.0.

Impact. Sent videos and some photos carried the sender's location and capture details to every recipient.

Description. Videos went out byte for byte, HEIC kept its Exif, and some fallback paths sent original bytes.

Fix. `media_strip` removes location, camera and time metadata in place on every send read, and refuses covered media it cannot parse.

Residual. Timed GPS tracks in fragmented MP4, subtitle tracks and TIFF or RAW files keep their metadata.

Test. `dm_video_send_strips_location_before_it_leaves`, `every_send_read_goes_through_the_strip`. Mutation passes Rust 18/18, Dart 4/4.

HOL-SEC-151: Peer thumbnails reached Flutter's image decoder unchecked

Severity: Medium (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. Peer thumbnails reached Flutter's native image decoder unchecked.

Description. File-card, video-poster and link-card thumbnails were decoded by Skia when a message painted.

Fix. Every peer thumbnail is decoded by pure-Rust `image-webp` and re-encoded, or dropped, before it crosses to Dart.

Residual. Asset-rail blobs and auto-downloaded images still reached Skia (AR-28, closed in 0.13 with HOL-SEC-173's fix).

Test. `a_peer_thumb_is_reencoded_or_dropped`, `a_card_thumb_reaches_dart_only_reencoded`, `a_header_thumb_must_be_a_placeholder_sized_webp`.

HOL-SEC-152: A device whose clock stepped back forgot its recovery key for good

Severity: Medium (Impact H, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. A device whose clock stepped back forgot its recovery key, so the master key alone again admitted devices there.

Description. Stored rosters were re-judged against the current clock on every load and stripped.

Fix. Held rosters are checked without the clock and keep the pinned key.

Test. `authz_a_clock_behind_the_newest_recovery_keeps_the_phrase_pinned`, `a_held_roster_is_never_judged_by_the_clock_again`.

HOL-SEC-153: During the legacy window a forged recovery key could lock the owner's own devices out of their phrase

Severity: Medium (Impact H, Exploitability L). **Class:** C. **Fixed in:** 0.12.0.

Impact. During the legacy window a forged recovery key could lock the owner's own devices out of their phrase.

Description. The owner's devices pinned the first recovery key any master-key holder published.

Fix. A device holding the 0.11 stored phrase drops keys that phrase does not derive and, at its first 0.12 start, signs the identity's first recovery with it.

Residual. Contacts and the relay still pin the first key seen for an identity none of whose devices kept the phrase (AR-15).

Test. `authz_a_recovery_key_from_the_network_never_locks_out_our_own_phrase`, `authz_a_legacy_identity_pins_its_phrase_before_a_forger_can`, `authz_the_first_start_roots_a_legacy_identity_in_its_stored_phrase`.

HOL-SEC-154: A destroy order could be dated in the future, judged without our roster, or have its targets re-split

Severity: Low. **Class:** C. **Fixed in:** 0.12.0; relay 2026-10-04.

Impact. A destroy order could be dated far ahead, judged without our roster, or have its target list re-split under its signature.

Description. Orders had no upper time bound, an unreadable roster read as "no recovery key yet", and targets joined with ',' were not shape-checked.

Fix. Future-dated orders are refused, an unreadable roster gives no verdict, and every target must be a peer id, in Rust and in the relay.

Test. `a_destroy_order_from_the_future_is_refused`, `a_destroy_order_is_never_judged_without_our_roster`, `a_destroy_orders_targets_cannot_be_re_split_under_its_signature`, relay `test_kill_order`.

HOL-SEC-155: App Lock showed message content and a reply box in notifications, and a link could open above the lock

Severity: Medium (Impact M, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. With App Lock on, notifications showed names and message text with a reply box, and a link could open above the lock.

Description. Notification and deep-link paths ignored the lock.

Fix. While locked, one neutral notification with no reply; links are buffered until unlock.

Test. `notification_lock_test.dart`, `deep_link_lock_test.dart`. Mutation passes Dart 17/17, Rust 5/5.

HOL-SEC-156: A wipe left Hollow files, log lines and the push registration behind

Severity: Medium (Impact H, Exploitability H). **Class:** C. **Fixed in:** 0.12.0.

Impact. A wipe left Hollow files, log lines and the push registration behind, which tell a coercer the identity existed.

Description. The wipe was a name list under the data root, it logged the duress event, and the push token was never deleted.

Fix. The wipe sweeps everything Hollow wrote under and beside the root, logs nothing, deletes and unregisters the push token, and temp staging moved under the root.

Residual. iOS without the filtering entitlement may still show a neutral banner; Google and Apple can link tokens through their own ids.

Test. `a_wipe_leaves_nothing_hollow_wrote_under_the_root`, `no_log_line_tells_of_a_wipe_or_a_duress_code`, `a_wipe_in_the_fetch_node_drops_the_push_token`, Dart `wipe_traces_test.dart`. Mutation passes Rust 22/22, Dart 8/8.

HOL-SEC-157: A duress code typed at a Settings prompt wiped but left the session running, and Settings could show a dead duress code

Severity: Medium (Impact H). **Class:** C. **Fixed in:** 0.12.0.

Impact. A duress code typed at a Settings prompt wiped the data but left the chats on screen.

Description. Only the launch prompt checked the duress slot fully.

Fix. One gate, `open_typed_secret`, serves every typed prompt and ends the session as a duress unlock does.

Test. `a_duress_code_at_any_settings_prompt_wipes_like_the_launch_prompt`, `turning_the_password_off_and_on_never_reports_a_dead_duress_code`.

HOL-SEC-158: iOS backups carried Hollow's data and keys, and the recovery phrase could be captured on screen and in the clipboard

Severity: Medium (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. iOS device backups carried Hollow's data and keys, and the recovery phrase could be captured on screen and in the clipboard.

Description. Folders were not excluded from backup, keychain items could migrate, and phrase screens had no capture protection.

Fix. Data folders are excluded from backup, keychain items are device-only, phrase screens are protected, and a copied phrase clears after 60 s.

Residual. The macOS Rust keychain item keeps its class.

Test. `app_lock_keychain_migration_test.dart`, `secret_clipboard_test.dart`.

HOL-SEC-159: A 4-digit App Lock PIN and a backup passphrase of any length fell quickly to an offline search

Severity: Medium (Impact H, Exploitability M). **Class:** C. **Fixed in:** 0.12.0.

Impact. A 4-digit App Lock PIN and a backup passphrase of any length fell quickly to an offline search.

Description. PIN length and backup passphrase length were unbounded below.

Fix. New PINs need six digits and backup export needs twelve characters; older secrets keep working.

Residual. A six-digit PIN can still be guessed offline, with no hardware attempt limit (AR-24).

Test. `a_new_pin_needs_six_digits`, `a_backup_needs_a_long_passphrase_and_an_old_short_one_still_opens`, `backup_passphrase_test.dart`.

HOL-SEC-160: The relay, the forwarder's disk and the shareable logs held more about people than they need

Severity: Low. **Class:** P. **Fixed in:** 0.12.0.

Impact. The relay, the forwarder's disk and shareable logs held more about people than they need.

Description. Phones sent every push setting, the forwarder stored client device ids on disk, and logs carried names and the link code.

Fix. Only non-default push settings are sent, forwarder sessions live in RAM, and logs and exports carry no names or codes.

Test. `push_prefs_relay_test.dart`, `fwd_keeps_no_client_device_id_on_disk`, `log_lines_name_no_person_place_file_or_link_code`.

HOL-SEC-161: Olm sessions accepted the truncated MAC of v1 and keys of small order

Severity: Info. **Class:** C. **Fixed in:** 0.12.0.

Impact. Olm sessions could start on the truncated v1 MAC or on keys of small order; no way to use either was found.

Description. A PreKey asking for the 8-byte v1 MAC opened a session, and vodozemac never checks that a key agreement is contributory.

Fix. Truncated-MAC PreKeys and small-order keys are refused before any session is built.

Residual. Later ratchet keys are not checked; lead L-02 found no way to use one.

Test. `a_prekey_with_a_truncated_mac_never_opens_a_session`, `a_small_order_key_never_starts_a_session`.

HOL-SEC-162: The device-link screens never said the code is only for a device you hold

Severity: Low. **Class:** C. **Fixed in:** 0.12.0.

Impact. Someone could talk a person into reading out a device-link code.

Description. The code screen never warned against sharing it, and the approval named only a device kind.

Fix. Both screens say the code is only for a device you hold and that nobody from Hollow will ask for it.

Test. Widget test "the code and the approval both say the code is never shared".

HOL-SEC-163: Saving a received file on iOS let its sender's name replace any file in the app's sandbox

Severity: Medium (Impact M-H, Exploitability M). **Class:** C. **Fixed in:** 0.12.1.

Impact. Saving a received file on iOS let its sender's name replace any file in the app's sandbox, the data folder included.

Description. The phone Save action passed the sender's file name to a plugin that removes whatever exists at that path before writing.

Fix. Every Save seeded with a remote name scrubs it with the node's `safe_file_name`, and iOS stages the copy in a fresh folder removed afterwards.

Test. `test/save_name_guard_test.dart`, the Rust `safe_name_*` units.

HOL-SEC-164: One small frame made the relay walk every room a session holds

Severity: High (Impact H, Exploitability H). **Class:** A. **Fixed in:** 0.12.1 (relay).

Impact. One small frame stalled the relay's event loop for every user; a burst could drop every socket.

Description. `active` answered with a fresh member list for every room the session held, as often as a client sent it.

Fix. The relay notes the rooms whose presence it withheld and `active` answers for those alone.

Test. Relay live `hs_active_costs_what_was_withheld`, `test_bounds_active`. Mutation pass 4/5 (survivor bounds memory only).

HOL-SEC-165: A client could grow the relay's ack timer queue by one entry per heartbeat

Severity: Low (Impact L, Exploitability H). **Class:** A. **Fixed in:** 0.12.1 (relay).

Impact. A client could grow the relay's ack timer queue by one entry per heartbeat, tens of MB at most.

Description. Each ack window queued a deadline, and a heartbeat closed the window without removing it.

Fix. A frame queues a deadline only when none is still to come.

Test. Relay live `hs_one_ack_timer`, `test_session_hostile` "acks owed to a client that beats between frames".

HOL-SEC-170: Receivers that never ack could make the relay drop other people's waiting messages

Severity: Medium (Impact M, Exploitability M). **Class:** A. **Fixed in:** 0.12.1 (relay).

Impact. Receivers that never ack could make the relay drop other people's waiting DMs and catch-up frames.

Description. Session rings shared the offline budget, and holding charges landed on the sender's address share.

Fix. Rings have their own pool; bytes are charged to the sender and holding to the receiving session's share.

Test. `test_session_hostile` "receivers that never ack" and "the rings' pool under pressure", `test_session_bounds`.

HOL-SEC-171: Session bounds walked whole tables on hot paths, so full rings or a full table could stall the relay

Severity: Medium (Impact M, Exploitability H). **Class:** A. **Fixed in:** 0.12.1 (relay).

Impact. Full rings or a full session table could stall the relay's single thread.

Description. Three bound checks walked whole tables on hot paths.

Fix. Rings and a session book keep ordered indexes so each choice costs logarithmic or constant time.

Residual. Many address blocks held by one attacker cannot be told apart (phase G).

Test. `test_session_hostile` "the ring against a model" and "the book that spares the caps a walk of the table", `relay-uws/bench/session_cost.cpp`.

HOL-SEC-172: A device coming back to a full address could lose its own session to its own login

Severity: Low (Impact L, Exploitability H). **Class:** A. **Fixed in:** 0.12.1 (relay).

Impact. A device returning to a full shared address could lose its own session to its own login.

Description. The relay ended a grace session before knowing who was arriving.

Fix. A new socket enters only against a grace slot, and the address is settled after login.

Test. Relay live "bounds: a full address and the grace slots it holds".

HOL-SEC-173: A crafted WebP thumbnail in a stranger's friend-request card stopped the receiver's node

Severity: High (Impact M-H, Exploitability H). **Class:** A. **Fixed in:** 0.13 (a7263f6b).

Impact. Any stranger could stop the receiver's node with one friend request; the window stayed open with no network until restart.

Description. A crafted WebP thumbnail in a friend-request card made `image-webp` 0.2.4 panic during the re-encode of HOL-SEC-151, and the panic unwound the node's event loop task. Found by fuzzing the new image check.

Fix. Every decode of peer bytes turns a decoder panic into a refusal (`without_unwinding`), and a pure-Rust image check with memory and time budgets now gates every peer image before any native decoder (closing AR-28).

Residual. The decoder still panics on these inputs, but the panic is contained; the upstream report is held until 0.13 ships.

Test. `a_webp_that_panics_the_decoder_is_refused_not_unwound`, `a_decoder_panic_is_a_refusal`, `mutated_corpus_never_panics_or_hangs`, cargo-fuzz target `image_check`. Mutation passes 34/35 and 22/22.

HOL-SEC-174: Two devices of one identity could mint the same server op id, and replicas diverged for good

Severity: Medium (Impact M, Exploitability M). **Class:** A. **Fixed in:** 0.13 (6b612cb0).

Impact. One of two genuine writes by the same person's devices was silently lost on some replicas, for good.

Description. Every device of an identity minted op stamps with the master as actor, so siblings writing in one millisecond, or after witnessing a peer ahead, minted the same op id and dedup kept one.

Fix. Each device mints in its own counter lane (the actor stays the master, compatible with 0.12.2), witnessing never steps the clock, and a restart witnesses its own log.

Test. `siblings_in_one_millisecond_mint_distinct_stamps`, `two_siblings_same_ms_ops_both_survive`, `two_siblings_after_a_peer_ahead_both_survive`, `g13h_siblings_after_a_peer_ahead_converge_on_both_writes`. Mutation passes 15/15 and 20/20.

HOL-SEC-175: The CRDT sync state vector could lose a server op for good

Severity: Medium (Impact M, Exploitability M). **Class:** A. **Fixed in:** 0.13 (98b4d842).

Impact. An op such as a ban or a role change could never reach a replica that missed it.

Description. The sync state vector sent only ops newer than the newest one per author the asker held, so an older op of that author was never sent again.

Fix. Range fingerprints over fold time replace the vector, so a missing op is found wherever it sits; 0.12.2 peers are still served by the vector.

Residual. The vector path for 0.12.2 peers goes in 0.14.

Test. `sibling_op_older_than_the_vector_tip_still_syncs`, `held_op_expired_after_a_later_op_still_syncs` (both failed on the vector), `digest_random_sets_converge`. Mutation pass 20/20.

HOL-SEC-176: A ground master id led a server's encryption group while the owner was away

Severity: Medium (Impact M, Exploitability M). **Class:** A. **Fixed in:** 0.13 (eb7ed684).

Impact. A member with a ground master id led a server's MLS group while the owner was away (committer, join answerer, repairer); commits stayed judged.

Description. Stand-in leadership went to the lowest master id by string sort, and door answers were ranked per device.

Fix. Leaders are ranked by standing (role tier, then admission position in the signed fold, then id); door answerers are one slot per identity in a nonce-salted order; the rule is gated per group for 0.12.2 compatibility.

Residual. Groups with a pre-0.13 leaf keep the old rule until 0.14, and AR-11 is widened to backdated admission by any former member.

Test. `g13w2f_a_ground_low_id_never_becomes_the_stand_in_committer` (red before), `g13w2f_a_ground_id_is_neither_catch_up_responder_nor_repairer`, `rank_masters_orders_by_tier_then_position_then_id`, `g13w2f_door_answerers_are_three_identities_whatever_their_device_ids`. Mutation passes 48/52, 17/19, 12/12.

HOL-SEC-177: One identity's roster could lift another identity's removal of a device

Severity: Low (Impact M, Exploitability L). **Class:** C. **Fixed in:** 0.13 (10dac6d6).

Impact. A device removed from one identity could count again after consenting into another, or a genuine device be refused, depending on which roster saved last.

Description. The resolver kept one revoked flag per device id and lifted it for any roster that counted the device.

Fix. Revocations are kept per (master, device), each master lifts only its own, and the old table is dual-written until 0.14.

Test. `g13c_a_lifting_by_one_master_leaves_anothers_removal`, `g13w3_a_removed_device_joining_another_identity_stays_refused_for_its_old_one`, `g13w3_revoked_devices_survive_the_move_to_per_master_marks`. Mutation passes 9/10 and 8/8.

HOL-SEC-178: A busy channel's ring replay starved the owner's direct frames, so a joiner was never seated

Severity: Medium (Impact M, Exploitability none needed). **Class:** A. **Fixed in:** 0.13 (892f0dcc).

Impact. A new member of a busy server never took its MLS seat or saw history.

Description. The relay's ring replay emptied the joiner's single per-sender receive bucket, so the owner's direct frames, the roster among them, were dropped.

Fix. Each sender has separate buckets for direct frames and for broadcasts, and an unplaced device is asked for its profile once.

Residual. Deferring the MLS ring pull until seated is a follow-up.

Test. `g13w3_a_joiner_past_a_full_ring_still_gets_its_welcome`, `g13w3_a_repair_asks_an_unplaced_member_device_for_its_profile` (both red before), `a_broadcast_flood_leaves_the_direct_bucket_whole_and_one_repair_waits_for_both`. Mutation passes 6/6 and 8/8.

HOL-SEC-179: A frame carried to our own sibling device could be lost in a room the sibling had left

Severity: Low (Impact M, Exploitability L). **Class:** A. **Fixed in:** 0.13 (5d5d9116).

Impact. A carried message to our own sibling (friend list sync, removal, server announce) could be lost silently.

Description. Frames to our own devices took the first room both devices shared, which could be a room the sibling had just left.

Fix. Our own devices are reached through our own room, else our inbox.

Residual. `send_tombstone_if_revoked` still uses the first-match lookup (redundant, follow-up).

Test. `our_own_device_is_reached_through_our_own_room_then_our_inbox`, `g13w3_a_carry_to_a_sibling_never_rides_a_room_it_left`. Mutation pass 7/7.

HOL-SEC-180: Two frames sealed in the same millisecond tied, so the second was taken as a replay

Severity: Low (Impact L, Exploitability M). **Class:** A. **Fixed in:** 0.13 (5d5d9116).

Impact. A genuine frame sealed in the same millisecond as the previous one, such as a second link card, was refused as a replay.

Description. Seal stamps came from the wall clock in milliseconds, so two frames could carry equal stamps.

Fix. Seal and carried stamps rise strictly per process, at most 500 ms ahead of the clock.

Test. `frames_sealed_within_one_millisecond_carry_increasing_stamps`, `carried_stamps_strictly_increase_within_a_millisecond`, `g13w3_our_newest_card_lands_on_our_row_over_a_card_stamped_ahead`. Mutation pass 7/7.

HOL-SEC-181: A removal stamped ahead of a later re-add ended the re-added friendship on some devices

Severity: Low (Impact M, Exploitability L). **Class:** A. **Fixed in:** 0.13 (c4e2f7f5).

Impact. A friendship re-added after a removal could end again, on some of our devices and not others.

Description. A re-add was stamped by the wall clock and compared with the removal's seal time, so a removal sealed ahead (clock skew or a late copy) won, and siblings re-shared its tombstone.

Fix. Requests and accepts are stamped from the seal sequence past any held removal, a `FriendRemove` names the friendship it ends, and siblings tell request and accept stamps apart.

Residual. A pre-0.13 bare `FriendRemove` keeps the seal rule; a capped re-add can still lose to a tombstone far ahead.

Test. `authz_a_removal_reaches_an_online_sibling_and_never_undoes_a_readd`, `a_late_copy_of_the_friends_removal_never_ends_our_readd`, `a_removal_names_the_friendship_it_ends_whatever_the_seal_clock`, `a_readd_outlives_the_tombstone_it_supersedes`. Mutation pass 21/21.

HOL-SEC-182: A device removed while it was connecting never learned its removal live

Severity: Low (Impact M, Exploitability L). **Class:** C. **Fixed in:** 0.13 (60438a4a).

Impact. A device removed while connecting, such as a stolen phone, showed no lock and did not start its erase until its next connect; contacts already refused it.

Description. The removal notice dropped because the device was in no room we saw yet, and the tombstone went to an inbox the relay was taking it out of.

Fix. Each time a device our roster removed arrives in a room we see, it is handed that roster there, once per arrival.

Test. `g13w3_a_device_removed_while_connecting_learns_it_when_it_appears`, `g13w3_a_removed_device_listed_in_a_room_refresh_learns_it`, `g13w3_the_arrival_notice_alone_skips_a_bare_master`. Mutation pass 5/5.

HOL-SEC-183: A few addresses could exhaust the relay box's memory with large broadcasts

Severity: High (Impact H, Exploitability H). **Class:** A. **Fixed in:** Relay, 2026-10-23 (986a4d75).

Impact. A few addresses could exhaust the relay box's memory, and the kill would lose every RAM buffer.

Description. uWebSockets keeps appending past `maxBackpressure` and keeps inbound frames whole, so non-reading sockets in a room with 64 MB broadcasts held gigabytes (estimated 8.4 GB from two IPv4 addresses on an 8 GB box).

Fix. A send budget (a quarter of RAM by default) bounds held bytes per socket and address share; the heaviest share's sockets close first, and a sender that cannot fit is closed with 1013 and resumes. The circuit breaker in the same commit runs in shadow mode only.

Residual. An attacker holding many address blocks still spreads its charge across them, and the breaker's enforce switch waits for 0.14.

Test. Relay `test_send_budget`, live `oom_honest_fanout_evicts_nonreaders` ("the relay's RSS stays bounded by the budget"), `oom_cotenant_gives_way_before_sender_trips`. Mutation passes 34/35, 18/18 and 2/2 live; 29/32 C++ mutants on the merged relay.

HOL-SEC-184: Peer discovery answered every device with full member lists every 30 seconds

Severity: Medium (Impact H, Exploitability L). **Class:** S. **Fixed in:** 0.13; relay 2026-10-23 (70f7f10e).

Impact. At 5,000 members one discovery round cost the relay about 30 s of CPU and 4.1 GB, every 30 s.

Description. Every device polled the full peer list of every server every 30 s, and the relay answered whole.

Fix. Rooms are audited every 300 s with a 64-bit presence digest, old clients get at most 64 ids, and servers admit at most 512 identities.

Test. `presence_audits_never_drift_under_churn_and_catch_one_lost_frame`, `tag_matches_the_relays_pinned_vector`, `g13_member_cap_refuses_past_the_cap`, `g13_member_cap_is_not_a_fold_rule`, relay `test_presence_view`. Mutation passes Rust 14/15, relay 9/9.

HOL-SEC-185: Opening a channel asked every member device for its history, and each page cost grew with the history

Severity: Low (Impact M, Exploitability L). **Class:** S. **Fixed in:** 0.13 (e87391e0).

Impact. A joiner pulled 2.3 to 3 copies of a channel's history, and a page of a 100,000-message channel cost a member about 0.86 s.

Description. A channel ask went to every member device, and the page query scanned and sorted the whole channel per page.

Fix. One entitled holder answers at a time with strict progress rules, and the page query seeks per sender on the index.

Residual. Verifying a page before it counts as progress is a follow-up.

Test. `g13w3_opening_a_channel_while_joining_takes_one_copy_of_its_history`, `pages_nobody_asked_for_never_keep_an_ask`, `per_sender_pages_serve_exactly_what_the_old_query_served`, `a_channel_page_costs_the_same_however_long_the_history`. Mutation passes 22/24 and 21/21.

HOL-SEC-186: The relay read client JSON only up to a raw NUL byte

Severity: Low (Impact L, Exploitability M). **Class:** C. **Fixed in:** Relay, 2026-10-23 (22116aa5).

Impact. The relay judged a different value than the client parses; no way to use it was found.

Description. nlohmann stops reading at a raw NUL after a complete value, so the relay ignored what followed.

Fix. `client_json::parse` refuses any text with a raw NUL.

Test. `test_client_json.cpp` and `test_auth_frame.cpp` NUL checks; fuzz seeds and crash inputs replayed by `run_tests.sh`.

6. Accepted risks and open items

6.1 Accepted risks

What Hollow knowingly does not defend against, with the reason and a review date, is kept in `audit/accepted_risks.md`. Its open rows as of the 0.13 release follow, then the entries closed since.

AR-01

Risk. The relay has no per-message rate limits, although ASVS 17.3.1 wants signalling to survive floods and RFC 9420 16.8 says KeyPackage requests SHOULD be rate-limited.

Decision. Revisited in 0.13 (2026-10-23, phase G2): still no per-message limit; a circuit breaker counts work in shadow mode and a send budget bounds the relay's held bytes. Was accepted (2026-09-26)

Reason. Message and binary rate limits were tried and broke the core: a reconnect burst (sync requests, channel probes, profiles, signalling) exceeds any limit, and dropped frames wedge CRDT sync. The protections that stay: per-IP connection caps (34 per address, 10 new per minute while the address holds a socket and 30 while it holds none, IPv6 /64), guest mode with its own limits and room cap, CAKE per-host fair share on the official relay's NIC (a setting on that box, not part of the repo's units or the setup wizard, so a self-hosted relay has it only if its operator adds it), coturn locked to the relay's own peers, the 64 MB payload ceiling and hard backpressure. G2 (0.13): every frame is charged in work units (frames, the writes they cause, signature checks, door proofs, audience size) against session buckets sized above a member of ten 1,536-device servers, and a frame the bucket cannot pay for closes the socket with code 1013 and a reconnect hint (`breaker.h`). A session's frame is never dropped: it stays uncounted and is resent on resume. A fetch or guest socket, which has no session, loses that frame and pauses 30 s. It ships in shadow mode: the relay counts what it would trip and closes nothing, `auth_ok` names the credit, and `enforced` is set only on an enforcing relay, so 0.13 clients pace themselves the same way (`relay_pace.rs`) without waiting on a shadow relay. The device ladder steps only when a session overspends the whole honest budget within 10 minutes (cap plus 10 minutes of refill, 1.4M units); any other trip is a pause. Separately, the relay's held bytes are bounded (`send_budget.h`): at most 64 MB per socket and a global budget of a quarter of RAM by default, never below 512 MiB or a third of a smaller box's RAM, which an operator may change but not push below that floor, charged per address share; under pressure the least progressed reader of the heaviest share is closed first. That is memory safety, not a volume quota. The breaker's numbers are compiled in; an operator cannot lower them.

Next review. 0.14: switch the breaker to enforce once its shadow counters show no honest trips, after plan-level tests for junk lock proofs and non-member leaves (relay mutations C6 and C9 survived).

AR-03

Risk. Inside a group call, any participant can forge media frames that appear to come from another participant (RFC 9605 7.2, shared SFrame keys).

Decision. Accepted (2026-09-26)

Reason. As far as we know, no mainstream E2EE call system (Signal, WhatsApp, Meet, Zoom) signs individual frames; all share symmetric frame keys among participants. The forger must be an admitted participant running a modified client. Per-frame signatures cost CPU on every phone. Outsiders cannot forge: the GCM tag stops them, and nonce uniqueness in shared-key mode was checked and found safe (lead L-01, phase E+F media review).

Next review. If a mainstream system ships per-frame sender authentication.

AR-04

Risk. Traffic analysis, relay availability, post-quantum, trust on first use, a compromised unlocked running device.

Decision. Accepted

Reason. Listed in WP 23.2 and claims.md "What we do not promise".

Next review. At each whitepaper revision.

AR-05
Risk. Any peer in a room we share can ask us for an asset by its hash (server emotes, stickers, GIFs, banners, avatar frames and animations, personal emotes), learn whether we hold it and receive its bytes (candidate H20).

Decision. Accepted (2026-09-27)

Reason. Assets are content-addressed: knowing a hash almost always means the asker has already seen the asset, since server emotes live in the server's state and profile media hashes ride the profile updates people already receive. Since 0.12 (design A) the requests and answers (`EmoteRequest`, `EmoteAssets`) ride inside Olm on the carried lane, so the relay sees neither.

Next review. If assets ever need access control beyond a shared room.

AR-06
Risk. Every `FileRequest` re-encrypts and re-streams the whole file, so a peer entitled to a file can make us upload it repeatedly (candidate H21).

Decision. Accepted (2026-09-27)

Reason. Honest clients ask only when they need the bytes (a download, a decrypt-fail retry). Only an entitled requester is served: our own devices, the DM counterpart, a member who can read the channel, or anyone for a file in a public channel. The per-sender frame budget (20 frames a second per device) limits how often one device asks, not the work each ask costs: every ask re-reads and re-encrypts the whole file. Since 0.14 the relay fallback no longer queues all its chunks at once, for files, vault shards and recovery-pool shards alike: a stream sends at the socket's pace from a fixed 4 MiB budget per device, and an ask for a file or shard whose relay stream to the same device still runs starts nothing. A device back on a fresh session ends its streams at once, and one that left every room we share (lost, or only hidden and still receiving) keeps its stream until it asks again, when the ask replaces it, so a retry is always served. A device runs at most 16 relay streams per asking identity and 64 in all, with at most 272 MiB staged on disk (one stream alone may hold more). When full, the asker holding the most gives way, public-channel guests before members; our own sends and devices stand outside these caps. A dedup window that outlasts the stream would break the retry. Re-checked with G2 (2026-10-23): the requester pays for its request frame and the serving device pays for the re-stream; bytes are not counted, and volume fairness on the official relay is left to CAKE on its NIC.

Next review. The post-0.13 file-traffic measurement (direct, TURN and relay fallback for a large file in a large server).

AR-08
Risk. Report counts per target on the relay can be inflated with throwaway accounts (one report per reporter, target and category until the relay box reboots, when dedup starts over and the counts stay) (candidate I12, report half).

Decision. Accepted (2026-09-27); the full-table half fixed in 0.14 (2026-10-31, track b14-bounds)

Reason. Nothing acts on the counts automatically; only the operator reads them. Any future automatic enforcement must not rest on raw counts. The full-table half is fixed in 0.14: the fingerprint table used to hold at most 500,000 reports and take no more once full, so a flood could stop later reports from counting until the box rebooted. Now each report is charged to the reporter's address share and the table is bounded by bytes (128 MiB). Once it is full, the share holding the most gives up its least recently used report and that report's count, so a flood from one address block pushes out only its own reports and every new report still counts. Every report weighs the same, so string length never decides which

goes. Counts carried from a file whose fingerprints the key cannot read stand outside the budget and never give way to a flood. Shares ride the restart snapshot, never the disk.

Next review. Before any automatic enforcement reads the counts.

AR-10
Risk. A joiner of a server founded before 0.12 trusts the member that answers (trust on first use) when its invite carries no owner pin, or while the owner has not run 0.12 to sign the checkpoint (design E residual R1). Until that checkpoint, such a server's ops also apply in arrival order over a log capped at 1000, so a member or an Olm peer can hand on a genuine old op from outside that window, or hold one back, and change the order its replicas saw (phase B re-check row 0.5; added 2026-10-02, decision D2). A joiner pinned to such a server's owner takes the answering member's members, channels and settings (never its roles, bans or mutes, HOL-SEC-093) until a member serves the owner's checkpoint, so a hostile member that answers first can withhold the checkpoint for as long as no honest member answers (re-check crdt A-06).

Decision. Accepted (2026-09-27, extended 2026-10-02)

Reason. Those servers have no founding op anyone can prove: their history predates op signing and was capped at 1000. Every 0.12 server has a self-certifying id, every 0.12 invite to an older server pins its owner, and the owner's first 0.12 start signs the checkpoint. What stays is an old link, or an owner who never updates.

Next review. When 0.11 invite links have aged out.

AR-11
Risk. A demoted or removed admin, or any ex-member, can still backdate ops to before its demotion or removal, and every member admits them at that time (design E residual R2). Since 0.13 such a backdated role grant also buys MLS precedence while the owner is away (`node/standing.rs` ranks by role tier first). A backdated admission buys no position: an admittee never ranks before its admitter's current span, and one whose admitters all left ranks last within its role tier.

Decision. Accepted (2026-09-27)

Reason. Without a total order handed out by an authority, no decentralized design tells a backdated op from one authored offline before the demotion (Matrix state resolution has the same gap). Such ops lose every register a later honest write touched, and the admin could do the same things while it held the role.

Next review. Reviewed 2026-10-01 with ID-1: device co-signatures order device statements, never server ops, so this stays. Re-checked with the 0.13 standing rule (g13 wave 3, 2026-10-23): impact widened to stand-in MLS leadership, confidentiality unchanged (commits and Welcomes stay judged). Next: if ops ever gain a verifiable author time.

AR-12
Risk. An op older than a checkpoint's `covers` (the newest clock the owner's state reflects) that the owner had not seen is dropped by every member (design E residual R3).

Decision. Accepted (2026-09-27)

Reason. Deterministic and rare: it takes an op dated before the owner's own newest one that never reached the owner, and the owner checkpoints once per existing server and then only when a log passes 2000 ops, at most hourly. Everything after `covers` survives, so an owner back from days away overwrites nothing that happened meanwhile. The author sees the change undone and can make it again.

Next review. If a lost change is ever reported.

AR-13

Risk. A file sent before 0.12 has a random 32-character id that commits to nothing, so a holder answering a re-pull, or a member holding a channel file's key, can still hand over other bytes for it (HOL-SEC-060 residual).

Decision. Accepted (2026-09-28)

Reason. Only history is exposed: a 0.11 client cannot deliver anything to 0.12 at all, since 0.12 refuses unsealed frames. Its author signed only the id, and no one but the author can add a commitment afterwards. Every 0.12 file is committed, the length tells the two kinds apart so a new file cannot be passed off as old, and an old-style id a member mints on 0.12 only ever carries that member's own content. The old delivery gates (owner or asked holder, readable channel, bytes never replaced once on disk) still hold.

Next review. When pre-0.12 history has aged out of retention.

AR-14

Risk. The app pins the first media forwarder each relay names and refuses another until the relay has not reported the pinned one online for 7 days, so on the very first contact a relay that is already hostile can name a forwarder of its choosing (A-D4 residual).

Decision. Accepted (2026-09-29)

Reason. The forwarder only ever carries SFrame ciphertext; what it learns is viewers' addresses and who watches whose share. Whoever runs the relay already runs its forwarder and sees every address, so a relay hostile from the start gains nothing by naming another one, and the pin slows a relay that turns hostile later: it must stop reporting the pinned forwarder for 7 days before the app takes another, and the app uses no forwarder from it meanwhile. A forwarder id built into the app would make every forwarder change an app update.

Next review. If forwarders are ever run by someone other than the relay operator.

AR-15

Risk. Design ID-1's residuals: a legacy identity (from before 0.12, none of whose devices kept the phrase 0.11 stored, phrase not yet signing a recovery there) still lets the master key admit a device; someone meeting the identity for the first time after a master-key holder published a forged recovery key pins the forged one; whoever learns the phrase is the identity (the newest recovery wins). ID-1R (2026-10-02, HOL-SEC-078) closed the inbox half and left: after the relay box reboots, or after the relay drops an identity's roster record under its fair-share byte budget, the first roster shown for that identity sets its recovery key at that relay, so a master-key holder who shows a forged one first holds that inbox there until that record is lost again; a member that floods its own base pushes out devices deeper than itself until the phrase is typed (HOL-SEC-079); a thief's own vouchees made before its removal stay until removed too (HOL-SEC-080). Meetings (session 33 follow-up, checked in code 2026-10-04): a meeting host who holds no roster for a participant judges that participant's devices by the master-signed certificate alone (`mls_authority::refused` refuses only where a held roster leaves the device out), so a device the participant removed stays seated in a running meeting, can knock on a new one and be admitted, and a master-key holder can mint a device and appear as the identity in any such meeting whose link and `key=` it has.

Decision. Accepted (2026-10-01, ID-1R part 2026-10-02, meetings 2026-10-04)

Reason. The legacy window closes at the first 0.12 start of any device that kept the phrase 0.11 stored: before it connects, that device signs the identity's first recovery with it (one fixed statement every device of the identity signs alike, so devices that upgrade at different times meet in one base), and its contacts, its other devices and the relay pin the real key when they next hear from it (session 35, decision C). The window stays open only for an identity none of whose devices kept that copy, or whose only such

device is missing from its own 0.11 device list, until the phrase signs a recovery there (the phrase check alone signs nothing). A restored backup that nobody refused becomes a member at every contact after seven quiet days on that contact's own clock, even while every owner device is away (phase E+F C-IDENTITY-14); `no_wait` turns that path off. A forged key only fools contacts who never met the identity before; everyone who did keeps the real one and the owner's devices see the conflict. Meetings are the same first-contact case: a host who never met the identity has nothing to tell its devices apart by, every knock is admitted by hand unless the host turned the waiting room off (it is on by default), the link and its key are needed, and participants who hold the roster (friends, co-members) refuse that device's chat and voice inside the meeting (HOL-SEC-123). The fix, if meeting impersonation ever matters: the host asks the relay for the participant's current roster fold (ID-1R) before admitting, at the cost of a new relay query and showing a stranger the participant's device list. A phrase is a bearer secret by design, the same as every recovery phrase. Nothing in an identity's id commits to its recovery key, so a relay that lost its memory cannot tell a forged key from the real one; reboots are rare and planned, a service restart keeps the registry, and pushing a record out under the budget takes many address blocks (the phase G class, as AR-16). A member's flood can only do what it could do by removing devices, and a new base gives it no standing.

Next review. When 0.11 identities have aged out, and if identity ids ever change.

AR-16

Risk. Design D1's residuals (HOL-SEC-091): whoever joins through an open invite is a member and sees the room; someone who already knows a device id can address it in a server's room and learn from a reply that it is there (in a server with a public channel, where members answer strangers); a removed member keeps seeing the room for up to the 60 s grace after the lock moves; a lock record evicted under the fair-share budget leaves its room open until a member puts the chain back; legacy (32-hex) servers and meetings stay open as before.

Decision. Accepted (2026-10-02)

Reason. Scope Vitalii agreed for D1: it stops scrapers that hold only a server id. The grace is what lets the op carrying the new door reach the members at all. A known device id is already a link across rooms. Eviction needs an attacker holding many address blocks (phase G). Legacy servers have no lock the relay can key by room, as in AR-10.

Next review. Phase G (G2, 0.13) kept it as it is; next when 0.11 servers have aged out.

AR-17

Risk. A guest previewing a server (its public channels, before joining) is shown the server's name, avatar, banner thumbnail and list of public channels by whichever peer in the room answers (normally a member), and nothing ties them to the owner (D6, re-check A-CH14 and A-CH16).

Decision. Accepted (2026-10-02)

Reason. The preview is a first look before a join, and the join itself is anchored (the server id or the owner pin). A member can already show a stranger anything it likes outside the app. A closed channel never reaches the list from an honest member (HOL-SEC-094), and every post and author name a guest sees is signed (HOL-SEC-095).

Next review. If server previews ever carry the owner's signature.

AR-18

Risk. Design D5's residuals (HOL-SEC-096): a destroy order from an identity that has no recovery yet (none of its devices kept the 0.11 phrase and the phrase never signed a recovery on 0.12) has no key the relay can check, so it stays an opaque deposit under the HOL-SEC-029 eviction rules; proven slots are bounded list-wide by address share, so an attacker minting free identities from many address blocks

can still evict one; the relay now reads a parked order and learns that an identity ordered some of its devices wiped.

Decision. Accepted (2026-10-03)

Reason. The legacy window is AR-15's. It closes at the first 0.12 start of a device that kept the 0.11 phrase, and otherwise only once the phrase signs a recovery in Settings; the phrase check the app offers signs nothing. Eviction takes many address blocks (a block counts as a fresh share each hour), and the genuine order sits alone in its own share, so it goes only once no other share holds more than it does (the phase G class, as AR-16). The relay already knows every device of each identity whose roster it holds and which device ids a deposit targets; reading the order adds only that it is genuine.

Next review. Phase G (G2, 0.13) kept it as it is; next when 0.11 identities have aged out.

AR-19

Risk. Decision D7's accepted residuals (phase B re-check). The Olm part (transport A-T18) is closed in session 33: each sending device's frames are read through a saved mark, the newest seal time we decrypted from it, written after its session by the node and the push fetch, and a decrypt failure on a frame sealed at or before that mark is dropped with no retire and no KeyRequest. What remains of it: a sender whose clock steps back (since 0.12.1 relay auth no longer bounds clocks; the app warns a device whose clock is more than a minute off the relay's) waits for a real re-key until its seals pass the mark, and a frame sealed before one we read that we never read ourselves (a gap past the 40 kept message keys, or a crossed session's frame in flight) is dropped without the re-key's DM resync and returns with the next catch-up. The rest: slow mode judges a post dated older than its window by the post's own signed time, so a member can backdate a burst past slow mode (channel A-CH01, decision 2b); a removed device's own removals still count until the phrase settles it, so a thief and the owner can remove each other and the owner must type the phrase within the 3-day grace (identity A-02); a reboot of the relay box (not a service restart), or the loss of an identity's roster record under the relay's fair-share budget, makes that relay forget the identity's removals, so a removed device can own its inbox there again until another device of the identity connects and shows its roster (the 0.11 device-list marks of HOL-SEC-031 and their switch were deleted in 0.13); the path closes for good when `ACCEPT_DEVICE_LIST_INBOX_PROOF` is switched off after 0.12 (relay A-02c).

Decision. Accepted (2026-10-02)

Reason. The Olm remainder needs an honest sender's clock to step back, or a frame already lost to its gap; either way the DM catch-up brings the message back. Backdating moves only the poster's own posts, which still pass every membership and posting gate, and slow mode is courtesy, not authority. Mutual removal is the ID-1 design: the phrase is the last word, the 3-day grace exists for it, and the owner's devices show the removal at once. Reboots are rare and planned, every device shows its roster on each connect, and pushing a record out under the budget takes many address blocks (phase G).

Next review. If slow mode ever becomes a moderation guarantee, and when 0.11 identities have aged out.

AR-20

Risk. A vault manifest is unsigned and its content id names no author, so the first manifest a member receives for a content id wins: a server member who lands one before the creator's sets that receiver's shard hashes, and the receiver then refuses (and deletes) genuine copies of that one content (HOL-SEC-117 residual, re-check files A-V10).

Decision. Accepted (2026-10-03)

Reason. Availability of one vault file at one receiver, from a member of that server; the bytes it serves are still checked against the content id, so nothing false is ever shown. The real fix binds the vault

content id into the file's own signed commitment, a protocol change (send path, a new card field, FFI and three Dart call sites); phase F WP7 left it as it is.

Next review. If vault content ids ever join the file's signed commitment.

AR-21
Risk. The update manifest carries no expiry and the app keeps no newest-seen floor, so whoever controls the update host can keep serving an old, validly signed manifest and hide a newer release (a TUF freeze), and a failed background update check stays quiet; the desktop updater trusts the signed manifest's SHA-256 alone and never checks the OS code signature of what it downloaded (phase E+F distribution C-DIST-04, C-DIST-05).

Decision. Accepted (2026-10-04)

Reason. We run the update host ourselves, over HTTPS. The Ed25519 key that signs the manifest never reaches the update host or the repo; it lives only on the release workstation and one backup machine, so a compromised host can only withhold an update, never install anything, and a downgrade is refused. A held-back release still shows on GitHub, the website and the news feed. A real expiry needs a regular re-signing with the offline key. Someone who installs a modified fork trusts whoever made it.

Next review. If the update host is ever run by someone else. The 0.13 close-out left it as it is (status and news feeds are signed with an issued stamp since 0.12.2; the manifest still has no expiry).

AR-22
Risk. Every Android release is signed with a debug-named certificate from a keystore generated on the release machine, under the Android default password, so possession of that one file is the whole signing key (phase E+F distribution C-DIST-03).

Decision. Accepted (2026-10-04)

Reason. The key was generated by the SDK on the release machine, is never in the repo, and has two backup copies, one on an offline disk and one on the second workstation; nobody can sign an update that installs over Hollow without the file. Changing the key breaks every upgrade unless done through APK signature scheme v3 key rotation.

Next review. Before a Play Store or F-Droid listing, or at the next key rotation.

AR-23
Risk. Ko-fi signs nothing, so the shop's webhook knows an order is genuine only by the artist's Ko-fi verification token inside the POST body (`shop/src/lib/server/kofi.js` `ingestKofiEvent`); whoever holds that artist's token can post orders with fresh message ids and receive codes for that artist's items, up to the per-order ceilings (phase E+F files C-FILES-05).

Decision. Accepted (2026-10-04)

Reason. The token lives in the artist's own Ko-fi settings, and the shop keeps only its HMAC, compared in constant time, per artist; a missing token refuses. A leaked token reaches only that artist's own listings, and a code still cannot carry a credential to anyone else: redemption blind-signs and every client checks it against the pinned root (C-32). Keeping the token private is the artist's part, the same as their Ko-fi password; an artist who thinks it leaked pastes a new one and mints a new webhook path from the artist settings, and the old ones stop at once. A daily mint cap was dropped on 2026-10-08: it would refuse an artist's genuine orders on exactly the day a piece sells well.

Next review. If Ko-fi ever signs its webhooks.

AR-24
Risk. The App Lock secret is protected by Argon2id alone, with no hardware-enforced attempt limit, so someone holding a copy of the data folder can guess a numeric PIN offline; since 0.12 a new PIN

has at least six digits (about a million guesses), and an older shorter PIN keeps working until its owner changes it (phase E+F local C-LOCAL-04, lead L-07, claim C-36).

Decision. Narrowed in 0.12.2 (2026-10-18, track B5): on a phone with secure hardware (an Android keystore in StrongBox or the trusted environment, an iPhone's Secure Enclave) the App Lock wrap needs a key that never leaves that hardware, so a copy of the data folder cannot test a single guess, the duress slot included. Guesses on the phone are paced by the app: four misses are free, then each try waits 30 seconds, rising to an hour, counted per profile and kept across restarts. A try is counted before the PIN is checked, so two prompts at once each pay for theirs. Waits run on the phone's boot clock, so setting the clock forward never ends one, and a restart of the phone starts the wait over. Residuals: there is still no hardware attempt counter, because neither Android nor iOS offers an app one for its own PIN, so someone running their own code on the unlocked phone can guess as fast as the hardware key answers, and can reset the count as well. In the default setup, where Hollow starts on its own, and whenever biometric unlock is on, the PIN itself is kept in the OS secure storage (the Android Keystore, the iOS keychain; Credential Manager or the keychain on a computer) so the app can read it at launch or after a fingerprint. Code running as the app can read it there too; a byte copy of the data folder still cannot. Desktops and phones without secure hardware keep the Argon2id wrap alone. A duress code set before 0.12.2 keeps its Argon2id-only wrap until it is set again, and Settings suggests that once. Was accepted (2026-10-04)

Reason. A passphrase is always allowed and also closes the on-phone residual, and asking for the PIN before Hollow starts (with biometric unlock off) keeps it out of the OS storage. Taking a copy of the data folder already needs the device or its backups (Android opts out of backups, iOS data is excluded since 0.12). Hollow never wipes after a number of misses: Vitalii decided (2026-10-18) that pacing is enough.

Next review. A hardware-held key for the desktop app lock (TPM, Keychain), later.

AR-25

Risk. Server MLS groups have no post-compromise recovery for a member that never commits: no leaf updates itself and add-only commits carry no path, so a one-time copy of a member's MLS state keeps reading that server's traffic until that member's leaf is replaced (a repair, a rejoin or a removal commit it makes) (phase E+F mls C-MLS-07; RFC 9420 section 16.6, RFC 9750 sections 7 and 8.2.2).

Decision. Partly fixed in 0.13 (2026-10-22, wave g13 s3): members refresh their own leaves on turns the committer hands out; the rest accepted. Was accepted (2026-10-04)

Reason. Each leaf now refreshes itself with a path-only commit when the group's committer hands it a turn, and the committer broadcasts that commit itself, so one device per group commits and a refresh never races the authority's own commit (`node/mls_turns.rs`, wiki `security_write_gates` §48). A group takes at most 48 self-updates a day up to 512 leaves and fewer above that, since every member processes every commit; a leaf is due at most once a day, so a member is refreshed about daily in groups up to 48 leaves, about every 11 days at 512 leaves and about every 96 days at 1,536. A device that is backgrounded or offline takes no turn, and a device older than 0.13 cannot act on one, so a copy of such a member's state keeps reading until its leaf is replaced another way. That remainder stays accepted: taking the copy needs the member's unlocked database or malware on its device, which reads the same traffic live anyway. WHITEPAPER 5.4 says exactly this.

Next review. With the next scale wave (cadence for groups above 512 leaves), and when 0.12.x devices have aged out.

AR-27

Risk. Any member of a server can make its MLS group move to a new epoch whenever it likes (a commit that only updates its own leaf is accepted), so a hostile member can make every member re-key, and every voice call rotate its SFrame key, over and over (phase E+F mls C-MLS-01 variant b). In a meeting without a waiting room the same holds for a seated guest that knocks again: since 0.12 the

host replaces its leaf in a new commit each time (that is what lets a guest who left come back), and a link holder could already force an epoch per fresh device id.

Decision. Fixed in 0.13 (2026-10-22, wave g13 s3) for all-0.13 groups; mixed groups and meetings accepted. Was accepted until 0.12.x (2026-10-04)

Reason. Every receiver now judges each commit against an epoch-rate rule before any rule that depends on its own view (`mls_rate::rate_refusal`, wiki `security_write_gates` §48): each leaf carries a tally of its master's recent counted commits, a commit that counts against a master must carry exactly the tally the receiver derives, and a master gets at most 3 counted commits in 12 epochs. A KeyPackage cannot plant history for another master, repairs a committer makes for others are charged to their target (an honest committer also paces them to 3 per master per 10 minutes, then a doubling backoff), and a master its own history shows at the cap is never chosen to answer, repair or commit. Still open: the rule applies only where every other master's leaves carry a tally, so a master's commits are not judged while another master keeps a 0.12.x leaf in the group; the server's anchored owner and meetings are exempt (a meeting without a waiting room seats knocks in one commit per batch, at most 6 such commits a minute, and a seated guest that knocks again is re-seated at once the first time, then after a backoff doubling from 30 seconds to 10 minutes); a legacy rebind stays unjudged until 0.14; a carried list written while the rule was off can cap repairs of a master it names once the group reaches those epochs (never that master's fitness). It costs only work and a brief media hiccup; no one reads or forges anything, and the member is visible and can be kicked.

Next review. 0.14: the "0.13-only" MLS default (option B) makes every group judged; the legacy rebind goes.

AR-31
Risk. Blocking someone does not recall copies of messages we sent them that the relay had already parked; they are delivered when that person next connects (phase E+F olm, C-OLM-02 follow-up).

Decision. Accepted (2026-10-04)

Reason. They are messages we sent before the block, on purpose; the relay holds them for at most the retention the recipient's app asked for (3 days by default, 7 at most, 24 hours with its offline inbox off) and the blocked person reads nothing we send afterwards. Recalling them would need a new signed withdraw frame at the relay.

Next review. If a recall frame is ever added for another reason.

AR-33
Risk. Notifications outside the app's own lock. A phone's lock screen shows a message preview whenever Hollow is not under App Lock, as the OS settings allow; when a UnifiedPush distributor fails, the app falls back to Google's push without asking, so someone who chose UnifiedPush to keep Google out is back on FCM (AR-26's metadata); the desktop tray's mute, deafen and leave act on a running call while App Lock is up (phase E+F local C-LOCAL-18, C-LOCAL-22; relay_push C-RP-14).

Decision. Partly fixed in 0.12.1 (2026-10-08): the Firebase fallback is an opt-out setting and the chosen distributor is kept and retried; lock-screen previews and the tray stay accepted

Reason. The phone's lock-screen previews are the person's OS setting, and App Lock hides them (HOL-SEC-155). The tray acts only on a call already running and reveals no content. The Firebase fallback was the part worth fixing, and 0.12.1 made it an opt-out setting.

Next review. If an OS gives apps a per-app preview control, or if the tray ever acts on more than a running call.

AR-35

Risk. Protocol hygiene the pass recorded. Fixed in 0.13 (g13w3-ar35): the live-frame replay guard outlives a restart (`live_frame_nonces`, each row kept until its frame turns stale; 32,768 rows for our own, friends' and co-members' devices plus 32,768 shared by everyone else, at most 1,024 per known identity or per stranger device, a full pool evicting from its heaviest sender and never refusing; until the stored rows load, live frames stamped before the start are refused); a share manifest must add up (`ShareManifest::well_formed`: chunk count tied to size, at most 2^20 chunks); archives open in format 2 (the signature over a `hollow-archive1` domain tag) as well as format 1; releases carry SLSA L1 provenance (`scripts/release_provenance.py`, unsigned). Still open: a first sight the store's queue was too far behind to take (1,024 waiting notes for a stranger, 4,096 for a known sender) is guarded only in RAM, so that frame can be replayed once after a restart inside its 5-minute window; a live frame acted on just before the app is killed, before its note committed, can be replayed once after the restart (the note is fire-and-forget on this hot path); a stranger flood can cost other strangers their stored rows, and a flood of co-member identities (strangers who joined a server we are in) can cost friends and our own devices theirs; when the stored rows cannot be read, honest frames stamped before the start are refused for up to 5 minutes (a one-shot call invite shows as missed); the RAM guard bounds nonces per sender, not the number of senders (pruned every 30 s); the media forwarder's replay guard stays in RAM; exports stay format 1 until 0.14; the camera video of a 1:1 call and voice audio forwarded along a large voice channel's gossip tree have no SFrame layer, only DTLS-SRTP (WHITEPAPER 6.3); the MLS legacy rebind (an unbound committer may rebind as the device or master its old credential names) lives until 0.14 (phase E+F olm C-OLM-05, –07; media C-MEDIA-08; files C-FILES-06; mls I-5; distribution C-DIST-07).

Decision. Partly fixed in 0.13 (2026-10-23, wave g13w3); the rest accepted (2026-10-04)

Reason. None of these opens a read or a forgery: the replayed frames are ones the sender sent and heal, the archive hash is computed by the verifier itself, the unlayered media is still encrypted end to end between the participants and neither TURN nor the relay sees it in the clear, the manifest bound holds (a bitmap of at most 128 KiB), and the release keys never reach the update host or the repo. The forwarder may write nothing to disk on the relay box; every fwd signal is sealed, a stream's owner ops count only from its owner, and a viewer leg needs the owner's allowlist, and a restart drops every stream it held. The rebind exists only for leaves from before 0.12, and removing it in a mixed 0.12.2/0.13 group would fork it (a refused commit spends the commit key); a legacy leaf converges without it through `stale_leaves` removal and a bound re-add. Refusing pre-start frames while the rows are unreadable is the price of failing closed.

Next review. 0.14: flip `ARCHIVE_WRITE_FORMAT` to 2; SFrame on DM camera video and gossip audio, unconditional; remove the legacy rebind (the Unbound to Bound arm of `mls_authority::commit_verdict`, the legacy signer and credential in `MlsManager`, its callers, the AR-27 note). Follow-ups: a tier for own and friends' rows co-members cannot reach; the RAM guard's sender count bounded by the same eviction; a signature on the provenance file.

AR-36

Risk. Resumable sessions residuals (wave 2 reviews, `rs_handshake_review.md`, `rs_bounds_review.md`). A resume costs the relay about 80 ms of CPU for a session in 10,000 rooms (one fresh `members` per room), bounded only by the per-address connection rate; behind one shared address a newcomer that logs in takes the oldest grace slot there (at most 10 a minute), so a neighbour can end another person's session in grace; an attacker holding many address blocks gets many fair shares; an inbox's owner gets its whole mailbox again on every proved or owning re-join of `inbox:{M}` (`replay_mailbox_no_delete`, found in session 3, older than sessions), and a deposit has no size cap below the 64 MiB frame, so someone who fills their own mailbox from throwaway identities turns each tiny re-join into up to hundreds of MB of relay egress. A fifth residual, a fetch socket re-reading its own grace ring on

every join, is fixed (resumable sessions session 3): each fetch socket reads a room's grace DMs once (`PerSocketData::grace_reads`, at most 64 rooms, `hs_fetch_reads_grace_once`).

Decision. Partly fixed in 0.13 (2026-10-22, wave g13w2-b; G2 circuit breaker 2026-10-23, shadow mode); the resume `members` cost, the halved grace-slot takeover, the mailbox re-read per new socket and the G2 residuals stay accepted

Reason. Grace-slot takeovers: a grace session gives its slot to a newcomer only after half its grace, at most 3 a minute per address, decided before any state changes; otherwise the newcomer is refused with ip_limit and retries with backoff (a newcomer behind a full CGNAT address waits). A device's own fetch socket never ends its own session. Mailbox: each socket reads it once (a sequence mark raised only by the replay, never snapshotted); a new socket or a gapped resume reads it all, so that egress per reconnect stays, bounded by the per-address connection rate and the 512 MiB buffer budget. Many address blocks: stays accepted, since weighting by block evicts the honest users who share big carrier blocks first. Resume `members`: a resume still answers one fresh `members` per room it holds (about 80 ms of relay CPU at 10,000 rooms), bounded by the per-address connection rate. Kept after a design and its review: presence frames are uncounted, so the relay cannot know which of them reached a socket that died, and it cannot tell a client whose sockets keep dying from one that pretends to. A rule that answers only rooms that changed must still re-send every room it wrote presence to within the liveness window, its own resume answers included, or an honest client keeps a stale room view (a silent one-way loss in DM, inbox, roster and forwarder rooms that no presence audit heals); with that rule an attacker pays nothing more, so the worst case stays where it is. G2 (2026-10-23) charges presence work in the breaker's work units, but 0.13 runs the breaker in shadow mode: it counts the trips it would make and pauses, delays or closes nothing, so until the 0.14 enforce switch the bounds below are not in force and the connection caps and the send budget are what limit a socket. Its residuals, accepted 2026-10-23: one abusive IPv4 address that stays under every human reference can still spend about 34k units a second plus fresh-session churn (about 0.45 of a relay core). For IPv6 the unit is a /64, so a /48 holder has 65,536 of them; the fresh-start tier drops to 24k for a flooding /48, but the connection flood itself (TLS, auth) is outside G2. A resume costs a flat 4 units per room (it undercounts a resume of many big rooms, bounded by the connection rate), and, once enforced, a resume of a session in debt waits until it is back at zero. Stranger counts: all payers' trackers share 32 MiB (about 63,000 payers with a few targets, or about 3,000 sketching ones); a full book forgets the heaviest share's least recently used tracker, which then counts afresh (each deposit still pays 3 units). Junk door proofs: a lock move still runs a DH for every stored proof that opened nothing, paid by the relay, not the mover; at most 64 per room plus 8 per address group beyond that, each held by a live socket or session (one IPv4 address adds at most 8, a /56 holder about 2,100 per room, about 50 ms of relay CPU per lock move), and lock moves come only from moderators. Under a crowd of more than 64 such proofs, a ninth member behind one address who proves a door the relay does not hold yet loses its automatic prove on the relock and recovers by DoorAsk or a rejoin. The client's priority lane orders by listed devices, so a hidden or held device can see a direct frame overtake an earlier room broadcast (separate MLS and Olm sessions, no ordering dependency). A churning visible peer costs each co-member's node at most 7 frames per churn (about 21 units of the co-member's own budget, paced, never tripped); churn is bounded per /64 by the connection rate (10 a minute while the address holds another socket, 30 while it holds none), so a /56 holder visible in an unlocked room can cost each co-member up to about 7,680 churns a minute, near 2,700 units a second. Door rooms show strangers no presence, so only unlocked rooms and members' own churn reach that.

Next review. 0.14: the breaker's enforce switch once shadow counters show no honest trips, and limits on a hidden sender's broadcasts (at most 3 provers by rank, `0x07` only to `~join`).

Closed entries

These risks were accepted at first and fixed since. They stay in the register for the record, and their IDs are never reused.

- **AR-02.** Every device holds the master key, so a stolen usable device can revoke its owner's real devices (they wipe themselves), issue destroy orders, and keep the identity. Closed (2026-10-01, HOL-SEC-077).
- **AR-07.** Once the relay's offline buffer holds its global ceiling of 65,536 recipient keys, a sender holding a single key evicts the oldest deposit of anyone, so many throwaway accounts can push real parked messages out (candidate I9). Closed (2026-09-29, HOL-SEC-070).
- **AR-09.** A signed `KeyRequest` stays valid for the 300 s skew window, so the relay can replay a captured one (resetting a session after the 5 s cooldown), and any new identity can make us mint one-time keys, which can push a friend request's carried key bundle back to the live key exchange (candidate L6). Closed (replay half 2026-09-27, HOL-SEC-054; minting half 2026-10-03, HOL-SEC-111).
- **AR-26.** Push wakes sent through Google (FCM) and Apple (APNs) carry the sender's device id, and for channel wakes the server id, channel id and mention flag, in the clear, so Google and Apple can see who messages a phone and which servers it belongs to; UnifiedPush already encrypts the same block (phase E+F relay_push C-RP-05). Closed (2026-10-18, 0.12.2).
- **AR-28.** Images from peers still reach Flutter's image decoder (Skia and its libwebp) without a pure-Rust check first in two places: asset-rail blobs (emotes, stickers, avatar frames, banners), which are content-addressed and so cannot be re-encoded without changing their id, and image attachments that auto-download; an attacker who holds a decoder bug and can send us an image could reach it without a tap (phase E+F files C-FILES-04; thumbnails ARE re-encoded in Rust since 0.12). Closed in 0.13 (2026-10-22).
- **AR-29.** A device removal reaches a contact only when that contact hears it: contacts who were offline at the time learn it on a later roster exchange, nothing makes a held roster expire, and nothing notices two contacts holding different rosters for one identity, so a relay that withholds the removal from a contact keeps the removed device receiving that contact's DMs (phase E+F identity C-IDENTITY-05, lead L-05; WhatsApp answers this with a 35-day device list expiry). Closed (2026-10-17, 0.12.2).
- **AR-30.** An Olm session is saved after the message it encrypted has left, without waiting for the save, so a kill in that window restarts on an older copy of the sending chain and the next message reuses a message key; whoever holds both ciphertexts learns where their plaintexts agree (phase E+F olm C-OLM-09). Fixed in 0.12.1 (2026-10-08).
- **AR-32.** The relay host's own surface. Closed in 0.13 (2026-10-22).
- **AR-34.** Identity residuals of the phase E+F pass. Fixed in 0.12.1 (2026-10-08).

6.2 Open items

These are known and not fixed in 0.13. None is a finding. Each is a hardening step, a residual already stated in a finding, or a compatibility path that 0.14 removes.

- **Circuit breaker enforcement.** The relay's circuit breaker runs in shadow mode. Its enforce switch waits for 0.14, after the shadow counters show no honest trips, and after two plan-level tests (junk door proofs on a lock upload, a non-member's leave) that the C++ mutation pass found missing. Guest opcode and rate refusals should run before the send budget is charged.
- **0.13 compatibility paths that 0.14 deletes.** The CRDT state vector for 0.12.2 peers (HOL-SEC-175), the old discovery answer (HOL-SEC-184), the ring-control switch for 0.12.1 clients, the old stand-in rule in mixed groups (HOL-SEC-176), the legacy MLS leaf rebind, and the dual-written `revoked_devices` table (HOL-SEC-177).
- **Planned for 0.14.** SFrame on 1:1 camera and gossip audio (AR-35), archives written in format v2, limits on broadcasts from senders a locked room hides, and a signed status notice for versions that stop working.
- **Friend removals.** A stranger's `FriendRemove` with no friend row still makes a tombstone, so junk can crowd the 256 shared removals; tombstone only identities we hold a row or request for. The residuals of HOL-SEC-181 stand.

- **Smaller protocol follow-ups.** A join request is judged against `left_at` with no clock slack; `send_tombstone_if_revoked` still uses a first-match room (HOL-SEC-179); the live-frame replay guard's pools should keep friends' and own devices' rows out of reach of a co-member flood, and its RAM guard should bound the number of senders; channel history pages should be verified before they count as progress (HOL-SEC-185); the MLS ring pull should wait until a joiner is seated (HOL-SEC-178); big servers need a priority lane for posts under the breaker.
- **Platform.** The iOS notification filtering entitlement, requested from Apple on 2026-09-27, is still pending, so a wake can show a neutral banner the extension cannot withhold (HOL-SEC-035, HOL-SEC-156). Under Docker, a TURN port lock that fails at boot leaves coturn unlocked until `check-host.sh` flags it.
- **Assurance.** An external audit, a formal model of at least one protocol, cargo-fuzz targets for the Rust wire parsers, and property tests for the Dart link parsers.

7. Code-maturity scorecard

In the style of Trail of Bits' code-maturity evaluation. Ratings: Strong, Satisfactory, Moderate, Weak, Missing. They describe the codebase at the 0.13 tag, after the fixes, and they are the author's own judgement.

Category	Rating
Arithmetic	Moderate
Auditing and logging	Satisfactory
Authentication and access controls	Satisfactory
Complexity management	Weak
Configuration	Satisfactory
Cryptography and key management	Satisfactory
Data handling	Satisfactory
Decentralization	Moderate
Documentation	Satisfactory
Memory safety and low-level code	Moderate
Testing and verification	Satisfactory
Maintenance and supply chain	Satisfactory

Arithmetic: Moderate. Arithmetic on values a peer chooses has failed three times in this review: an HLC counter that wrapped (HOL-SEC-020), unchecked subtraction on sender-chosen stamps that panicked debug builds (HOL-SEC-145), and a negative size from a `2^63` declaration in the Dart stream intake (HOL-SEC-116). Each site now saturates or checks, and time comparisons go through a stamp ceiling (`frame_auth::stamp_ceiling`). Nothing enforces this across the code, since the clippy lints for arithmetic side effects and indexing are not on.

Auditing and logging: Satisfactory. One logging macro (`hollow_log!`) and a rule that log lines carry no names, codes, keys or message content (claim C-37, HOL-SEC-160), with key lines dropped from libwebrtc's logs (HOL-SEC-142). The relay writes nothing about clients to disk (HOL-SEC-075) and a wipe leaves no log trace (HOL-SEC-156). Refusals are logged where a test can see them. There is no tamper-evident audit trail, and diagnosing an incident depends on a user exporting a redacted log.

Authentication and access controls: Satisfactory. Authority now rests on signatures bound to their subject and checked at one gate per class: the frame seal (`node/frame_auth.rs`), the lane rule, `change_may_touch_row` for every remote change to a message row, `op_allowed` in the CRDT fold, the roster for devices, `mls_authority` for leaves and commits, the join lock and door proofs at the relay. The wiki `security_write_gates.md` records 52 sections of gates, and source-scan tests fail when a receive path stops calling its gate. The rating is not Strong because most findings of this review were in this category, the gates were added after the code they protect, and the matrix rows are agent-verified.

Complexity management: Weak. The node's event-loop dispatcher (`node/swarm.rs`) is about 15,000 lines, the relay's handler (`ws_handler.cpp`) about 4,600, and the rules interact across designs (roster, fold, join lock, door rooms, standing). Several 0.13 findings came from such interactions. A seal clock change exposed a friend re-add race (HOL-SEC-181), a faster store exposed a routing bug (HOL-SEC-179), and a ring replay starved direct frames (HOL-SEC-178). Rules are kept in one function where possible and documented, but the whole is hard for one person to hold.

Configuration: Satisfactory. The relay box runs each service under its own account in a systemd sandbox, keeps secrets in root-only files and nothing about clients on disk, and `check-host.sh` fails on the old shape (HOL-SEC-073 to 075). The four 0.11 compatibility switches are deleted. Self-hosters get one `.env`, a TURN port lock and an opt-out for public statistics. Gaps: the Docker path's port lock can fail open at boot, and the official relay remains a single box.

Cryptography and key management: Satisfactory. Primitives come from audited libraries (vodozemac, OpenMLS, RustCrypto). Every signature carries its own domain tag (dozens of distinct `hollow-*` tags) and its subject, signed fields are shape-checked by signer and verifier (HOL-SEC-143), and Rust and C++ share known-answer vectors. The recovery phrase is never stored. Gaps: no formal model of the protocols; an App Lock PIN has no hardware-enforced attempt limit (AR-24); the Android release key sits on one machine (AR-22); server MLS groups rely on self-update turns for post-compromise recovery (AR-25).

Data handling: Satisfactory. Remote file names go through `safe_file_name`, zip entries through `enclosed_name` with an allowlist and size budget, client JSON at the relay through one depth-limited parser, message bodies are refused whole past 64 KiB, peer images are checked in pure Rust before a native decoder, and ids are shape-checked at every entry. The review still found two remote panics in Rust (HOL-SEC-007, HOL-SEC-173), a canonicalisation bug in the signing payload (HOL-SEC-143) and a parser differential at the relay (HOL-SEC-186).

Decentralization: Moderate. Members hold their servers' state and history, a server's authority is provable from signed ops, and the relay can neither read nor forge what it carries (design A). Availability still rests on one relay per user, the official relay is one machine, phone wakes go through Google and Apple, and update signing rests on one offline key held by one person.

Documentation: Satisfactory. A protocol whitepaper, the claims, threat model, authorisation matrix, accepted-risk register, design documents for every redesign, one file per finding, and the write-gate wiki. Gaps: some of the working memory behind decisions lives outside the repository, and the whitepaper trails the code in places (its check is appendix B).

Memory safety and low-level code: Moderate. The core is Rust; outside test code it has under a hundred `unsafe` blocks, mostly in FFI, OS keystore and file-locking code. The relay is C++, sanitized in CI, and fuzzed nightly; sanitizer runs caught two use-after-free bugs before deploy. Twice a single client could end the process of a released relay (HOL-SEC-028, HOL-SEC-128), and review caught a third way in unreleased code (section 3.7). Native media and decoding code (patched libwebrtc, ffmpeg, Skia) is large and reached by peer bytes; it is gated, and reviewed only where Hollow configures it (section 2).

Testing and verification: Satisfactory. 2,758 Rust tests in the full run, 704 of them multi-node harness tests with a hostile mock relay, 2,767 Flutter tests, relay suites plain and sanitized, a test that failed before every fix, mutation passes on every security rule, and fleet runs of the real apps on desktop and phones. Not Strong because there is no formal model, the Rust wire parsers are not fuzzed, the mutation scripts cannot be re-run against today's tree, a few tests are load-sensitive, and the harness does not reach the relay C++ or the media plane.

Maintenance and supply chain: Satisfactory. CI runs cargo-deny (advisories, bans, licences, sources), osv-scanner, gitleaks over the whole history and zizmor on the workflows; actions are pinned to commit hashes; Dependabot proposes updates after a seven-day cooldown. Update manifests and status feeds are signed with a key kept outside the repository. Gaps: nine advisories are ignored in `deny.toml` (each with a written reason), the forked `flutter_webrtc` and patched libwebrtc are maintained by one person, and build provenance is new in 0.13.

8. Appendices

Appendix A: Coverage

This document lists what each work package of the audit examined, what it found, what it examined and found sound, and what it did not examine. It is the `coverage.md` the audit plan requires before the audit can close (`reports/planned/security/SECURITY_AUDIT_PLAN.md` section 3 artifact table and section 6 exit criteria), in the style of a Cure53 work-package note, including "areas examined that yielded no findings". It is an appendix of the final report `SECURITY_AUDIT_2026_10.md`.

Scope and how to read this

- **Scope commit.** `41080e0d` on `main` ("Add a setup wizard for self-hosted relays"). Earlier phases ran on the branches that became the 0.12.0 release (2026-10-05), 0.12.1 (2026-10-16) and 0.12.2 (2026-10-20); the 0.13 wave ran on `security/0.13` from `faf97c4b` (Release 0.12.2+1).
- **Period.** 2026-09-26 (plan and phase A) to 2026-10-24 (merged-tree suites and fleets of the 0.13 wave).
- **Who.** An internal review: the project owner set every policy, and AI agents enumerated code, wrote tests and acted as hostile reviewers (plan section 3, "the policy is decided by us, the evidence is gathered with help"). No independent human team took part. The final report is labelled an internal security review, never a third-party audit.
- **Each section** gives what was examined, how, what it found (HOL-SEC ids, briefly), what it examined that yielded no finding, and what it did not examine. Every statement cites its source. "No record" means the sources read hold nothing on that point.
- **Finding files.** `audit/findings/` holds 168 files: HOL-SEC-001 to 165 and 170 to 172. Numbers 166 to 169 were never used. Severities in the file headers: 8 Critical, 30 High, 71 Medium, 57 Low, 2 Info (HOL-SEC-002 reads "High, possibly Critical" and is counted High). Findings from the 0.13 wave are described by what they are, since the final report numbers them.

Source keys used below. Paths are relative to the repository root unless noted.

Key	Source
PLAN	`reports/planned/security/SECURITY_AUDIT_PLAN.md`
CLAIMS, TM, AR	`audit/claims.md`, `audit/threat_model.md`, `audit/accepted_risks.md` (all under `reports/planned/security/`)
MATRIX, CAND	`audit/authz_matrix.md`, `audit/candidate_findings.md`
EV, RC	`audit/phase_b_evidence/authz_<area>.md`, `audit/phase_b_recheck/recheck_<area>.md`
EF/x, DISP	`audit/phase_ef/<slice>.md`, `audit/phase_ef/dispositions.md`
MUT	`audit/mutation_passes/README.md` and the scripts beside it
RS-H, RS-B	`audit/rs_handshake_review.md`, `audit/rs_bounds_review.md`
SCALE	`reports/planned/relay-and-sync/SCALE_PROBE_2026_10.md` section 8

Method in one table

Activity	What it produced	Source
Research and method	Digest of eight published messenger audits, STRIDE, LINDDUN GO, ASVS/MASVS, RFC 9420/9750/9605, Olm and Sesame; the method, the work packages, secure-coding rules v0	PLAN sections 0-5

Activity	What it produced	Source
Phase A	37 claims (C-01 to C-37, C-23 withdrawn), 12 attacker profiles (P-01 to P-12), 11 assets, 10 trust boundaries, flows F-01 to F-96, attack trees AT-1 to AT-6, the accepted-risk register	CLAIMS, TM sections 1-6, AR
Phase B evidence	Nine read-only enumeration passes, about 275 sections and 200 suspicions with `path:line` and verbatim quotes, grouped into candidate classes A to P	EV, CAND, MATRIX "How the rows were built"
Phase B re-check	Ten read-only passes at `d16deefe` (2026-10-02) re-checked every section against the code of the day; every FIXED held; leftovers became HOL-SEC-083 to 117	RC, MATRIX
Phase B rebuild	Six passes at `1bac467f` (2026-10-03) rewrote the matrix: 346 rows, 1,737 citations checked by script (quote on its line), 0 wrong; the lead re-read every OPEN row and ten sampled FIXED rows	MATRIX
Designs	D (MLS leaves), E (CRDT fold), A (sealed frames, lanes), ID-1 (roster, phrase root, SPAKE2 link), ID-1R (relay rosters), D1 (door-proof rooms), the join lock	`audit/design_*.md`, PLAN state of play
Phase H	Relay host hardening (accounts, sandboxes, secrets, logs)	PLAN state of play session 19, HOL-SEC-073 to 075
Phases E and F, merged	Eight read-only slices at `aa104d48` (2026-10-04): STRIDE per element, the 13 bug classes of PLAN 2.2, protocol checklists, LINDDUN GO on relay and push; 443 STRIDE cells, every candidate dispositioned	EF/*, DISP
Hostile reviews	Resumable sessions (handshake, bounds) and every 0.13 track (design review, code review, narrow re-review)	RS-H, RS-B
Tests	Every fix with a test that failed first; 210 distinct `authz_*` and 10 `c24_*` (wiretap) test functions in `rust/hollow_core/src` at the scope commit (grep count)	finding files, MATRIX "Guard tests"
Mutation passes	One mutation at a time, named tests expected to fail, file restored by hash	MUT, finding files, per track
Fleet and phones	Throwaway-identity journeys on Windows, macOS, Linux, iOS Simulators, Android emulators	`reports/shipped/security/REGRESSION_PASS_0.12.md`
Relay suites	`relay-uws/test/run_tests.sh` plain and with `SANITIZE=1` (ASan, UBSan) on the VPS before every deploy, and in CI job "Relay C++"	CLAUDE.md, `.github/workflows/ci.yml:350-372`
Fuzzing	Nine relay libFuzzer targets; one Rust cargo-fuzz target for the image check	commit `22116aa5`, `relay-uws/fuzz/`, `rust/hollow_core/fuzz/`
Scale probes	G1 rerun on the merged 0.13 tree	SCALE

Attacker profiles (TM section 1) are applied with one standing rule: every peer attacker runs a client of its own making, holds valid keys and signs correctly, so the question is always whether the signer is allowed.

WP1. Identity, devices, linking, revocation, destroy, duress

Examined. The Rust identity core (`identity/roster.rs`, `recovery.rs`, `duress.rs`, `keys.rs`, `device_key.rs`, `platform_keystore.rs`, `node/roster_book.rs`, `node/destroy.rs`, `node/link_handler.rs`, `node/link_pake.rs`, `node/resolver.rs`, `node/security_alerts.rs`, `api/roster.rs`, `api/wipe.rs`, `api/identity.rs`, `api/storage.rs`); the Flutter identity UI (roster, roster lock, link dialog, duress and security sections, unlock and app lock shell, backup and destroy flows); the push fetch node for kill frames; stores E-10, E-11, E-13, E-14; flows F-01 to F-07, F-11 to F-13 and the `.hollow` restore; `spake2-0.4.0` and `zip-2.4.2` in the cargo registry; the relay's mirror of the roster fold (`relay-uws/src/roster.h`). Attackers P-01, P-03, P-04, P-07, P-08, P-09. Leads L-04, L-05, L-06, L-10, L-11. Attack trees AT-1 (every path to a wipe) and AT-2 (identity takeover). Sources: EF/identity, EF/identity_part2, EV/identity, RC/identity, MATRIX identity (35 rows) and new:10-14, 21-26.

How. Phase B matrix walk and re-check; designs ID-1 and ID-1R with their mutation passes (`tmp_id1_mutate.py`, `tmp_id1r_mutate.py`; ID-1R 13 of 14 rules killed, the last an equivalent mutant, PLAN session 25); 117 roster vectors shared by Rust and the relay's C++ mirror; phase E+F slice (71 STRIDE cells, protocol checklist RFC 9382, RFC 5869, BIP-39, RFC 8032); fleet journeys for linking, removal and destroy (PLAN sessions 22, 25, 26).

Found. HOL-SEC-001 (a foreign device list wiped devices), 002 (the relay could decrypt device-link snapshots), 005, 006, 029, 031 to 034, 059, 076, 077 (a stolen device held the identity for good), 078 to 083, 096, 112, 113, 115, 125, 129 (link snapshot, backup or archive wrote files anywhere), 130, 152, 153, 154, 157, 162. Residuals accepted as AR-15, AR-18, AR-19 (identity part), AR-34 (later fixed in 0.12.1). The 0.13 wave added three items (see "Phase G"): revocations kept per (master, device), a device removed while connecting now learns it, and removals carried inside DMs.

Examined, no finding. - Matrix rows with the binding present on every transport (`V`): `LinkDeclined` and `LinkSnapshotAck` (identity:A-23/A-24), every path that ends in a wipe (A-34), `ProfileRelay` (A-44), the signed profile card store (N-04), `LinkPake`, `LinkPakeReply`, `LinkSealed`, `RosterNotice`, the roster statements Consent, Recovery, PhraseAdmit, Vouch, Pending, LegacyClaim and Removal, and `roster_book::ingest` (new:10-14, 21-26). MATRIX. - L-06 (destroy replay) holds: a new install always runs a new device id, the first start stamps the link time, older orders are refused, and copies within a session are refused by the RAM stamp (EF/identity_part2 "Leads"; tests `destroy_refuses_signal_older_than_link_time`, `destroy_identity_signature_and_freshness_rules`). - L-10 holds for unsolicited prompts: "Add this device?" appears only after a hello opened under the SPAKE2 keys, one handshake per code (EF/identity_part2 "Leads"). - L-11 holds for phrase-protected identities: the master key alone admits nobody (`the_master_key_alone_admits_nobody_once_protected`, `authz_a_stolen_backup_is_never_a_member_until_approved`). - L-04: every Ed25519 check is `verify_strict` (EF/olm "L-04"). - AT-1: every path to the wipe routine, the removal lock and the duress wipe is enumerated with its gate; duress has no remote trigger (EF/identity summary, EF/identity_part2 "AT-1"). - C-LOCAL-08 (crash between wipe steps): no finding, the marker is the first fallible step (DISP).

Not examined. Nothing was built or run in the phase E+F slice; test names were checked to exist, not to pass at that tree (EF/identity header). No formal model of the roster (PLAN section 2.8 item 9 and decision 3 defer it; no record that one was built). The harness shares one process-wide resolver, so device-to-master attribution across processes is not covered there (CLAUDE.md "Multi-node harness").

WP2. DMs, Olm key exchange and sessions, friend requests and accepts, blocklist

Examined. `crypto/olm_manager.rs`, the KeyRequest, KeyBundle and Encrypted arms of `node/swarm.rs`, `node/crypto_handler.rs`, `node/olm_lane.rs`, `node/frame_auth.rs`, `node/dm_room.rs`, DM fan-out in `node/message_ops.rs`, `node/fetch.rs` and `push_enrich.rs`, the forwarder as an Olm responder, the Olm tables and RAM caches, vodozemac 0.9.0 and ed25519-dalek 2.2.0 in the registry. Flows F-20 to F-26, the frame seal on every relay frame and DM room membership. Attackers P-01, P-03, P-04, P-06. Leads L-02, L-04. Sources: EF/olm, EV/dm, RC/dm, MATRIX dm (30 rows) and new:1-3.

How. Phase B matrix walk and re-check; design A (sealed frames, lanes, DM room names from the masters' X25519 agreement) with `c24_*` wiretap tests on the mock relay; phase E+F slice (57 STRIDE cells, Olm, X3DH, Double Ratchet and Sesame checklists); mutation passes `tmp_s31_olm`, `tmp_s33_olm` (19/19) and `tmp_s31_friends` (MUT).

Found. HOL-SEC-003 (the relay could open an Olm session as any device), 008, 013, 036 (a stranger befriended us with an accept), 038, 039, 053 and 054 (relay-stamped sender, replays), 057, 062, 087, 089, 111, 143 (a sync responder made a signed message read as a shorter text), 144, 145, 161. AR-19 (Olm half, closed in session 33 with persisted read marks), AR-30 (fixed in 0.12.1), AR-31 accepted. The 0.13 wave fixed a friend re-add that lost to the removal it replaced, and persisted the live-frame replay guard (AR-35 item 1).

Examined, no finding. - Matrix `V` rows: one-time key publication (dm:A-DM-06), `SessionAck` (A-DM-08), `DirectMessage` (A-DM-13), DM `RemoveReaction` (A-DM-17), `StatusUpdate` (A-DM-22), `AutoDownloadPref` (A-DM-26), `frame_auth::open`, the plaintext lane drop and `MessageEnvelope::Carried` (new:1-3). MATRIX. - L-02 (vodozemac non-contributory DH) holds: every non-ephemeral key input is signed and verified before session creation on every path (EF/olm "L-02"). - L-04 holds: every Ed25519 check is strict, and no signature bytes serve as an id, dedup key or replay key (EF/olm "L-04"). - The Olm half of AR-19 matches the code as described (EF/olm "AR-19").

Not examined. No formal model of the Olm and device-list layer (PLAN 2.8 item 9). The Olm library itself was read for L-02 only; its audit is upstream (Least Authority, 2022, PLAN 2.9).

WP3. Servers, CRDT authority, roles, MLS groups and subgroups, conferences, joins

Examined. CRDT ingest and the fold (`crdt/fold.rs`, `crdt/anchor.rs`, `admit_remote_op`, `op_allowed`), every `CrdtPayload` variant (60 crdt matrix rows), channel content (21 rows), server joins and MLS (26 rows); `crypto/mls_manager.rs`, `node/mls_authority.rs`, the MLS ingress arms of `node/swarm.rs`, the committer, `node/conference.rs`, the CryptoStore actor and OpenMLS's in-RAM state; openmls 0.9.0, tls_codec 0.5.0 and openmls_basic_credential 0.6.0 in the registry. Flows F-30 to F-37. Attackers P-01, P-03, P-05, P-06, P-07. Leads L-03, L-08. Sources: EV/crdt, EV/channel, EV/server_mls, RC (same areas), MATRIX, EF/mls, `audit/design_D_mls_authority.md`, `audit/design_E_crdt_authority.md`, `audit/design_D1_door_rooms.md`.

How. Phase B matrix walk, re-check and rebuild; designs D, E, D1 and the join lock, each with harness tests that failed first; phase E+F MLS slice (63 STRIDE cells, every RFC 9420 and RFC 9750 obligation on the application); mutation passes `tmp_s32_crdt`, `tmp_s32_kick`, `tmp_s31_kick`, `tmp_d1`, `tmp_d3` (31/31), `tmp_s32_conf`, `tmp_s33_conf` (17/17), `tmp_s33_join` (35/35) (MUT).

Found. CRDT and channels: HOL-SEC-004, 009, 010, 012, 014, 015, 018 to 021, 046 to 052 (design E: a joiner took its state from whoever answered, replay past the op window, never-member backfill), 055, 056, 088, 092 to 095, 097 to 101, 118, 119, 121. MLS: HOL-SEC-017, 041 (Critical: an MLS seat proved nothing about its holder), 042 to 044, 084, 124, 131 (Welcomes would fail once a leaf was 84 days old), 132 to 135, 137. Conferences: HOL-SEC-061, 072, 123, 134, 136. Door rooms and joins: HOL-SEC-091, 092, 121, 127. Accepted: AR-10, 11, 12, 16, 17; AR-25 partly fixed and AR-27 fixed for all-0.13 groups in 0.13 (AR rows). The 0.13 wave found and fixed: siblings could mint the same CRDT op id (silent divergence, live in 0.12.2), the state-vector sync lost ops for good (live in 0.12.2), stand-in MLS leaders chosen by the lowest (grindable) id, and a ring replay that kept a joiner from ever taking its MLS seat; it also built AR-25 self-update turns and the AR-27 receiver epoch cap (see "Phase G").

Examined, no finding. - Matrix `V` rows (16 crdt, 2 channel): `CrdtOp` over MLS (crdt:A-03), transport facts (0.6), `ServerRenamed`, `MessagePinned`, `LabelCreated`, `LabelDeleted`, `LabelAssigned`, `LabelUnassigned`, `ChannelGrantSet`, `MemberMuted`, `EmojiAdded`, `EmojiRemoved`, `StickerAdded`, `StickerRemoved`, `JoinKeySet`, `JoinLock`; `ChannelSyncRequest` serving history (channel:A-CH07) and pin and unpin ingest (A-CH19); `ServerCheckpoint`, `JoinSealed`, `MeetingSealed` (new:4, 5, 18-20).

MATRIX. - L-03 (credential validation at every RFC 9420 entry point) holds at Add by KeyPackage frame, Add by parked join, Add by meeting knock, adds in a received commit, Update on the commit path, every proposal type, external commits, the Welcome tree, the application-message sender and catch-up; two gaps were filed (C-MLS-01, C-MLS-03, now HOL-SEC-132, 135). EF/mls "Leads". - L-08 holds for atomicity (the whole OpenMLS store is one snapshot in one statement, so disk never holds a torn group) and for allocation from peer input (`tls_codec` caps preallocation at 4096 bytes; ratchet, catch-up and cache bounds listed). EF/mls "Leads". - Info notes, not findings: padding 0, the MLS signer stored with the device secret, past-epoch senders classified by certificate, the legacy rebind (AR-35, removal in 0.14), the probe digest visible to the relay. EF/mls "Info".

Not examined. The phase E+F pass had no slice for CRDT ops, public channels or the backfill responders: flows F-30, F-34 and F-35 appear in no `phase_ef` file (grep), and TM section 7 still lists the STRIDE walk as "to do". Their coverage is the phase B matrix (crdt, channel rows) and design E. In the MLS slice nothing was run; C-MLS-04 rested on OpenMLS source until its fix; RFC section numbers were cited from memory; the push fetch's single-writer guard was taken from a code comment; relay behaviour after a kick was taken from AR-16 and design D1, not re-read (EF/mls "What I could not check"). No formal model.

WP4. Relay C++, opcode gates, rings, availability cache, snapshot, auth, kill list

Examined. `relay-uws/src` handlers (59 relay matrix rows plus new:27-32 for `auth_hello`, auth v2, `lock_get`, `lock_put`, `inbox_roster`, `lock_chain`, the door challenge), the restart snapshot, rings and the offline buffer, fair-share tables, the kill list, the session layer of resumable sessions, the relay host. Flows F-50 to F-53. Attacker P-01 against clients, and P-03 to P-05 against the relay (strangers with free identities, one or many addresses, carrier NAT, co-members of a big server). Sources: EV/relay, RC/relay, RC/relay_partB, MATRIX relay, EF/relay_push, RS-H, RS-B, `audit/design_ID1R_relay_rosters.md`, `audit/design_D1_door_rooms.md`.

How. Phase B matrix walk and re-check; a live relay test that drives the real `ws_handler.cpp` (`test_relay_live`, both builds of the release-day switches, MATRIX "Guard tests"); relay suites plain and under ASan and UBSan on the VPS before every deploy (the first sanitized run caught a use-after-free in the kill-list eviction, PLAN session 18); relay mutation passes `tmp_s32_relay`, `tmp_s33_relay` (21/21 on Linux plus 15/15 with `--mock`), `tmp_s33_join_relay` (5/5); the resumable-sessions reviews (a hostile test first for every case; handshake relay mutations 22 of 24 killed, client 3 of 4; bounds 19 of 19); phase H; the 0.13 fuzzing and G2 work.

Found. HOL-SEC-028 (Critical: one malformed frame from anyone stopped the relay), 029, 030, 031, 063 to 066, 069 to 071, 078, 091, 096, 126, 127, 128 (High: one join frame crashed the relay), 164, 165, 170 to 172. Phase H: HOL-SEC-073 (the relay, push sender and forwarder ran as an account with passwordless sudo), 074, 075. Accepted: AR-01, AR-06, AR-08, AR-14, AR-16, AR-18, AR-32 (closed in 0.13), AR-36 (partly fixed in 0.13). The 0.13 wave found a raw NUL in client JSON (Low), held bytes that could exhaust the box's memory, and closed the four 0.11 compatibility switches (see "Phase G").

Examined, no finding. - Matrix `V` rows (17): JSON `leave`, `subscribe`, push token register and unregister, `set_push_prefs`, `set_offline_buffer`, `get_turn_credentials`, binary 0x02, opcodes 0x00, 0x01 and unknown ones, self-hosted license keys, the HTTP endpoints, the restart snapshot, client events Connected, LeftRoom and the room budget events, the door challenge and `DoorStatus`; plus new:27-32 (auth v2, lock get and put, `inbox_roster`, the lock chain reply, the auth challenge). MATRIX. - Resumable sessions, bounds (RS-B "Attacks examined"): ring floods evict only the flooder (1.1); tombstones and gap accounting against a model under 60,000 random operations (1.2); frames larger than a ring (1.3); the `OfflineIndex` buffer address reuse with every exit path enumerated (3); per-IP grace slots (4.1); table-cap eviction order (4.2); IPv4 and IPv6 /48 shares and v4-mapped addresses (4.3); snapshot v9 records, truncation and the table cap on restore (6.1-6.4); drain on SIGTERM (7); wrong acks (8.2); `end` in a loop (8.4); pushes during grace (9). - Resumable sessions, handshake (RS-H): session ids compared

in constant time and drawn from libsodium's CSPRNG; ownership on resume needs a current roster record; a door moved during grace is judged by the session's own door nonce; after a restart every locked room needs a fresh proof; kill signals come first; nothing about sessions is logged; client JSON only through `client_json::parse` and pre-auth frames only through `parse_auth_frame`. - L-09 holds as AR-01 (EF/relay_push "Leads"). - The 0.13 fuzzing found no memory-safety or undefined-behaviour report in relay code in about 1.36 billion executions over nine targets (commit `22116aa5`).

Not examined. The harness does not run the relay C++ (CLAUDE.md "Multi-node harness"); relay logic is covered by its own suites. No penetration test of the deployed box: the phase E+F slice did not log into production, so coturn's live `/etc/turnserver.conf` and kdump were taken from the repo (EF/relay_push "Could not check"); `check-host.sh` is the box check (CLAUDE.md). Uncovered C++ judge rules after the 0.13 mutation pass: the plan pricing of `lock_put` junk proofs and of a non-member leave (survivors C6, C9), owed before the breaker's enforce switch. uWebSockets itself was not reviewed (it is on OSS-Fuzz, PLAN 2.8 item 6).

WP5. Updater, manifest signing, release pipeline, flatpak repo

Examined. `api/updater.rs`, the updater, news and status providers and widgets, the generated update and relaunch scripts, the update host, CDN and flatpak repo, flows F-70 to F-73, the release scripts, the installers (Inno, APK, Linux tarball and flatpak, macOS) and `.github/workflows`. Attacker P-10 (hostile update host, CDN, flatpak repo, network path or a PR author). Claims C-33, C-34. Source: EF/distribution (38 STRIDE cells, TUF attack list, SLSA).

How. One read-only phase E+F slice; fixes with tests (HOL-SEC-146, 147); feeds signed in 0.12.2 (CLAUDE.md "release feeds are signed").

Found. HOL-SEC-146 (links someone else chose opened with any scheme), 147 (news posts fetched remote images; a manifest version reached file names and update scripts). Accepted: AR-21 (no manifest expiry, no OS code-signature check), AR-22 (Android release key), AR-35 item 7 (no build provenance; SLSA L1 provenance script added in 0.13, commit `46898ff4`, unsigned).

Examined, no finding. The manifest is verified with `verify_strict` against a baked-in key before Dart sees a byte; every download is SHA-256-pinned against the signed manifest; non-https is refused; only a strictly newer `latest` reads as an update. The committed historical manifests verify under the current key, so they could serve a freeze but not a forgery (EF/distribution "Summary", "Notes for the lead").

Not examined. The `hollow://` feed link was traced statically, not driven at runtime; no hostile signing key was minted to drive the Windows `update.bat`; the flatpak GPG enforcement and the Android certificate were confirmed from code and memory, not re-run (EF/distribution "Notes for the lead"). The self-hosted relay setup wizard and its signed `relay.json` feed (commit `41080e0d`, inside the scope commit) have no audit or hostile-review record in the sources read; the commit message notes the first real `relay.json` publish still waits for approval.

WP6. Push, FCM, UnifiedPush, iOS NSE, channel push

Examined. The push sidecar (`push-sidecar/index.js`, `unifiedpush.js`, `fcm.js`), the push extension (Android background isolate, UnifiedPush entry, iOS `NotificationService.swift` with `push_enrich.rs`, `node/fetch.rs`, the iOS hints cache), channel push (0x09), push prefs and tokens on the relay. Flows F-36, F-53, F-60. Attackers P-01, P-11. Sources: EF/relay_push (79 STRIDE cells across relay and push, LINDDUN GO "relay (P-01) and push providers (P-11)"), EV/transport, RC/transport, MATRIX transport (24 rows).

How. Phase B matrix walk (transport, push fetch); phase E+F slice with LINDDUN GO; the 0.12.2 sealed-wake work (AR-26 row); fleet and phone runs.

Found. HOL-SEC-035 (the push path ignored blocks, key changes, mentions and the wake's sender), 059, 086, 107, 155, 156, 158, 160. AR-26 (wake payloads readable by Google and Apple) closed in 0.12.2 by RFC 8291 sealing; AR-33 (Firebase fallback, lock-screen previews) partly fixed in 0.12.1.

Examined, no finding. Matrix `V` rows: what the fetch node does not handle (device lists, CRDT, KeyRequest, friend flows, syncs, channel edits; transport:A-T-NF), `GossipCrdtOp` over a data channel (A-T14), frames that bypass `handle_incoming_request` (A-T21). The K3 deferral still matches the code: Android names nobody for an unknown sender (`authz_an_empty_wake_names_only_a_sender_we_know`). F-53 holds (push token registration); F-50 answered (inbox rooms show owners only, D1 hides locked rooms, DM rooms are HMAC names). AR-14, AR-16 and AR-18 unchanged by the slice. EF/relay_push "Leads".

Not examined. The iOS stranger-wake suppression waits for Apple's notification filtering entitlement (requested 2026-09-27): matrix rows transport:A-T10, relay:A-22 and relay:A-24 stay DEFERRED (MATRIX "Still open after phase B", MEMORY.md). `web-push` 3.6.7 internals were not in the tree; iOS backup inclusion of the App Group needed a device (EF/relay_push "Could not check"). The push parsers in `fetch.rs`, `push_enrich.rs` and the sidecar's `parseToken` are listed as fuzz targets and were not fuzzed (EF/relay_push "Fuzz targets").

WP7. Files, at-rest encryption, asset rail, `.hollowpack`, support credentials, link previews

Examined. File, vault, share, asset, preview and credential handlers in the Rust core; HFE1 content files at rest; ffmpeg as a helper; the Skia image codec; third-party fetchers (FxEmbed, TikTok, Klipy, FFZ, IGDB proxies); the shop's Ko-fi webhook and redeem path. Flows F-80 to F-86. Attackers P-03 to P-05, P-10, P-12. Sources: EV/files, RC/files, MATRIX files (35 rows), EF/files (31 STRIDE cells; phase B authorisation rows cited, not redone).

How. Phase B matrix walk and re-check; design A item A-D2 (self-certifying file ids, `node/file_commit.rs`); phase E+F slice; mutation passes `tmp_s31_vault`, `tmp_s31_dartfile`, `tmp_s32_files` (MUT); the 0.13 image check with its own fuzz target.

Found. HOL-SEC-022 to 027, 060 (any holder could answer for a file with other bytes), 067, 085, 102 to 106, 116, 117, 122, 148 (link previews fetched loopback and LAN addresses on the sender), 149 (ffmpeg decoded received media with no tap), 150 (location metadata in sent media), 151, 163 (iOS save let a sender's file name replace sandbox files). Accepted: AR-05, AR-06, AR-13, AR-20, AR-23, AR-35 (share manifest, fixed in 0.13); AR-28 closed in 0.13. The 0.13 image-check track found a panic in `image-webp` 0.2.4 that reached the event loop through a stranger's friend-request thumbnail (see "Phase G").

Examined, no finding. - Matrix `V` rows: `FileRequest` serving key and bytes (files:A-F3), `FileUnavailable` (A-F4), `RecoveryShardReceived` (A-R5), `ShareManifestRequest` (A-S1), `ShareChunkRequest` and `ShareChunkResponse` (A-S4, A-S5), `EmoteAssets` (A-E2). MATRIX. - F-86, the HOL-SEC-002 variant search: no file, share or vault key is ever sent where the relay can read it (EF/files "F-86"). - The embed and GIF proxy bases are user-configured, https-only with a host; showcase fetches are host-pinned to the Hollow CDN; vault paths sanitise server and shard ids before any join (EF/files "Notes / non-findings"). - The at-rest half of L-12 (E-12) holds (EF/files "Leads").

Not examined. Of the seven fuzz targets EF/files ranks, only the pure-Rust image check got one in 0.13; the bundled ffmpeg parsers, Skia's codec, `hollowpack::verify_pack`, libwebp via `webp_animation`, the `image` crate decoders behind `load_bounded`, `vault/erasure.rs::unpack_shard` and `link_preview::parse_og_metadata` were not fuzzed (EF/files "Phase-G fuzz targets"). Skia still decodes an image after the Rust check passes it; the check bounds what reaches Skia, it does not replace Skia's decoder (commit `a7263f6b`).

WP8. Local, SQLCipher, keystore, app lock, logs, deep links, clipboard, notifications

Examined. The Flutter UI, the Rust core at process level and the push extensions; stores E-10 to E-14; flows F-90 to F-96 (FFI, core to storage, the loopback media server, deep links, notifications, clipboard

and screenshots, support logs, helper processes); boundaries TB-4, TB-8, TB-9. Attacker P-09 (a device holder, a disk copy, another local process or OS user, a web page or app handing Hollow a link), P-11 (Apple holding an OS backup). Checklist OWASP MASVS v2 L2. Leads L-07, L-12. Source: EF/local (58 STRIDE cells, 40 requirements).

How. One read-only phase E+F slice; fixes with tests; the 0.12.2 hardware-wrapped App Lock (AR-24 row); App Lock and wipe journeys on the fleet and iOS.

Found. HOL-SEC-129 (archive and backup extraction wrote outside Hollow's folders), 155 (App Lock showed notification content and a reply box; a link opened above the lock), 156 (a wipe left files, log lines and the push registration), 157, 158 (iOS backups carried data and keys; the phrase in screenshots and the clipboard), 159 (short PINs and backup passphrases), 163. AR-24 (narrowed in 0.12.2), AR-33, AR-04.

Examined, no finding. No authorisation decision lives only in Dart (C-LOCAL-14); helper process arguments are not built from remote input (C-LOCAL-15); Android backup and device transfer are off (C-LOCAL-16); no remote-triggered panic in the local parsers walked (C-LOCAL-21); the wipe marker resumes safely (C-LOCAL-08); L-12 holds, the loopback server's four gates are sound, with two Info residuals (C-LOCAL-12, –13). EF/local, DISP.

Not examined. Runtime mobile behaviour (whether the deep-link confirm paints above the mobile lock cover, the iOS app-switcher snapshot, the App Group backup default) was read in source only; no test was run in the slice (EF/local "What I could not check"). There is still no hardware attempt counter for the App Lock PIN, by platform design (AR-24).

WP9. Media, SFrame keys and nonces, forwarder lane, call signalling

Examined. Media signalling (`node/voice_handler.rs`, `node/call_book.rs`, the CallSignal and VoiceChannel arms, the Dart call and voice providers), the SFrame layer (`frame_cryptor_service.dart` over libwebrtc's FrameCryptor and key provider), the standalone and embedded media forwarder, `screen_audio_capturer` and ffmpeg on peer media, SFrame key material in RAM, TURN. The libwebrtc frame cryptor was read in the desktop build tree (webrtc-sdk m144, our two patches leave it unmodified) and cross-checked against the `m144_release` head. Attackers P-01, P-05, P-06, P-10. Leads L-01. Sources: EF/media (46 STRIDE cells, RFC 9605 checklist), EV/media, RC/media, MATRIX media (16 rows).

How. Phase B matrix walk; phase E+F slice; mutation pass `tmp_s32_media` (MUT); voice and call fleet runs (mixed iPhone and Android calls).

Found. HOL-SEC-016, 037, 040, 045, 058, 090, 108, 109, 110, 120, 126 (anyone could see who used a media forwarder), 138 (a kicked member stayed in the voice call), 139 (undecryptable frames pinned a receiver's CPU), 140 (a share passed the forwarder before encryption), 141 (the Share lane leaked IP addresses with Always relay on), 142. Accepted: AR-03 (members can forge each other's frames, RFC 9605 7.2), AR-14, AR-35 (1:1 camera video and gossip-forwarded audio carry no SFrame layer, only DTLS-SRTP; SFrame there is on the 0.14 list).

Examined, no finding. - L-01 (SFrame nonce uniqueness): SAFE, no fix required (EF/media "L-01"). - AR-03: the code allows less than the accepted risk says (mesh attribution is per connection, so forging needs a forwarding role) (EF/media "Summary"). - Matrix `V` rows: plaintext `Call*` refused (media:A-MED-02), `fwd_*` at an embedded forwarder (A-MED-10), client-bound forwarder answers (A-MED-11). MATRIX. - Info observations I-1 to I-6 (no candidate): forwarder replay and header visibility, an SQLCipher open on the event loop, two upstream libwebrtc traps, helpers parse peer media unsandboxed, TURN credentials are a shared bearer token, a dead IV seed (harmless under L-01) (EF/media "Info").

Not examined. Nothing was built or run in the slice; the CPU cost was computed, not measured; the mobile libwebrtc binaries (Android 144.7559.01, iOS and macOS 144.7559.09) were not source-verified file by file; str0m's VP8 descriptor parser and the shipped ffmpeg were not reviewed; coturn's config came from the repo (EF/media "What I could not check"). The forked `flutter_webrtc` and our patched

libwebrtc build were examined only for the frame cryptor, and `screen_audio_capturer` was not fuzzed. The multi-node harness does not cover media or native code (CLAUDE.md).

Cross-cutting designs

These designs closed whole candidate classes rather than single rows. Each design file states its rules and residuals; the plan's state of play records the sessions.

Design	Examined	Result	Source
D, MLS leaf authority	Leaf credentials, commit and Welcome judging, fork repair	HOL-SEC-041 to 045; residual AR-27	`audit/design_D_mls_authority.md`, PLAN session 8
E, CRDT state authority	Anchors, the HLC fold, membership records	HOL-SEC-046 to 052; AR-10 to AR-12	`audit/design_E_crdt_authority.md`, PLAN session 9
A, frame authority	Every message type's lane, sealing, replay rules; five inventories (`design_A_inventory/`)	HOL-SEC-053 to 062, 072; claim C-24 reworded	`audit/design_A_frame_authority.md`, PLAN sessions 10-17
Join lock	Door and change keys, answers judged against a later lock read	Relay half deployed 2026-09-29	PLAN session 16
ID-1	The phrase as root, the roster, SPAKE2 linking	HOL-SEC-002, 076, 077; AR-02 closed, AR-15	`audit/design_ID1_identity_authority.md`, PLAN sessions 20-22
ID-1R	The relay folds rosters, owner-only inboxes	HOL-SEC-078 to 082	`audit/design_ID1R_relay_rosters.md`, PLAN sessions 25-26
D1, door-proof rooms	Server rooms visible only to door provers	HOL-SEC-091, 127; AR-16	`audit/design_D1_door_rooms.md`
G, MLS turns (0.13)	Self-update cadence and the receiver epoch rule	AR-25 partly fixed, AR-27 fixed for all-0.13 groups	`audit/design_G_mls_turns.md` (archived design; code and wiki `security_write_gates` section 48 win)
G, standing (0.13)	A stand-in MLS authority nobody can grind	Built with review changes	`audit/design_G_standing.md` (wiki section 51)
G2, circuit breaker (0.13)	Per-session work budgets, shipped in shadow	Enforce switch in 0.14	`audit/design_G2_breaker.md` (wiki section 52)

Phase G, the 0.13 wave (2026-10-22 to 10-24)

Each track went through a design review where needed, a hostile code review, a fix round, mutations, the full Rust suite on the PC and a fleet run. Merged-tree results on `c4e2f7f5`: Rust nextest 2749 of 2758 (7 keystore tests that fail over ssh, 2 load flakes passing alone), Flutter 2767 with 0 failures, analyze 0 errors, Windows fleet 28 of 28, every iOS phone scenario and the mixed iPhone and Android pass 10 of 10 in both roles. `41080e0d` changes no relay C++ or relay test file. The whole 0.13 relay was deployed on 2026-10-23.

Track	Examined	Found	Examined, no finding or judged sound	Source
Relay fuzzing	`parse_auth_frame`, the binary opcode parsers (moved into `binary_frame.h`), client JSON, `ring_auth`, join-lock links, rosters, kill orders, the snapshot codec, crypto inputs: nine libFuzzer targets with ASan and UBSan	Low: client JSON with a raw NUL was judged as a different value than the client's serde reads; now refused, with regression inputs	About 1.36 billion executions, no memory-safety or UB report in relay code; the parser extraction is byte-identical to the old inline code (exhaustive test up to 9 bytes), no membership gate moved	commit `22116aa5`
Image check (AR-28)	Every peer image path into Flutter: rail blobs, attachments, profile stills, push avatars, server icons, guest events, overlay and showcase images, sticker import	A crafted WebP in a stranger's friend-request thumbnail panicked `image-webp` 0.2.4 during re-encoding and ended the event loop task (remote crash in 0.12.2). The new `image_check` cargo-fuzz target also hit an `image-webp` panic (`yuv.rs`), which the check now counts as a refusal	HEIC and AVIF never drawn as images (they stay file cards); 34 of 35 mutations killed, the last a double layer	commit `a7263f6b`
HLC lanes	CRDT op ids across sibling devices	Siblings could mint the same op id, so replicas diverged for good (live in 0.12.2)	15 of 15 mutations, round 2 20 of 20	commit `6b612cb0`
Range-digest sync	Op sync between members	The state vector lost an author's older ops for good (live in 0.12.2); receivers re-forwarded ops N x (N-1) times. Review: an unchecked digest range let a member freeze the event loop (fixed before merge)	20 of 20 mutations	commit `98b4d842`
Presence digest and cap	Peer discovery every 30 s, member cap	A cost, not a security bug: one discovery round at 5k members took 30.4 s of relay CPU and 4.13 GB (now 1.02 s, 1.71 MB); servers admit at most 512 identities	Rust mutations 14 of 15 (one redundant), relay 9 of 9	commit `70f7f10e`
MLS cost	Past-epoch window, whole-store saves	Review: the committer's past copy kept a staged commit's secrets (fixed before merge)	32 of 32 mutations after the fix round	commit `f6e04a02`
AR-25 and AR-27	Self-update turns, receiver epoch cap	Several review HIGHs in the design and the code (tally parsing, KeyPackage planting), fixed before merge	Voice fleet with SFrame key per epoch: zero heal or decrypt failures	commit `af7196db`

Track	Examined	Found	Examined, no finding or judged sound	Source
Switches removal	The four 0.11 relay compatibility switches	Code deleted; seven live refusal tests fail on the old relay	VPS plain and SAN green	commit `6265b545`
AR-32 and AR-36	TURN reach to the relay host, the report key on disk, public stats, grace-slot takeovers, mailbox re-reads	AR-32 closed; AR-36 partly fixed	Item 7 (members only for changed rooms) judged unsafe to build: presence frames are uncounted, so the relay cannot know what reached a dying socket; kept accepted. Relay mutations 26 of 27 (one equivalent), TURN lock 18 of 18	commit `5cd8e92f`
Roster leftovers	Removals carried inside DMs, push-stored removals, sibling echo hold, new-device alert	Review: a cross-identity un-revoke (a device id's revoked flag followed whichever roster saved last); fixed in `10dac6d6`	39 of 41 mutations, fix round 17 of 18	commits `24eeed19`, `10dac6d6`
Message-store pool	SQLCipher opens on the event loop	Same-millisecond seals made a receiver treat a second link card as a replay; a send to our own device took a room the sibling had left	13 of 13, then 7 of 7 mutations	commit `5d5d9116`
AR-35	Replay guard across restarts, share manifests, archive format 2, provenance	A share manifest's size was not tied to its chunk count (sparse file reported complete)	27 of 27 mutations; residuals in the AR-35 row	commit `46898ff4`
Ring bucket	Ring replay against per-sender receive buckets	A busy channel's ring replay starved the owner's direct frames, so a joiner never took its MLS seat (live in 0.12.2)	6 of 6, then 8 of 8 mutations	commit `892f0dcc`
Sync cost	Channel history asks and page queries	Opening a channel asked every member device; per-page cost grew with history; review: an unsolicited page kept every ask alive (fixed)	21 of 21 mutations after the fix round	commit `e87391e0`

Track	Examined	Found	Examined, no finding or judged sound	Source
OOM send budget and G2 breaker	Bytes uWebSockets holds past backpressure; per-session work	Held frames could take several GB and an OOM kill loses the snapshot; reviews found a malformed-message crash path, a per-payer table that grew without bound and an O(members x links) stall in the new code, all fixed before merge	Honest fleet peaks small (119 frames/s, 7 joins, 36 verifies); enforced-mode fleet runs showed 0 honest trips, a flood tripped; VPS plain and SAN 46 of 46, 0 sanitizer output; relay mutations 29 of 32, survivor S7 argued sound, C6 and C9 not equivalent (tests owed)	commit `986a4d75`
Stand-in authority	Who leads an MLS group while the owner is away	Leaders were the lowest master id by string sort, which anyone can grind	12 of 12 mutations; Windows fleet a, b, c pass; a PC test failure proved to be a test race	commit `eb7ed684`
Removed device in a room	A device removed while connecting	It never learned its removal until its next connect	5 of 5 mutations	commit `60438a4a`
Friend re-add	Re-add after a removal	A re-add made shortly after a removal could be undone (wall-clock stamp older than the removal's seal)	21 of 21 mutations; a reviewer's frame-time rule was rejected (per-copy seals, behind clocks)	commit `c4e2f7f5`
G1 rerun	Join, message, reconnect, leave and kick, idle, MLS and relay costs on the merged tree	One regression risk: the digest ask fell back to the full vector under load (fixed in `fbd2b957`); cap stays 512 identities	Leave and kick 34x fewer frames, reconnect sync requests 15x smaller, idle 15x less, MLS 100x faster at 1k; three timing results marked void or unexplained (SCALE 8.5)	SCALE 8.1-8.7
Storage measurement	DB size per message, first sync of a new member	Channel-open asks fanned to every member device; per-page cost was quadratic; a `UNIQUE(...,text)` index drops an identical same-millisecond message with a different id (0.14)	1.7 KB per message, first sync takes the whole history	-

Fixed in the same commit, not a separate finding: `announce_door_change` sent presence to the device's own fetch sockets; since `986a4d75` it skips fetch and guest sockets (`relay-uws/src/ws_handler.cpp`, the `!d->is_fetch` check in that function).

Exit criteria against the record

Criterion (PLAN section 6)	State in the record
Every DFD element walked through its STRIDE cells; LINDDUN GO on relay and push	443 cells in eight phase E+F slices; LINDDUN GO done in EF/relay_push. Flows F-30, F-34, F-35 (CRDT ops, public channels, backfill responders) had no E+F slice; TM section 7 still says "to do"

Criterion (PLAN section 6)	State in the record
Every matrix row has verified code evidence and an `authz_*` test per wrong principal	346 rows, 0 OPEN, 3 DEFERRED (K3), every row with a guard test column. Most rows are agent-verified with mechanically checked citations; the lead re-read OPEN rows and ten sampled FIXED rows (MATRIX). Per-principal completeness is not recorded per row
Every requirement traces to a test	Requirements exist per slice (R-IDENTITY, R-OLM, R-MLS, R-RP, R-DIST, R-FILES, R-LOCAL, R-MEDIA), written at `aa104d48` with some NOT MET at the time. There is no consolidated `requirements.md` (PLAN artifact table) and no record re-checking each R-* at the scope commit
Every finding fixed and retested, or accepted	Finding headers read "Fixed" or "Fixed… retest at release"; HOL-SEC-015 and 017 read "Fixed" since the close-out (their rest closed by HOL-SEC-062 and 041, as CAND and PLAN record). Retest dates per finding are not filled in
Every finding has a variant-analysis section	51 of 168 finding files mention variants (grep). PLAN phase D (variant analysis as its own session) has no separate record
`coverage.md` lists each work package	This file
Tooling items 1-5 of PLAN 2.8 run in CI	1 and 2: CI job "Supply Chain" runs cargo-deny 0.20.2, osv-scanner 2.5.1, gitleaks 8.30.1 over the whole history and zizmor 1.30.1 (`ci.yml:285-347`). 3: the harness runs in nextest. 4 (proptest state machines): no record, `proptest` is not a dependency. 5: relay fuzzing runs nightly on the Mac mini by decision, not in public CI (crash inputs stay private); the Rust envelope parsers are not fuzzed

Not covered and known gaps

- **No independent team and no outside audit yet.** The work was done by the owner with AI agents as enumerators, builders and hostile reviewers. An external audit with the support of OSTIF is planned.
- **No formal protocol model.** Verifpal or Tamarin on the roster, destroy orders and a relay-controlling attacker was deferred until the device design froze (PLAN 2.8 item 9, decision 3); no record that it was done.
- **No penetration test of the deployed relay box.** Host state is checked by `check-host.sh`; the slices read repo config, not the live box (EF/relay_push "Could not check").
- **The harness covers neither the relay C++ nor media and native code, nor device-to-master attribution across processes** (one process-wide resolver) (CLAUDE.md "Multi-node harness"). The relay has its own suites; media and native code rely on fleet runs.
- **Media and native code only in part.** The forked `flutter_webrtc` and our libwebrtc build were read for the frame cryptor only; mobile WebRTC binaries were not verified file by file; `screen_audio_capturer`, ffmpeg and Skia were not fuzzed (EF/media, EF/files).
- **Rust parsers not fuzzed**, except the image check: the serde envelopes, `parse_ops_tolerant`, `fetch.rs` frame parsing, `hollowpack`, vault shards and the link-preview parser (PLAN 2.8 item 5, EF/files, EF/relay_push).
- **No property-based tests** of the authorisation cores (PLAN 2.8 item 4); no record.
- **Static rules and lint ratchets** (PLAN 2.8 items 7, 8): no record in the audit; an earlier Semgrep pass (issue 46) and SonarQube Cloud predate it.
- **Phase E+F slices ran nothing.** Every slice was read-only; their "met with a test" verdicts mean the test exists, not that it passed at that tree (EF/local, EF/identity headers).
- **CRDT and channel STRIDE.** Covered by the phase B matrix and design E only (see WP3).
- **Open accepted risks.** `AR` holds the current state of every row. Among them: no per-message relay limits (AR-01, AR-06; the G2 breaker runs in shadow until the 0.14 enforce switch), member frame

forgery in calls (AR-03), the first-contact and legacy residuals of the identity designs (AR-10 to AR-19), and the residuals of AR-25, AR-27 (mixed-version groups and meetings), AR-33, AR-35 and AR-36.
- **iOS stranger wakes** wait on Apple's filtering entitlement (K3).
- **0.14 list** of known compatibility paths still in 0.13: vector sync, the old discovery answer, the ring-1 switch, the MLS legacy rebind, SFrame on 1:1 camera and gossip audio, archive format 2 writes, the `revoked_devices` dual write, the hidden-sender broadcast limits and the breaker enforce switch.

Timeline

Dates	Phase	Main output
2026-09-26	Research, method, phase A	PLAN; claims, threat model, AR register; HOL-SEC-001, 002
2026-09-26 to 09-29	Phase B evidence and class fixes	HOL-SEC-003 to 072; designs D, E, A, join lock; relay deploys
2026-09-30	Phase H	HOL-SEC-073 to 075
2026-09-30 to 10-02	ID-1, ID-1R, first regression pass	HOL-SEC-002, 076 to 082; fleet 28 of 28, phones 9 of 9
2026-10-02 to 10-04	Phase B re-check, rebuild, close	HOL-SEC-083 to 127; 346 matrix rows, 0 OPEN
2026-10-04	Phases E and F, merged	HOL-SEC-128 to 162; AR-21 to AR-35; DISP
2026-10-05	Final regression pass, 0.12.0 released	-
2026-10-06 to 10-07	Scanner triage; resumable-sessions reviews	HOL-SEC-163, 164, 165, 170 to 172; AR-36
2026-10-08 to 10-20	0.12.1 and 0.12.2	AR-24 narrowed, AR-26 and AR-29 closed, AR-30 and AR-34 fixed, AR-33 in part
2026-10-22 to 10-24	Phase G, the 0.13 wave	26 commits `22116aa5` to `41080e0d`; relay deployed 10-23; merged-tree suites and fleets 10-24

Appendix B: Whitepaper claims check

Appendix to the 0.13 security report. Close-out item of the audit plan (`SECURITY_AUDIT_PLAN.md`, phase G close-out): `WHITEPAPER.md` security claims re-checked against `claims.md` and against the code.

- **Scope:** commit `41080e0d` on `main` (tree relay `relay-uws/src` and client `rust/hollow_core/src` plus `lib/` where a claim lives in Dart.
- **Date:** 2026-10-24.
- **Method:** `WHITEPAPER.md` read whole. Every security-relevant statement, and every claim C-01 to C-37 of `claims.md`, was located with code search, floored with Grep, and checked by reading the lines cited below. The 0.13 changes named in the wiki rows of `security_write_gates.md` §47 to §50 and in the wave g13 0.13 change list were each checked in code for text they make stale. No tests were run for this check; the evidence is the code as written at `41080e0d`. Accepted risks are named by their `accepted_risks.md` row.
- **Verdicts:** *Holds* (the code does what the text says), *Holds with a residual* (true, with a known limit named by its AR row), *Stale* (the text describes older behaviour), *Overclaims* (the text promises more than the code does). Every Stale and Overclaims row was edited in `WHITEPAPER.md` to make it true; the column "Action" says how.

Paths below are relative to the repository root. `hc/` is `rust/hollow_core/src/`, `relay/` is `relay-uws/src/`.

1. Whitepaper statements

Section	Claim (short quote)	Verdict	Evidence	Action
1.1	"without the relay ever learning that two connections belong to the same person"	Overclaims	The relay sees which device ids join `inbox:{master}` and holds each roster (`relay/roster_book.h`); WP 3.1 and C-24 already say so	Reworded: the relay can tell which device ids belong to one person but reads nothing they send
3 (intro)	"without the relay ever learning that two connections belong to the same human"	Overclaims	as above	Same rewording
3.1	"The device key drives identity only at the transport layer"	Stale (0.12)	Device key seals every relay frame (`hc/node/frame_auth.rs:175`), signs Olm key exchange (`hc/node/crypto_handler.rs:693`), is the MLS leaf signer (`hc/crypto/mls_manager.rs:632`), signs roster statements (`hc/identity/roster.rs`)	Lists what the device key signs; content, server ops and profiles stay master-keyed
2.3	"Argon2id (65536 iterations, 3 parallelism, 32-byte output)"	Stale (misdescribed)	`argon2::Params::new(65536, 3, 1, Some(32))` = 64 MiB memory, 3 iterations, 1 lane (`hc/identity/encryption.rs:109`)	Parameters corrected
2.3	Duress slot always present, both slots derived, wipe shows nothing	Holds	`hc/identity/duress.rs:88`, `:121` (dummy slot); C-07	none
2.3	Remote destroy signed by the recovery key, judged against link time and applied stamp	Holds with a residual	`hc/node/destroy.rs:145` (`judge_own_order`); AR-18	none
2.4	Content files at rest are per-file AES-256-GCM	Holds	`hc/node/at_rest.rs:271` (`read_all`) and the module's gates	none
2.5	Backup Argon2id with 64 MB memory	Holds	`hc/api/storage.rs:2247`, `:2311`	none
2.6	New PIN has at least six digits; on-phone pacing	Holds with a residual	`lib/src/core/services/app_lock_service.dart:10` (`kMinPinDigits = 6`); AR-24	none
3.2	Roster fold, removals a union, master key admits nothing	Holds with a residual	`hc/identity/roster.rs:797` (`fold`), `hc/node/resolver.rs:95` (`is_bare_master`); AR-15, AR-19 (mutual removal)	none

Section	Claim (short quote)	Verdict	Evidence	Action
3.4	SPAKE2 link, one guess per code, landing as one set	Holds	`hc/node/link_pake.rs:124-146`, `hc/api/storage.rs:2109` (`land_snapshot`), `:2589` (`refuse_while_not_ready`)	none
3.5	DM room name only its two parties can compute	Holds	`hc/node/dm_room.rs:47`	none
3.6	Removal reaches contacts through DM roster digests, 35-day re-ask, 10 s hold	Holds with a residual	`hc/node/roster_reach.rs:620` (`hold_for_stale_roster`); AR-29 residuals (no cross-contact comparison, a relay can drop blind)	none
3.6	Removed device locks and erases after three days	Holds	`lib/src/ui/shell/roster_lock.dart:58-83`; 0.13 adds a re-send when the removed device appears in a room (`hc/node/roster_book.rs:420`)	none
3.6	"The phrase can also turn the wait off"	Overclaims (ambiguous: reads as "admits at once")	`no_wait` means a restored backup never joins by waiting (`hc/identity/roster.rs:86`)	Says the seven-day path is turned off, so a backup joins only by approval or the phrase
4.3	Frame leaves only after its session save; stale sessions pruned after 7 days	Holds	`hc/node/crypto_handler.rs:828` (`olm_frame`), `hc/node/swarm.rs:6435`	none
5.2	Subgroup coordinator "the lowest-id online member who both still qualifies and already holds the subgroup"	Stale (0.12 owner first, 0.13 standing)	`hc/node/crypto_handler.rs:2058-2090` (`elect_subgroup_coordinator`)	Owner while online, otherwise chosen as in 5.3
5.2.1	"Each leaf's credential is the bare device peer ID"	Stale (0.12, design D)	Bound credential `hl1:{device}:{master}:{master_signature}` (`hc/node/mls_authority.rs:64`), signer = device key (`hc/crypto/mls_manager.rs:632`), unbound adds refused (`hc/node/mls_authority.rs:76`)	Describes the bound leaf and that unbound leaves are ignored
5.2.1	Linked sibling "inherits the source device's MLS signing material ... clears and regenerates"; legacy leaf "never re-keyed"	Stale (0.12)	Backup carries no MLS identity and landing scrubs device secrets (`hc/api/storage.rs:2109`); a pre-0.12 leaf is rebound to the device key (`hc/crypto/mls_manager.rs:1509`)	Rewritten to the 0.12 behaviour

Section	Claim (short quote)	Verdict	Evidence	Action
5.3	"the online member with the lexicographically lowest peer ID ... acts as coordinator"	Stale (0.13)	Owner first (`hc/node/crypto_handler.rs:1825`), standing where every leaf runs 0.13 (`hc/node/standing.rs:91`, `:158`), old rule in mixed groups (`:149`)	Owner, then standing (role, membership position, id), lowest id only in mixed groups
5.3.1	KeyPackage to "lowest online peer, excluding self"	Stale	as 5.3	Refers to 5.3
5.4	Three past epochs, 512 skipped keys	Holds	`hc/crypto/mls_manager.rs:22-30`, `hc/crypto/mls_past.rs:21`	none
5.4	"Members do not yet refresh their own leaf keys ... Scheduled self-updates are planned"	Stale (0.13, AR-25)	Turns handed by the committer, path-only commit judged and broadcast by it (`hc/node/mls_turns.rs:382-497`, `:290`); at most once a day per leaf, at most 48 a day per group, fewer above 512 leaves (`:67-79`); only an on-screen device takes a turn (`our_turn`, wiki §48); meetings skipped (`:410`); a pre-0.13 leaf never answers a turn	Rewritten to exactly this, with the residual (rarely online device, 0.12.2 device, large server)
5.6	Every relay frame signed by the sending device, fixed lanes	Holds	`hc/node/frame_auth.rs:175`, `:211`; `hc/node/types.rs:4488` (`lane`)	none
6.3	DM camera video and gossip audio have no SFrame layer	Holds with a residual	AR-35 (0.14: SFrame on both)	none
6.4	"The TURN server sees only SFrame ciphertext"	Overclaims	6.3's two paths are DTLS-SRTP only	Says ciphertext, SFrame inside DTLS-SRTP or DTLS-SRTP alone on those paths
6.4	Screen shares stream only on a watch request	Holds	`hc/node/voice_handler.rs:524`; `lib/src/core/providers/voice_channel_provider.dart:359`	none
9.7	MLS coordinator "(lowest peer ID)"	Stale	as 5.3	Refers to 5.3
10.1	HLC `actor` = "peer ID"; "Monotonically increasing per actor"	Stale (0.13 lanes)	Actor = author's master (`hc/crdt/operations.rs:123`); per-device counter lanes (`hc/crdt/hlc.rs:45-55`, `:173-179`)	Actor is the master; monotonic per device, siblings mint in their own lanes
10.1, 10.6, 23.1	Drift bound 5 minutes	Holds	`hc/crdt/hlc.rs:18`, `:138`	none

Section	Claim (short quote)	Verdict	Evidence	Action
10.2, 10.6	Ops signed, author bound to key, unsigned refused	Holds	`hc/crdt/operations.rs:98-130`; `hc/crdt/fold.rs:172` (`ingest_remote`); `hc/crdt/server_state.rs:1806` (`op_allowed`)	none
10.5	"Each sends a state vector"	Stale (0.13 range digest)	`hc/crdt/digest.rs:1-29`, `hc/node/op_sync.rs:1-11` (vector only for older builds)	Steps 1 and 2 describe the salted range digest; the vector for pre-0.13 peers
10.5	Server delete honoured only from the owner	Holds	`hc/crdt/server_state.rs:1931`	none
11.5	"the `author` field is verified against the actual sender's peer ID"	Stale (contradicts 10.2)	`hc/crdt/operations.rs:112-130`	Author must match the signing key, never the relayer
11.5	Every serving path asks the channel ladder	Holds	`hc/node/crypto_handler.rs:1696` (`channel_readable_by`)	none
11.6	Voice channels never public	Holds	`hc/crdt/server_state.rs:227` (`effective_public`)	none
11.7	Receivers enforce mutes, posting and media-only on live traffic	Holds with a residual	`hc/node/message_ops.rs:2735`, `:1722`; AR-19 (slow mode by signed time)	none
12.1	Relay has "no knowledge of ... application state"	Overclaims	Relay holds rosters, join locks, kill orders, push registrations, nickname claims (12.7)	Says the only application state it holds is what 12.7 lists
12.2	v1 auth payload `hollow-ws-auth:{peer_id}:{ts}`, ±60 s	Stale (0.12; v1 code deleted in 0.13)	`relay/auth_frame.h:18-27`, `:160-180`; nonce and domain check `relay/ws_handler.cpp:513-600`; client `hc/node/ws_client.rs:2547`	Rewritten: `auth_hello`, nonce, signed v2/v3 payload, peer id derived from key, no timestamp judgment, v1 refused
12.3	DM room = "deterministic hash of both peer IDs"	Stale (0.12)	`hc/node/dm_room.rs:47`	Keyed hash only the two parties compute
12.3	10,000 rooms per peer, 64 MB binary, 1 MB text	Holds	`relay/ws_handler.cpp:32`, `:4298`, `:4397`	none
12.5	"No application-level rate limiting"	Stale (0.13 breaker, shadow)	`relay/breaker.h:16-34` (shadow by default, 1013 close plus resume when enforced)	Adds the shadow-mode circuit breaker, which drops nothing
12.5	"nothing is counted or recorded"	Overclaims (0.13)	The breaker counts work units (`relay/breaker.h`)	"no volume is counted or recorded"
12.5	Eviction "of whichever sender currently occupies the most slots"	Stale (0.12, HOL-SEC-070)	Heaviest hashed address share (`relay/ws_handler.cpp:2218-2222`)	Address share

Section	Claim (short quote)	Verdict	Evidence	Action
12.5	"Hard backpressure: 64 MB per connection"	Stale (0.13 send budget)	`relay/send_budget.h:15-60`, `:93-103`; `relay/ws_handler.cpp:4249-4265`	Adds the whole-relay budget charged to the non-reading socket's share and the two-minute stall close
12.6	TURN credentials only over the authenticated WebSocket	Holds	`relay/http_handlers.cpp:37-43`	none
12.6	"The only traffic the TURN server can carry is Hollow client to Hollow client"	Overclaims before 0.13 (AR-32); true with the port lock	`relay-uws/deploy/turn-port-lock.sh:1-30`, `hollow-turn-port-lock.service`	Adds a "Port lock" bullet; the sentence now depends on it and names the forwarder
12.7	What the relay sees (table)	Overclaims (omission)	Join lock chains (`relay/join_lock.h:14-19`, `relay/door_room.h`), nickname claims (`relay/ws_handler.cpp:2658`) were missing	Two rows added
12.9	Stats fields; no opt-out	Stale (0.13)	`relay/server_stats.h:11-37`, `relay/config.h:32`, `:91`; client hides the count when absent (`lib/src/ui/settings/network_section.dart:268`)	Lists the counters and `PUBLIC_STATS=off`
12.10	`/register`, `/unregister`, `/bootstrap` endpoints	Stale (removed before 0.12)	`relay/http_handlers.cpp:21-33`	Says they are removed
12.12	Nickname claim within five minutes; resolver refuses older than eleven	Holds	`relay/ws_handler.cpp:2658`; `hc/node/nick_claim.rs:16`	none
12.13	"A global byte budget ... with oldest-first eviction"	Stale (0.12)	`relay/state.h:104-107`	Heaviest address share loses its oldest frame
12.13	Join ring holds "what the relay already routed in plaintext"; "anyone holding the room's invite can read the ring"; Twitch proof "stripped from the parked copy"	Stale (0.12 join lock)	Request sealed to door and invite key (`hc/node/join_lane.rs:1-11`, `:103-118`), resolution sealed (`hc/node/sync_handler.rs:1667-1700`), parked copy keeps `twitch_proof_json` (`hc/node/join_lane.rs:108`)	Rewritten: sealed copies, readers are current join-key holders, a follow credential may ride
12.13	Member cap applied at admission	Holds	`hc/node/member_cap.rs:12`, `:21` (512 identities, admission only, advisory per wiki §47)	none
12.14	Report key "in its own owner-only file"	Stale (0.13, AR-32)	`relay/reports.h:30-64`, `relay/reports.cpp:76-120`	Key in memory only, handed over in memory, new after a reboot
12.15	Grace 120 s (30 to 600), 8 MiB and 4,096 frames	Holds	`relay/session.h:29-35`	none

Section	Claim (short quote)	Verdict	Evidence	Action
12.15	"A session in grace keeps its connection slot"	Stale (0.13, AR-36)	`relay/session_bounds.h:237-265`, `relay/state.h:41`	Adds the half-grace takeover rule, three a minute per address
13.1	Wake block sealed to the device	Holds with a residual	`hc/crypto/push_seal.rs:373`; `push-sidecar/fcm.js:4-7`; AR-26 residuals	none
13.2	Offline DM buffer 100 messages, 1 image, 24 h	Holds	`relay/state.h:55-60`	none
15.1	Signing v2/v3, album shape-checked	Holds	`hc/node/crypto_handler.rs:374` (`sign_message_versioned`)	none
12.14, 23.1	Blocks enforced at ingest, master-keyed	Holds with a residual	`hc/node/blocklist.rs:41`; AR-31	none
16.3	Archive format 2 domain tag	Holds (clarified)	`hc/archive/loader.rs:347`; exports stay format 1 (`hc/archive/types.rs:5`); AR-35	Adds "0.13 opens both formats and still writes format 1"
22	Relay auth "timestamp-bound, ±60s"	Stale	as 12.2	Row says domain and one-use nonce
23.1	Link previews make no recipient request	Holds	`hc/node/link_preview.rs:5`	none
23.1	Resource exhaustion "64 MB hard backpressure"	Stale	as 12.5	Names the per-connection and whole-relay budget
23.1	Privilege escalation "verified against the actual sender"	Stale	as 11.5	Author bound to the signing key
23.1	Stolen device: "A backup file restored elsewhere waits until one of your devices approves it"	Overclaims	Seven quiet days admit it unless `no_wait` (3.6, AR-15)	Adds the seven-day path and its switch
23.4	Signed manifest, no downgrade, signed feeds	Holds with a residual	`hc/api/updater.rs:96`, `:171`, `:208`; `lib/src/core/providers/updater_provider.dart:177-190`; AR-21, AR-22	none
23.4	Flatpak repository GPG-signed	Holds (not re-run)	`scripts/publish_flatpak_repo.sh:10`	none
24	"MLS post-compromise recovery ... Periodic self-update commits are planned"	Stale (0.13)	as 5.4	States what 0.13 gives and its limits

2. claims.md promises

Claim	Short quote	Verdict	Evidence	Action
C-01	Only a current device or the phrase changes my devices	Holds with a residual	`hc/identity/roster.rs:797`; `hc/node/resolver.rs:95`; AR-15, AR-19, AR-34	none

Claim	Short quote	Verdict	Evidence	Action
C-02	Nothing another identity sends can wipe my devices	Holds with a residual	`hc/node/destroy.rs:145`; relay courier `relay/kill_order.h`; AR-18	none
C-03	A removed device stops getting anything, locks, erases in three days	Holds with a residual	`hc/node/roster_reach.rs:620`; `hc/node/roster_book.rs:420` (0.13: told on arrival); `lib/src/ui/shell/roster_lock.dart:58`; AR-29	none
C-04	A replayed roster never brings back a removed device	Holds with a residual	`hc/identity/roster.rs:797` (union of removals); AR-15	none
C-05	Linking hands the identity only to the confirmed device; one relay guess	Holds	`hc/node/link_pake.rs:124-146`; `hc/api/storage.rs:2109`	none
C-06	A copied identity file is useless without machine or password	Holds	`hc/identity/encryption.rs:109`; "no protection" mode excluded by design	WP 2.3 parameters corrected
C-07	Duress destroys, shows nothing, costs the same	Holds	`hc/identity/duress.rs:88`, `:121`; both slots derived (CLAUDE.md, wiki §13)	none
C-08	Only the two people read a DM	Holds with a residual	`hc/node/crypto_handler.rs:828`; `hc/node/dm_room.rs:47`; AR-04 (traffic analysis)	none
C-09	A shown message was signed by that master over exactly what is shown	Holds	`hc/node/crypto_handler.rs:374`; `hc/node/message_ops.rs:1722`	none
C-10	The relay cannot insert itself into a key exchange	Holds with a residual	`hc/node/crypto_handler.rs:687`, `:693`; AR-04 (TOFU)	none
C-11	Safety numbers verify the person; new-device warning	Holds	`hc/crypto/safety_number.rs:80`	none
C-12	Friend accept only answers a request I sent	Holds	`FriendAccept` arm `hc/node/swarm.rs:13218`, lands only on our pending outgoing row of that request or newer (`:13375`); 0.13 removal stamps `hc/node/social.rs:204` (wiki §50)	none
C-13	Blocked identity dropped before store or notify	Holds with a residual	`hc/node/blocklist.rs:41`; AR-31	none

Claim	Short quote	Verdict	Evidence	Action
C-14	Removed or banned member cannot read later content	Holds with a residual	Removal commit judged and merged (`hc/node/mls_authority.rs:70`); AR-16 (room visibility for 60 s, not content); AR-25 narrowed by 0.13 self-updates	none
C-15	Only role holders change server state; false author rejected	Holds with a residual	`hc/crdt/operations.rs:98-130`; `hc/crdt/fold.rs:172`; `hc/crdt/server_state.rs:1806`; AR-10, AR-11, AR-12	WP 11.5 and 23.1 reworded
C-16	Only the owner deletes a server	Holds	`hc/crdt/server_state.rs:1931`	none
C-17	Nobody posts, edits or reacts as someone else; mutes enforced by receivers	Holds with a residual	`hc/node/message_ops.rs:2735`, `:1722`; AR-19 (slow mode)	none
C-18	Restricted channel content reaches only those allowed	Holds	`hc/node/crypto_handler.rs:1696`; subgroups (WP 5.2)	none
C-19	Nobody adds to a group without the admission rules	Holds with a residual	`hc/node/mls_authority.rs:40`, `:70-106`; AR-15 (meetings), AR-35 (legacy rebind until 0.14)	WP 5.2.1 now describes the bound leaf
C-20	Public channel messages signed and unforgeable	Holds with a residual	`hc/crdt/server_state.rs:227`; `hc/node/crypto_handler.rs:374`; AR-17 (guest previews)	none
C-21	Media readable only by participants	Holds with a residual	`hc/crypto/mls_manager.rs:2139` (`export_secret`); WP 6.3; AR-35 (two DTLS-only paths), AR-03	WP 6.4 TURN sentence corrected
C-22	My screen share streams only to people who asked	Holds	`hc/node/voice_handler.rs:524`; `lib/src/core/providers/voice_channel_provider.dart:359`	none
C-23	Withdrawn	n/a	AR-03	none
C-24	A malicious relay sees routing metadata only	Holds with a residual	`hc/node/types.rs:4488` (`lane`); `hc/node/frame_auth.rs:175`, `:211`; `hc/node/join_lane.rs:1-11`; AR-04	WP 1.1, 3, 12.1, 12.7, 12.13 reworded
C-25	A malicious relay can delay or drop, never forge	Holds with a residual	Signatures on every listed object (frame seals, CRDT ops, rosters, accepts, kill orders); AR-29 (withholding)	WP 12.2 updated

Claim	Short quote	Verdict	Evidence	Action
C-26	Push providers never receive content; wake block sealed	Holds with a residual	`hc/crypto/push_seal.rs:373`; `push-sidecar/fcm.js:4-7`; AR-26 residuals	none
C-27	Reading a link preview makes no request to the site	Holds	`hc/node/link_preview.rs:5`	none
C-28	An invite link never reveals the server id to the website	Holds	`lib/src/ui/chat/hollow_link_utils.dart:14` (fragment link)	none
C-29	Nothing a peer sends writes outside Hollow's folders	Holds	`hc/node/share_handler.rs:304` (`safe_file_name`); `hc/api/storage.rs:2109`	none
C-30	Files E2EE in transit and unreadable at rest without the identity	Holds	`hc/node/at_rest.rs:271`; `hc/node/file_commit.rs:43`, `:161`	none
C-31	An asset shown for a hash is exactly those bytes; unsolicited dropped	Holds with a residual	`hc/node/assets.rs:5`; AR-05; 0.13 pure-Rust pre-check before Skia (`hc/node/image_gate.rs:1-6`) closes AR-28's decoder exposure	none
C-32	Support and Twitch credentials issued by the pinned root, not transferable	Holds with a residual	`hc/node/support_creds.rs:642`; AR-23	none
C-33	Only signed updates, no downgrade	Holds with a residual	`hc/api/updater.rs:171`; `lib/src/core/providers/updater_provider.dart:182`; AR-21, AR-22	none
C-34	Flatpak accepts only bundles signed by Hollow's key	Holds (not re-run)	`scripts/publish_flatpak_repo.sh:10`	none
C-35	App Lock hides content and notifications until unlock	Holds with a residual	`lib/src/core/providers/system_notification_provider.dart:480`, `:492`; AR-33	none
C-36	Argon2id per PIN guess, six-digit minimum	Holds with a residual	`lib/src/core/services/app_lock_service.dart:10`; `hc/identity/encryption.rs:109`; AR-24	none
C-37	Logs never hold content, keys, codes or passphrases	Holds	`hc/lib.rs:154-175` (redaction); relay log filter checked in the regression pass	none

3. Counts

- Whitepaper statements: 70 rows. Holds 25, Holds with a residual 9, Stale 27, Overclaims 9. All 36 Stale and Overclaims rows were edited (30 edits, some covering several rows).
- claims.md: 37 rows. Holds 15, Holds with a residual 21, withdrawn 1. None Stale or Overclaimed at `41080e0d`.

4. Edits made to WHITEPAPER.md

1. 1.1 Design goals, multi-device bullet: the relay can tell which device ids belong to one person.
2. 3 intro: same.
3. 3.1: what the device key signs since 0.12.
4. 2.3: Argon2id parameters (64 MiB, 3 iterations, 1 lane).
5. 5.2: subgroup coordinator is the owner, else chosen as in 5.3.
6. 5.2.1: bound leaf credential; linked devices get no MLS signing material; pre-0.12 leaves rebind.
7. 5.3: coordinator by owner, then standing, lowest id only in mixed groups.
8. 5.3.1: coordinator reference.
9. 5.4: self-update turns since 0.13 and what they leave.
10. 9.7: MLS coordinator reference.
11. 10.1: HLC actor is the master; per-device lanes.
12. 10.5: range digest, vector only for pre-0.13 peers.
13. 11.5: CRDT author bound to the signing key.
14. 12.1: the relay's application state is what 12.7 lists.
15. 12.2: v2/v3 challenge login; v1 refused.
16. 12.3: DM room is a keyed hash only the parties compute.
17. 12.5: shadow circuit breaker; "no volume is counted"; eviction by address share; send budget.
18. 12.6: port lock bullet; the "only traffic" sentence tied to it.
19. 12.7: rows for join locks and nickname claims.
20. 12.9: counters listed; `PUBLIC_STATS=off`.
21. 12.10: HTTP discovery endpoints removed.
22. 12.13: global budget evicts by address share; join ring copies sealed, follow credential may ride.
23. 12.14: report key in memory only.
24. 12.15: grace slot takeover rule.
25. 6.4: TURN sees only ciphertext, SFrame or DTLS-SRTP alone on the 6.3 paths.
26. 3.6: the phrase turns the seven-day path off (no ambiguity).
27. 16.3: 0.13 reads both archive formats, writes format 1.
28. 22: relay auth row.
29. 23.1: resource exhaustion, privilege escalation, stolen device rows.
30. 24: MLS post-compromise bullet.
31. 5.4: receiver epoch-rate rule (AR-27), added by the lead after this check.
32. 7.3: image check before display; HEIC and AVIF stay file cards (AR-28), added by the lead after this check.

5. Mismatches not fixed

1. **Version header.** Line 3 still reads `Version 0.12.2` while the text now describes 0.13. Left for the release step, as asked.
2. **AR-27, the receiver epoch-rate rule, is not described.** No text was stale, so nothing was added. 5.4 could gain one sentence: receivers refuse a commit past 3 counted commits per identity in 12 epochs where every device runs 0.13 (`hc/crypto/mls_rate.rs:183`, wiki §48). Lead's call.
3. **AR-28, the pure-Rust image pre-check, is not described.** No stale text. A sentence in 7.3 or 10.7 would state it (`hc/node/image_gate.rs`). Receivers now refuse formats the check cannot decode (HEIC and AVIF among them); 7.3 says images become WebP on send, but whether every send path and quality tier converts HEIC was not verified here.
4. **Designs D and E are under-described, not over-described.** 5 never says commits are staged and judged before merge (only 5.3.3 hints at it), and 10.5 says a joiner "adopts the snapshot" without saying a member's snapshot keeps only the owner's role (HOL-SEC-093) or that state folds from a provable anchor. 1.1 still says server state has "no authoritative source", while design E fixes the owner. These under-claim; a fuller rewrite of 10 is a documentation task, not a correction.

5. **Accepted-risk and claims files lag 0.13.** `accepted_risks.md` AR-25, AR-27 and AR-28 still read "Accepted until 0.12.x"; claims.md "What we do not promise" still says leaf keys are not refreshed on a schedule (AR-25). Both files are outside this task's scope; they need the close-out update.
6. **Other id-ordered elections stay grindable.** 9.7 (vault coordinator, 2nd-lowest id) and 9.8 (recovery pool, lowest id) describe the code as it is; the 0.13 design review lists `vault/placement.rs` and `door_room::first_to_answer` as out of the standing change. The text is true; whether to promise more is a design decision.
7. **The circuit breaker is in shadow mode.** 12.5 now says so. When enforcement is switched on (0.14 at the latest), 12.5 and 23.1 need the enforced behaviour.
8. **TURN port lock depends on the deployment.** 12.6 says the official relay runs it and the setup wizard installs it. A hand-built or Docker relay whose lock failed at boot stays unlocked until `check-host.sh` or the next start (AR-32 residual); the text does not promise more than that, but a self-hoster might read it as automatic.
9. **AR-35 replay guard, presence digest, member cap, per-(master, device) revocation, friend re-add stamps.** Checked; none of them makes existing text false, and none is described in detail. No edit.